BÁO CÁO PHÁT HIỆN LỖI (DEFECT / BUG REPORT) – HỆ THỐNG ESHOP

> **Môn học:** Kiểm thử Phần mềm (CS423 / CSC13003) – FIT@HCMUS
> **Sinh viên thực hiện:** Nguyễn Quốc Kỳ
> **MSSV:** 23120138 – **Lớp:** 23CLC02
> **Bài tập:** HW02 – Domain Testing & Boundary Value Analysis
> **Hệ thống thử nghiệm (SUT):** EShop (Web, Admin, Mobile, Backend REST API)
> **Repository GitHub của nhóm:** Nhóm 11 – EShop Seminar & Testing
> **Tài liệu đối chiếu đặc tả:** `specs/system_requirements_specification.md`
> **Ngày báo cáo:** 18/10/2026

---

1. TỔNG HỢP & THỐNG KÊ LỖI (DEFECT METRICS DASHBOARD)

1.1 Thống Kê Theo Mức Độ Nghiêm Trọng (Severity) & Phân Hệ

Phân hệ / Pool	Mã FR	Tên tính năng	Critical	Major	Medium	Minor	Tổng số Bug
Pool A (Web/Auth)	**FR-02**	Đăng nhập & Khóa tài khoản	2	3	0	0	**5**
Pool B (Web/Cart)	**FR-07**	Giỏ hàng (Shopping Cart)	0	11	2	0	**13**
Pool C (Admin/Coupon)	**FR-17**	Quản lý Mã Giảm Giá	3	12	3	0	**18**
Pool D (Mobile/Order)	**FR-20 & FR-10**	Hủy đơn hàng theo trạng thái	1	1	1	0	**3**
TỔNG CỘNG			**6**	**27**	**6**	**0**	**39**

1.2 Bảng Ma Trận Truy Vết Lỗi (Traceability: Test Case ↔ Bug ID ↔ GitHub Issue)

Bug ID	Tóm tắt lỗi	Tính năng	TC phát hiện	Mức độ	GitHub Issue	Trạng thái
`BUG-FR02-01`	Bộ đếm số lần đăng nhập sai tăng 2 thay vì 1 đơn vị sau 1 lần thử sai	FR-02	`TC_FR02_03`	Major	Issue #4	Open
`BUG-FR02-02`	Khóa tài khoản sớm tại lần thử sai thứ 2 với thời gian phạt 180s thay vì 30s	FR-02	`TC_FR02_04`	Critical	Issue #5	Open

Bug ID	Tóm tắt lỗi	Tính năng	TC phát hiện	Mức độ	GitHub Issue	Trạng thái
BUG-FR02-03	Bộ đếm số lần đăng nhập sai nhảy vọt lên 4 thay vì 3 tại lần thử sai thứ 3	FR-02	TC_FR02_06	Major	Issue #6	Open
BUG-FR02-04	Đăng nhập bằng mật khẩu đúng trong khi đang bị khóa vẫn thành công và tự gỡ khóa	FR-02	TC_FR02_07	Critical	Issue #7	Open
BUG-FR02-05	Form đăng nhập dùng input type="text" cho email, bỏ qua hoàn toàn HTML5 format validation	FR-02	TC_FR02_14	Major	Issue #8	Open
BUG-FR07-01	Nút "Thêm vào giỏ hàng" tại trang chi tiết sản phẩm bỏ qua lần bấm đầu tiên	FR-07	TC_FR07_01	Major	Issue #9	Open
BUG-FR07-02	Thêm cùng sản phẩm tạo dòng mới riêng biệt thay vì tăng số lượng	FR-07	TC_FR07_02	Major	Issue #10	Open
BUG-FR07-03	Endpoint POST /api/cart chấp nhận ID sản phẩm không tồn tại (9999)	FR-07	TC_FR07_03	Major	Issue #11	Open
BUG-FR07-04	Endpoint POST /api/cart chấp nhận ID sai kiểu dữ liệu ("abc") không validate	FR-07	TC_FR07_04	Major	Issue #12	Open
BUG-FR07-05	Nhập số lượng 0 hệ thống vẫn chấp nhận, lưu bản ghi có thành tiền 0 ₫	FR-07	TC_FR07_05	Major	Issue #13	Open
BUG-FR07-06	Hệ thống chấp nhận số lượng âm (-1), hiển thị thành tiền âm trong giỏ	FR-07	TC_FR07_06	Major	Issue #14	Open
BUG-FR07-07	Xóa trống ô số lượng khiến giỏ hàng bị tính toán sai thành "NaN ₫"	FR-07	TC_FR07_07	Major	Issue #15	Open
BUG-FR07-08	Nhập số lượng thập phân (1.5) được chấp nhận, giao diện tự làm tròn xuống 1 và API trả về 200 OK	FR-07	TC_FR07_09	Major	Issue #16	Open
BUG-FR07-09	Endpoint POST /api/cart chấp nhận payload khuyết hoặc null trường quantity với 200 OK	FR-07	TC_FR07_10	Major	Issue #17	Open
BUG-FR07-10	Bảng giỏ hàng thiếu hoàn toàn nút +/- để điều chỉnh số lượng sản phẩm theo đặc tả	FR-07	TC_FR07_13, TC_FR07_14	Major	Issue #18	Open
BUG-FR07-11	Nút Xóa sản phẩm xóa trực tiếp không có dialog xác nhận theo yêu cầu SRS	FR-07	TC_FR07_15, TC_FR07_16, TC_FR07_19	Major	Issue #19	Open
BUG-FR07-12	Giao diện giỏ hàng trống chỉ có text thuần, thiếu hình ảnh minh họa theo đặc tả	FR-07	TC_FR07_17	Medium	Issue #20	Open

Bug ID	Tóm tắt lỗi	Tính năng	TC phát hiện	Mức độ	GitHub Issue	Trạng thái
BUG-FR07-13	Footer giỏ hàng hiển thị nhãn "Tổng tạm tính" thay vì "Tổng cộng" theo đặc tả	FR-07	TC_FR07_18	Medium	Issue #21	Open
BUG-FR17-01	Tạo trùng mã coupon gây lỗi unhandled HTTP 500 rò rỉ ngoại lệ SQLite	FR-17	TC_FR17_10	Major	Issue #22	Open
BUG-FR17-02	Endpoint POST /api/admin/coupons chấp nhận mã rỗng tạo coupon 200 OK	FR-17	TC_FR17_11	Major	Issue #23	Open
BUG-FR17-03	Nhập mã coupon chỉ chứa khoảng trắng được chấp nhận, hiển thị dòng trống trên bảng Admin	FR-17	TC_FR17_12	Major	Issue #24	Open
BUG-FR17-04	Endpoint POST /api/admin/coupons chấp nhận enum type không hợp lệ ('free_shipping') tạo coupon 200 OK	FR-17	TC_FR17_13	Major	Issue #25	Open
BUG-FR17-05	Form Admin và API cho phép tạo coupon giảm giá 0% (discount_value = 0)	FR-17	TC_FR17_14	Major	Issue #26	Open
BUG-FR17-06	Form Admin và API chấp nhận giá trị giảm giá âm (-10) cho loại percent	FR-17	TC_FR17_15	Major	Issue #27	Open
BUG-FR17-07	Form Admin và API chấp nhận tỷ lệ giảm giá vượt 100% (101%) cho loại percent	FR-17	TC_FR17_16	Major	Issue #28	Open
BUG-FR17-08	Form Admin và API cho phép tạo coupon giảm giá 0 ₫ (discount_value = 0) cho loại fixed	FR-17	TC_FR17_17	Major	Issue #29	Open
BUG-FR17-09	Form Admin và API chấp nhận đơn hàng tối thiểu âm (-1 ₫) và lưu vào CSDL	FR-17	TC_FR17_18	Major	Issue #30	Open
BUG-FR17-10	Endpoint POST /api/admin/coupons chấp nhận max_uses_per_user = 0 và tự ép thành 1 thay vì trả về HTTP 400	FR-17	TC_FR17_19	Major	Issue #31	Open
BUG-FR17-11	Endpoint POST /api/admin/coupons chấp nhận max_uses_per_user âm (-1) và lưu vào CSDL	FR-17	TC_FR17_20	Major	Issue #32	Open
BUG-FR17-12	Endpoint POST /api/admin/coupons thiếu authorizeAdmin cho phép user thường (role='user') tạo coupon	FR-17	TC_FR17_23	Critical	Issue #33	Open
BUG-FR17-13	Endpoint DELETE /api/admin/coupons/:id trả về 200 OK khi xóa ID không tồn tại (9999) thay vì 404 Not Found	FR-17	TC_FR17_24	Medium	Issue #34	Open
BUG-FR17-14	Endpoint DELETE /api/admin/coupons/:id chấp nhận ID âm (-1) trả về 200 OK thay vì 400/404	FR-17	TC_FR17_25	Medium	Issue #35	Open

Bug ID	Tóm tắt lỗi	Tính năng	TC phát hiện	Mức độ	GitHub Issue	Trạng thái
`BUG-FR17-15`	Endpoint DELETE /api/admin/coupons/:id chấp nhận ID dạng chuỗi ('abc') trả về 200 OK thay vì 400 Bad Request	FR-17	`TC_FR17_26`	Medium	Issue #36	Open
`BUG-FR17-16`	Công thức tính tiền giảm giá coupon loại percent bị đảo ngược khiến tổng thanh toán tăng gấp 10 lần	FR-17	`TC_FR17_27`	Critical	Issue #37	Open
`BUG-FR17-17`	Endpoint /api/apply-coupon từ chối đơn hàng bằng đúng ngưỡng tối thiểu tại điểm biên On-point	FR-17	`TC_FR17_30`	Major	Issue #38	Open
`BUG-FR17-18`	Endpoint /api/apply-coupon cho phép số tiền thanh toán bị âm khi mức giảm vượt quá giá trị đơn	FR-17	`TC_FR17_34`	Critical	Issue #39	Open
`BUG-FR20-01`	Endpoint PUT /api/orders/:id/cancel cho phép khách hàng tự hủy đơn ở trạng thái shipping	FR-20	`TC_MOB_05`	Critical	Issue #40	Open
`BUG-FR20-02`	Endpoint PUT /api/orders/:id/cancel chấp nhận trạng thái dị thường (corrupted_state) và đổi thành canceled	FR-20	`TC_MOB_08`	Medium	Issue #41	Open
`BUG-FR20-03`	Nút Hủy đơn trên Mobile App không hiển thị hộp thoại xác nhận Alert, kích hoạt hủy ngay khi bấm	Mobile	`TC_MOB_23`	Major	Issue #42	Open

---

2. BÁO CÁO CHI TIẾT TỪNG LỖI (DETAILED DEFECT TICKETS)

2.1 Các lỗi thuộc Pool A: FR-02 – Đăng nhập & Khóa tài khoản

[BUG-FR02-01] Bộ đếm số lần đăng nhập sai tăng 2 thay vì 1 đơn vị sau 1 lần thử sai

Trường thông tin	Chi tiết
Bug ID	`BUG-FR02-01`
Tiêu đề Bug	`[FR-02][Backend API / SQLite DB] Failure counter increments by 2 instead of 1 upon invalid login attempt`
Chức năng (Feature)	FR-02: Đăng nhập & Khóa tài khoản (Pool A)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v18.19 • Linux
Mức độ (Severity)	**Major** (Sai lệch ngưỡng bảo mật khiến tài khoản bị khóa sớm ngoài ý muốn)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR02_03` (Thử sai lần 1 $N = 1$)

Trường thông tin	Chi tiết
GitHub Issue Link	Issue #4: [BUG] [FR-02][Backend API / SQLite DB] Failure counter increments by 2 instead of 1 upon invalid login attempt
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- Tài khoản người dùng `test@eshop.com` tồn tại trong SQLite database với `login_attempts = 0`, `locked_until = NULL`.
- Backend server đang chạy tại `http://localhost:3000`.

2. Các bước tái hiện (Steps to Reproduce):

1. Gửi yêu cầu đăng nhập với email hợp lệ `test@eshop.com` và mật khẩu không chính xác `WrongPass1!`:

```
curl -i -s -X POST http://localhost:3000/api/login \
  -H "Content-Type: application/json" \
  -d '{"email":"test@eshop.com","password":"WrongPass1!"}'
```

2. Truy vấn SQLite kiểm tra giá trị cột `login_attempts` của tài khoản `test@eshop.com`:

```
SELECT id, email, login_attempts, locked_until FROM users WHERE email='test@eshop.com';
```

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "email": "test@eshop.com",
  "password": "WrongPass1!"
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-02):

> *Trích dẫn SRS FR-02 (Item 2):* "Sau mỗi lần đăng nhập sai, hệ thống tăng bộ đếm số lần đăng nhập sai liên tiếp lên đúng 1 đơn vị."

- Endpoint `POST /api/login` trả về HTTP `401 Unauthorized`.
- Trong CSDL SQLite, trường `login_attempts` phải tăng từ `0` lên **đúng** `1` ($N=1$). Trường `locked_until` tiếp tục giữ nguyên là `NULL`.

5. Kết quả thực tế (Actual Result):

- Endpoint `POST /api/login` trả về HTTP `401 Unauthorized` (`{"error":"Invalid email or password"}`).
- Tuy nhiên trong SQLite CSDL, trường `login_attempts` tăng từ `0` lên `2` ($N=2$) chỉ sau đúng 1 lần thử sai duy nhất. Điều này vi phạm quy tắc đếm tuần tự của SRS và khiến tài khoản bị khóa chỉ sau 2 lần thử sai thay vì 3 lần.
- HTTP Status Code: `401 Unauthorized`
- Database Mutation: `login_attempts` = 2, `locked_until` = null

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp bằng chứng terminal & database:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/4

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:** File `backend/server.js`, dòng 54.
- **Đoạn mã gây lỗi:**

```
const newAttempts = user.login_attempts + 2;
```

- **Khắc phục:** Sửa phép cộng thành tăng 1 đơn vị:

```
const newAttempts = user.login_attempts + 1;
```

[BUG-FR02-02] Khóa tài khoản sớm tại lần thử sai thứ 2 với thời gian phạt 180s thay vì 30s

Trường thông tin	Chi tiết
Bug ID	`BUG-FR02-02`
Tiêu đề Bug	`[FR-02][Backend API / SQLite DB] Premature account lockout triggered at attempt N=2 with excessive 180s duration`
Chức năng (Feature)	FR-02: Đăng nhập & Khóa tài khoản (Pool A)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v18.19 • Linux
Mức độ (Severity)	**Critical** (Khóa oan tài khoản người dùng hợp lệ và phạt thời gian vượt mức 6 lần quy định)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR02_04` (Thử sai lần 2 - Biên Off-point trước ngưỡng khóa)
GitHub Issue Link	Issue #5: [BUG] [FR-02][Backend API / SQLite DB] Premature account lockout triggered at attempt N=2 with excessive 180s duration

Trường thông tin	Chi tiết
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- Tài khoản người dùng `test@eshop.com` đang tích lũy 1 lần đăng nhập sai trước đó: `login_attempts = 1`, `locked_until = NULL`.
- SUT backend đang chạy tại `http://localhost:3000`.

2. Các bước tái hiện (Steps to Reproduce):

1. Gửi yêu cầu đăng nhập lần thứ 2 với email `test@eshop.com` và mật khẩu không chính xác `WrongPass2!`:

```
curl -i -s -X POST http://localhost:3000/api/login \
  -H "Content-Type: application/json" \
  -d '{"email":"test@eshop.com","password":"WrongPass2!"}'
```

2. Truy vấn SQLite kiểm tra giá trị hai cột `login_attempts` và `locked_until` của tài khoản `test@eshop.com`:

```
SELECT id, email, login_attempts, locked_until FROM users WHERE email='test@eshop.com';
```

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "email": "test@eshop.com",
  "password": "WrongPass2!"
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-02):

> *Trích dẫn SRS FR-02 (Mục 2 & 3):* "Sau mỗi lần đăng nhập sai, hệ thống tăng bộ đếm số lần đăng nhập sai liên tiếp lên đúng 1 đơn vị. Nếu đăng nhập sai từ 3 lần trở lên liên tiếp, tài khoản bị tạm khóa 30 giây (môi trường demo)."

- Tại lần thử sai thứ 2 ($N=2$, điểm Off-point trước ngưỡng khóa 3):
  - HTTP Status: `401 Unauthorized` (`{"error": "Invalid email or password"}`).
  - Trong CSDL SQLite: `login_attempts` phải tăng từ `1` lên **đúng** `2` ($N=2$).
  - Trường `locked_until` phải tiếp tục giữ nguyên là `NULL` (chưa kích hoạt khóa).
- Khi tài khoản đạt ngưỡng khóa ($N=3$), thời hạn phạt chỉ được là 30 giây.

5. Kết quả thực tế (Actual Result):

- Endpoint `POST /api/login` trả về HTTP `401 Unauthorized`.
- Tuy nhiên trong CSDL SQLite:
  - `login_attempts` bị tăng vọt từ `1` lên **`3`** (do lỗi logic `+ 2`).
  - Do `newAttempts >= 3`, hệ thống kích hoạt khóa tài khoản non ngay tại lần thử thứ 2 ($N=2$).

    - Thời hạn khóa `locked_until` bị đặt thành **180 giây** (`2026-10-18T17:38:17.793Z` so với thời điểm gửi `17:35:17 GMT`), dài gấp 6 lần quy định 30 giây của SRS.
- HTTP Status Code: `401 Unauthorized`
- Database Mutation: `login_attempts` = 3, `locked_until` = `2026-10-18T17:38:17.793Z` (+180s)

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp bằng chứng terminal & database:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/5

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:** File `backend/server.js`, dòng 54–58.
- **Đoạn mã gây lỗi:**

```
const newAttempts = user.login_attempts + 2;
let lockedUntil = null;
if (newAttempts >= 3) {
  lockedUntil = new Date(Date.now() + 180000).toISOString();
}
```

- **Khắc phục:**
    1. Đổi phép cộng sang tăng 1 đơn vị: `user.login_attempts + 1`.
    2. Đổi thời gian khóa về đúng 30 giây theo SRS demo: `Date.now() + 30000`.

```
const newAttempts = user.login_attempts + 1;
let lockedUntil = null;
if (newAttempts >= 3) {
  lockedUntil = new Date(Date.now() + 30000).toISOString();
}
```

[BUG-FR02-03] Bộ đếm số lần đăng nhập sai nhảy vọt lên 4 thay vì 3 tại lần thử sai thứ 3

Trường thông tin	Chi tiết
Bug ID	`BUG-FR02-03`
Tiêu đề Bug	`[FR-02][Backend API / SQLite DB] Failure counter jumps to 4 instead of 3 upon reaching consecutive failure threshold`

Trường thông tin	Chi tiết
Chức năng (Feature)	FR-02: Đăng nhập & Khóa tài khoản (Pool A)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v18.19 • Linux
Mức độ (Severity)	**Major** (Sai lệch trạng thái bộ đếm bảo mật tại điểm On-point kích hoạt ngưỡng khóa)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR02_06` (Thử sai lần 3 - Điểm biên On-point kích hoạt ngưỡng khóa $N = 3$)
GitHub Issue Link	Issue #6: [BUG] [FR-02][Backend API / SQLite DB] Failure counter jumps to 4 instead of 3 upon reaching consecutive failure threshold
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- Tài khoản người dùng `test@eshop.com` đang tích lũy 2 lần đăng nhập sai trước đó: `login_attempts = 2`, `locked_until = NULL`.
- SUT backend đang hoạt động tại `http://localhost:3000`.

2. Các bước tái hiện (Steps to Reproduce):

1. Gửi yêu cầu đăng nhập lần thứ 3 liên tiếp với email `test@eshop.com` và mật khẩu không chính xác `WrongPass3!`:

```
curl -i -s -X POST http://localhost:3000/api/login \
  -H "Content-Type: application/json" \
  -d '{"email":"test@eshop.com","password":"WrongPass3!"}'
```

2. Truy vấn SQLite kiểm tra giá trị hai cột `login_attempts` và `locked_until` của tài khoản `test@eshop.com`:

```
SELECT id, email, login_attempts, locked_until FROM users WHERE email='test@eshop.com';
```

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "email": "test@eshop.com",
  "password": "WrongPass3!"
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-02):

> *Trích dẫn SRS FR-02 (Mục 2 & 3):* "Sau mỗi lần đăng nhập sai, hệ thống tăng bộ đếm số lần đăng nhập sai liên tiếp lên đúng 1 đơn vị. Nếu đăng nhập sai từ 3 lần trở lên liên tiếp, tài khoản bị tạm khóa 30 giây (môi trường demo)."

- Tại lần thử sai thứ 3 ($N=3$, điểm On-point kích hoạt ngưỡng khóa):
  - HTTP Status: `401 Unauthorized` hoặc `403 Forbidden`.
  - Trong CSDL SQLite: `login_attempts` phải tăng từ `2` lên **đúng** `3` ($N=3$).
  - Trường `locked_until` được gán mốc hết hạn đúng $T_{trigger} + 30\text{ giây}$.

5. Kết quả thực tế (Actual Result):

- Endpoint `POST /api/login` trả về HTTP `401 Unauthorized`.
- Trong CSDL SQLite:
  - `login_attempts` bị tăng vọt từ `2` lên `4` ($N=4$) do lỗi logic `user.login_attempts + 2`.
  - `locked_until` được gán giá trị thời gian 180 giây (3 phút) sau đó thay vì 30 giây.
- HTTP Status Code: `401 Unauthorized`
- Database Mutation: `login_attempts` = 4, `locked_until` = `2026-10-18T17:49:37.416Z`

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp bằng chứng terminal & database:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/6

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:** File `backend/server.js`, dòng 54.
- **Đoạn mã gây lỗi:**

```
const newAttempts = user.login_attempts + 2;
```

- **Khắc phục:** Sửa phép cộng thành tăng 1 đơn vị:

```
const newAttempts = user.login_attempts + 1;
```

[BUG-FR02-04] Đăng nhập bằng mật khẩu đúng trong khi đang bị khóa vẫn thành công và tự gỡ khóa

Trường thông tin	Chi tiết
Bug ID	`BUG-FR02-04`

Trường thông tin	Chi tiết
Tiêu đề Bug	`[FR-02][Backend API / Security] Correct password bypasses active account lockout and clears lockout state`
Chức năng (Feature)	FR-02: Đăng nhập & Khóa tài khoản (Pool A)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v18.19 • Linux
Mức độ (Severity)	**Critical** (Lỗ hổng bảo mật nghiêm trọng: Bỏ qua cơ chế khóa tài khoản và tự giải phóng trạng thái phạt)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR02_07` (Thử đăng nhập bằng mật khẩu đúng trong thời gian khóa)
GitHub Issue Link	Issue #7: [BUG] [FR-02][Backend API / Security] Correct password bypasses active account lockout and clears lockout state
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- Tài khoản người dùng `test@eshop.com` đang trong thời gian bị tạm khóa (`locked_until` có giá trị trong tương lai).
- SUT backend đang chạy tại `http://localhost:3000`.

2. Các bước tái hiện (Steps to Reproduce):

1. Kiểm tra CSDL SQLite để xác nhận mốc `locked_until` của tài khoản `test@eshop.com` đang có hiệu lực trong tương lai.
2. Gửi yêu cầu đăng nhập với email `test@eshop.com` và mật khẩu đúng `Test1234!` trong thời gian tài khoản đang bị khóa:

```
curl -i -s -X POST http://localhost:3000/api/login \
  -H "Content-Type: application/json" \
  -d '{"email":"test@eshop.com","password":"Test1234!"}'
```

3. Truy vấn lại CSDL SQLite để kiểm tra xem tài khoản có bị gỡ khóa sớm hay không:

```
SELECT id, email, login_attempts, locked_until FROM users WHERE email='test@eshop.com';
```

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "email": "test@eshop.com",
  "password": "Test1234!"
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-02):

> *Trích dẫn SRS FR-02 (Mục 3):* "Trong thời gian tài khoản bị tạm khóa, mọi yêu cầu đăng nhập (kể cả khi nhập đúng thông tin) đều bị hệ thống từ chối."

- Endpoint `POST /api/login` trả về HTTP `403 Forbidden` (`{"error": "Tài khoản đã bị khóa. Vui lòng thử lại sau."}`).
- Tuyệt đối không cấp JWT token cho phiên làm việc.
- Trong CSDL SQLite, trường `locked_until` phải giữ nguyên, không được tự ý xóa hoặc mở khóa sớm.

5. Kết quả thực tế (Actual Result):

- Endpoint `POST /api/login` trả về HTTP `200 OK` (`{"message": "Login successful"}`).
- Cấp JWT token hợp lệ và cho phép người dùng đăng nhập thành công vào hệ thống.
- Trong CSDL SQLite, trường `locked_until` bị xóa về `NULL`, chấm dứt thời gian phạt khóa tài khoản ngay lập tức.
- HTTP Status Code: `200 OK`
- Database Mutation: `locked_until` = null (mở khóa trái phép)

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp bằng chứng terminal & database:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/7

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:** File `backend/server.js`, dòng 40–52.
- **Đoạn mã gây lỗi:**

```
if (user.locked_until && new Date() < new Date(user.locked_until)) {
  return res
    .status(403)
    .json({ error: "Tài khoản đã bị khóa. Vui lòng thử lại sau." });
}

if (user.password === password) {
  db.run(
    "UPDATE users SET login_attempts = 0, locked_until = NULL WHERE id = ?",
    [user.id],
  );
  const token = jwt.sign({ id: user.id, role: user.role }, SECRET_KEY);
  res.json({ message: "Login successful", token, user });
}
```

- **Nguyên nhân:**
  1. Khi chuỗi `locked_until` trong SQLite không có hậu tố `Z`, JavaScript diễn giải theo giờ Local (GMT+7), làm lệch 7 giờ so với `new Date()` (UTC), khiến điều kiện `new Date() < new Date(user.locked_until)` bị sai (false).
  2. Khi vượt qua điều kiện kiểm tra, khối `if (user.password === password)` lập tức thực thi câu lệnh SQL xóa `locked_until = NULL`, làm sụp đổ hoàn toàn cơ chế khóa bảo mật.
- **Khắc phục:** Chuẩn hóa so sánh múi giờ UTC hoặc ép định dạng ISO, và chặn hoàn toàn nhánh reset khi đang trong thời gian khóa:

```
const lockedTime = user.locked_until ? new Date(user.locked_until.includes('T') ? user.locked_until : user.
locked_until.replace(' ', 'T') + 'Z') : null;
if (lockedTime && new Date() < lockedTime) {
  return res
    .status(403)
    .json({ error: "Tài khoản đã bị khóa. Vui lòng thử lại sau." });
}
```

[BUG-FR02-05] Form đăng nhập dùng input type="text" cho email, bỏ qua hoàn toàn HTML5 format validation

Trường thông tin	Chi tiết
Bug ID	`BUG-FR02-05`
Tiêu đề Bug	`[FR-02][Web UI] Email input uses type="text" instead of type="email", bypassing HTML5 format validation`
Chức năng (Feature)	FR-02: Đăng nhập & Khóa tài khoản (Pool A) / Web Client UI
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v18.19 • Linux
Mức độ (Severity)	**Major** (Bỏ qua cơ chế validate định dạng email client-side bắt buộc theo đặc tả SRS)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR02_14` (Single-Fault Boundary: Email thiếu ký tự `@`)
GitHub Issue Link	Issue #8: [BUG] [FR-02][Web UI] Email input uses type="text" instead of type="email", bypassing HTML5 format validation

Trường thông tin	Chi tiết
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT Web frontend đang chạy tại `http://localhost:5173`.
- Người dùng truy cập trang đăng nhập `http://localhost:5173/login`.

2. Các bước tái hiện (Steps to Reproduce):

1. Mở trang đăng nhập tại `http://localhost:5173/login`.
2. Tại trường nhập liệu email đầu tiên (đang gắn nhãn sai là "Username"), nhập chuỗi email không hợp lệ thiếu `@`: `testeshop.com`.
3. Tại ô mật khẩu, nhập `Test1234!`.
4. Bấm nút "Sign In" (hoặc nhấn Enter).

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "email": "testeshop.com",
  "password": "Test1234!"
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-02):

> *Trích dẫn SRS FR-02 (Mục 5):* "Trường email phải dùng `type="email"` (có validate HTML5 format)."

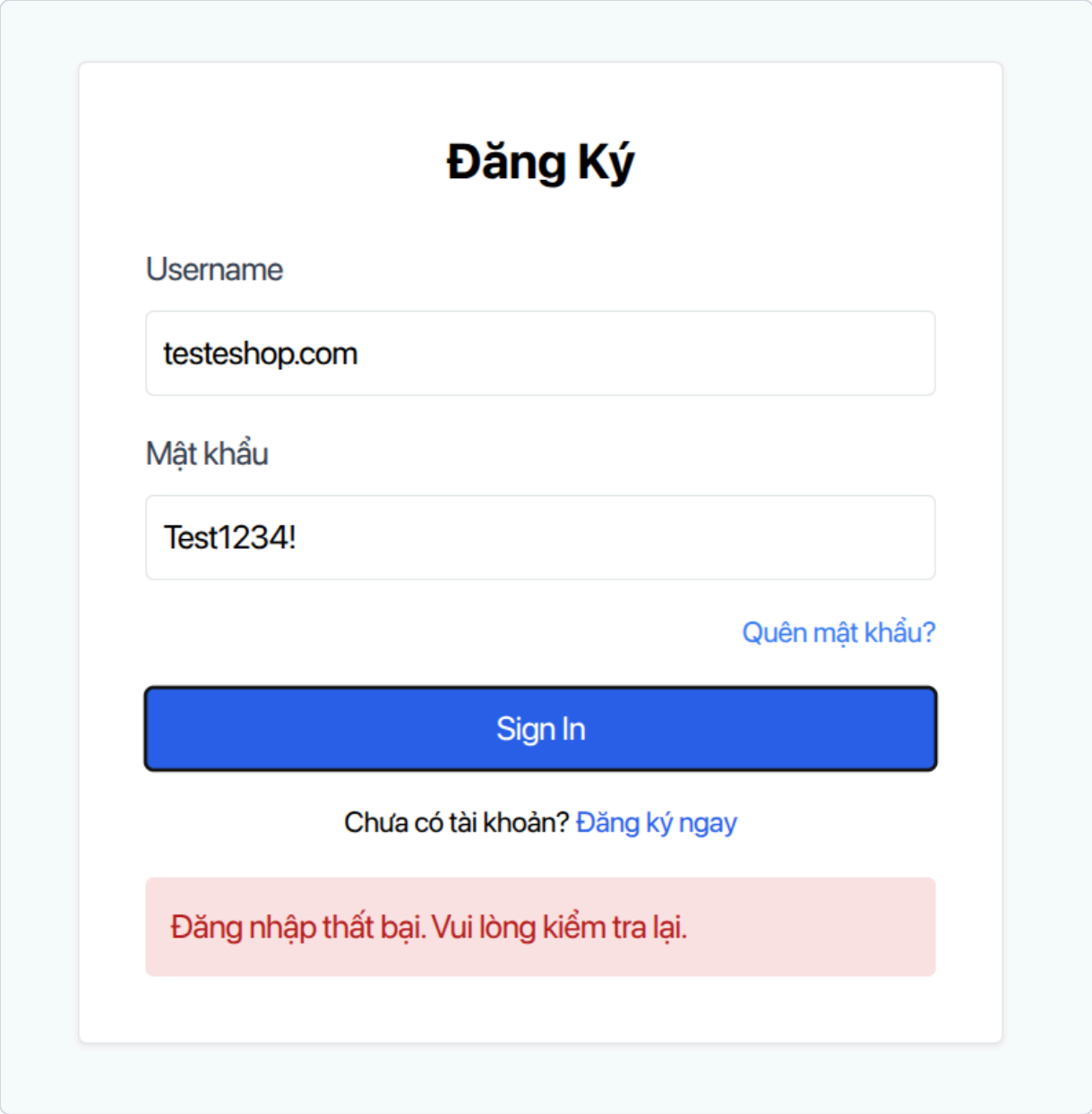
- Trình duyệt hiển thị tooltip/cảnh báo HTML5: *"Please include an '@' in the email address..."* (hoặc tiếng Việt tương đương).
- Form bị chặn gửi ở Client, không gửi HTTP POST `/api/login` lên backend khi định dạng email sai.

5. Kết quả thực tế (Actual Result):

- Trường nhập email được lập trình với `type="text"` (nhãn là "Username") thay vì `type="email"`.
- Trình duyệt không kích hoạt HTML5 format validation, cho phép submit thẳng payload `testeshop.com` lên server.
- Backend nhận request sai định dạng và trả về HTTP `401 Unauthorized` (`{"error":"Invalid email or password"}`).
- *(Các lỗi giao diện liên quan phát hiện đồng thời: Tiêu đề trang đăng nhập hiển thị "Đăng Ký" thay vì "Đăng Nhập", và ô mật khẩu dùng `type="text"` làm lộ plaintext password).*
- HTTP Status Code: `401 Unauthorized`
- Client Behavior: Không kích hoạt HTML5 format validation

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp bằng chứng giao diện Web UI & API:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/8

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:** File `frontend-web/src/pages/Login.jsx`, các dòng 24, 28–35, 38–46.
- **Đoạn mã gây lỗi:**

```
<h2 className="text-2xl font-bold mb-6 text-center">Đăng Ký</h2>
<form onSubmit={handleSubmit} className="space-y-4">
  <div>
    <label className="block text-gray-700 mb-2">Username</label>
    <input
      type="text"
      value={email}
      onChange={(e) => setEmail(e.target.value)}
      className="w-full border p-2 rounded"
      required
    />
  </div>
```

- **Khắc phục:** Sửa type thành `email`, nhãn thành "Email", sửa tiêu đề "Đăng Nhập", và ô mật khẩu dùng `type="password"`:

```
<h2 className="text-2xl font-bold mb-6 text-center">Đăng Nhập</h2>
<form onSubmit={handleSubmit} className="space-y-4">
  <div>
    <label className="block text-gray-700 mb-2">Email</label>
    <input
      type="email"
      value={email}
      onChange={(e) => setEmail(e.target.value)}
      className="w-full border p-2 rounded"
      required
    />
  </div>
```

2.2 Các lỗi thuộc Pool B: FR-07 – Giỏ hàng (Shopping Cart)

[BUG-FR07-01] Nút "Thêm vào giỏ hàng" tại trang chi tiết sản phẩm bỏ qua lần bấm đầu tiên

Trường thông tin	Chi tiết
Bug ID	`BUG-FR07-01`
Tiêu đề Bug	`[FR-07][Web UI] Add to cart button on Product Detail page ignores first click`
Chức năng (Feature)	FR-07: Giỏ hàng (Shopping Cart - Pool B)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Làm gián đoạn luồng đặt hàng chính của khách hàng)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR07_01` (Verify adding a new valid product to empty cart)
GitHub Issue Link	Issue #9: [BUG] [FR-07][Web UI] Add to cart button on Product Detail page ignores first click
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- Giỏ hàng của người dùng đang hoàn toàn trống (`cart.length === 0`).
- SUT backend và frontend-web đang chạy tại `:3000` và `:5173`.
- CSDL có sản phẩm ID 1 (`iPhone 15 Pro Max`).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở trình duyệt, truy cập trang chi tiết sản phẩm: `http://localhost:5173/product/1`.
2. Giữ nguyên số lượng mặc định là `1`.
3. Nhấn nút "Thêm vào giỏ hàng" **1 lần duy nhất**.
4. Quan sát phản hồi trên giao diện (nút không chuyển sang "Đã thêm").
5. Nhấn vào mục "Giỏ hàng" trên thanh Header (`http://localhost:5173/cart`).

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "product_id": 1,
  "quantity": 1
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-07):

> *Trích dẫn SRS FR-07 (Mục 1):* "Hiển thị danh sách sản phẩm với các cột: Sản phẩm, Đơn giá, Số lượng (có nút +/- để chỉnh), Thành tiền, Thao tác."

- Khi nhấn nút "Thêm vào giỏ hàng" trên trang chi tiết sản phẩm, nút phải đổi trạng thái xác nhận thành công ("Đã thêm"), sản phẩm được cập nhật vào CartContext.
- Trang giỏ hàng `/cart` hiển thị bảng gồm 1 dòng sản phẩm iPhone 15 Pro Max, đơn giá 30.000.000 ₫, số lượng 1, thành tiền 30.000.000 ₫ và tổng tiền 30.000.000 ₫.

5. Kết quả thực tế (Actual Result):

- Khi người dùng nhấn "Thêm vào giỏ hàng" lần đầu tiên, giao diện hoàn toàn không có phản hồi và sản phẩm không hề được đưa vào giỏ hàng.
- Khi điều hướng sang `/cart`, màn hình hiển thị: *"Giỏ hàng của bạn đang trống"*.
- Người dùng buộc phải nhấn nút lần thứ 2 liên tiếp thì sản phẩm mới được thêm vào.
- State Client: `cart` vẫn là mảng rỗng `[]` sau lần bấm đầu tiên.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp bằng chứng giao diện Web UI:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/9

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:** File `frontend-web/src/pages/ProductDetail.jsx`, các dòng 21–25.
- **Đoạn mã gây lỗi:**

```
const handleAddToCart = () => {
  if (clickCount === 0) {
    setClickCount(1);
    return; // Không làm gì cả ở lần đầu tiên
  }

  addToCart(product, parseInt(quantity));
  setAdded(true);
  setClickCount(0); // Reset lại
  setTimeout(() => setAdded(false), 2000);
};
```

- **Khắc phục:** Loại bỏ điều kiện `clickCount === 0`, kích hoạt `addToCart` ngay trong lần nhấn đầu:

```
const handleAddToCart = () => {
  addToCart(product, parseInt(quantity));
  setAdded(true);
  setTimeout(() => setAdded(false), 2000);
};
```

[BUG-FR07-02] Thêm cùng sản phẩm tạo dòng mới riêng biệt thay vì tăng số lượng

Trường thông tin	Chi tiết
Bug ID	`BUG-FR07-02`
Tiêu đề Bug	`[FR-07][Web UI] Adding duplicate product creates new row instead of incrementing quantity`
Chức năng (Feature)	FR-07: Giỏ hàng (Shopping Cart - Pool B)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Vi phạm trực tiếp quy tắc gộp dòng sản phẩm theo SRS FR-07)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR07_02` (Verify adding duplicate product increments quantity without creating new row)
GitHub Issue Link	Issue #10: [BUG] [FR-07][Web UI] Adding duplicate product creates new row instead of incrementing quantity
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- Hệ thống backend và web đang hoạt động bình thường.
- Giỏ hàng của người dùng đã có sẵn 1 sản phẩm ID 1 (`iPhone 15 Pro Max`) với số lượng $Q = 1$.

2. Các bước tái hiện (Steps to Reproduce):

1. Đảm bảo giỏ hàng đã có 1 sản phẩm `iPhone 15 Pro Max` ($Q=1$).
2. Từ trang chủ hoặc trang sản phẩm, thực hiện thao tác thêm tiếp sản phẩm `iPhone 15 Pro Max` lần thứ hai ($Q_{add}=1$).
3. Điều hướng vào trang giỏ hàng `http://localhost:5173/cart`.
4. Quan sát cấu trúc các dòng trong bảng giỏ hàng.

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "product_id": 1,
  "quantity_added": 1
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-07):

> *Trích dẫn SRS FR-07 (Mục 2):* "Thêm cùng một sản phẩm vào giỏ sẽ tăng số lượng, không tạo dòng mới."

- Bảng giỏ hàng duy trì **chính xác 1 dòng duy nhất** cho sản phẩm `iPhone 15 Pro Max`.
- Cột Số lượng tự động cộng dồn: $Q = 1 + 1 = 2$.
- Cột Thành tiền: $30.000.000 \times 2 = 60.000.000\text{ đ}$.
- Tổng tiền hiển thị $60.000.000\text{ đ}$.

5. Kết quả thực tế (Actual Result):

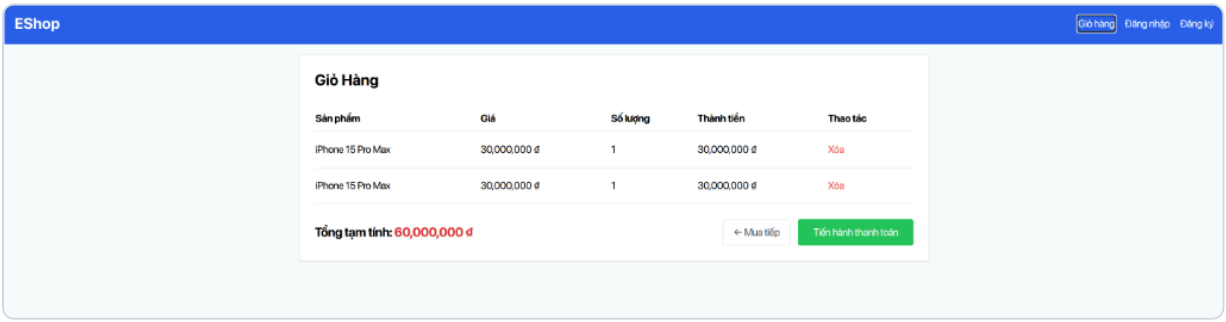
- Bảng giỏ hàng sinh ra **dòng thứ hai riêng biệt** cho cùng sản phẩm `iPhone 15 Pro Max`.
- Cả hai dòng đều hiển thị `Sô´lượng: 1` và `Thành tiền: 30,000,000 ₫`.
- Mặc dù tổng tiền cộng đúng thành $60.000.000\text{ đ}$, nhưng việc tách thành 2 dòng riêng biệt vi phạm nghiêm trọng quy chuẩn UX và logic giỏ hàng của SRS.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp trước khi thêm (1 dòng):*



- *Ảnh chụp sau khi thêm trùng lặp (Lỗi 2 dòng):*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/10

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:** File `frontend-web/src/context/CartContext.jsx`, các dòng 8–10.
- **Đoạn mã gây lỗi:**

```
const addToCart = (product, quantity) => {
  setCart([...cart, { ...product, quantity }]);
};
```

- **Khắc phục:** Kiểm tra nếu sản phẩm đã tồn tại thì cộng dồn `quantity`, ngược lại mới append phần tử mới:

```
const addToCart = (product, quantity) => {
  const existingIndex = cart.findIndex((item) => item.id === product.id);
  if (existingIndex > -1) {
    const newCart = [...cart];
    newCart[existingIndex].quantity += quantity;
    setCart(newCart);
  } else {
    setCart([...cart, { ...product, quantity }]);
  }
};
```

[BUG-FR07-03] Endpoint POST /api/cart chấp nhận ID sản phẩm không tồn tại (9999) mà không kiểm tra CSDL

Trường thông tin	Chi tiết
Bug ID	`BUG-FR07-03`
Tiêu đề Bug	`[FR-07][Backend API] Endpoint POST /api/cart accepts non-existent product ID (9999) without validation`
Chức năng (Feature)	FR-07: Giỏ hàng (Shopping Cart API - Pool B)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Lỗi toàn vẹn dữ liệu: cho phép lưu sản phẩm rác/không tồn tại vào giỏ hàng người dùng)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR07_03` (Validate rejection when adding well-formed non-existent product ID)
GitHub Issue Link	Issue #11: [BUG] [FR-07][Backend API] Endpoint POST /api/cart accepts non-existent product ID (9999) without validation
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- Backend EShop đang chạy tại cổng `:3000`.
- Người dùng `test@eshop.com` có JWT Bearer token hợp lệ.
- CSDL SQLite hoàn toàn không chứa sản phẩm có `id = 9999`.

2. Các bước tái hiện (Steps to Reproduce):

1. Lấy Bearer token đăng nhập cho tài khoản `test@eshop.com`.
2. Gửi request HTTP `POST /api/cart` kèm payload chứa `id = 9999`:

```
curl -i -s -X POST http://localhost:3000/api/cart \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{"id": 9999, "price": 100000, "quantity": 1}'
```

3. Gửi request `GET http://localhost:3000/api/cart` để kiểm tra giỏ hàng người dùng.
4. (Giao diện Web): Truy cập `http://localhost:5173/product/9999`.

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "id": 9999,
  "price": 100000,
  "quantity": 1
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-07 & API Spec §4.2):

> *Trích dẫn API Spec §4.2 & SRS FR-07:* "Từ chối thêm sản phẩm không tồn tại vào giỏ hàng."

- Backend bắt buộc phải truy vấn CSDL SQLite kiểm tra sự tồn tại của sản phẩm trước khi cập nhật giỏ hàng.
- Endpoint `POST /api/cart` phải từ chối request với mã lỗi HTTP `404 Not Found` hoặc `400 Bad Request` (`{"error": "Product not found"}`).
- Giỏ hàng của người dùng không được phép chứa ID 9999.

5. Kết quả thực tế (Actual Result):

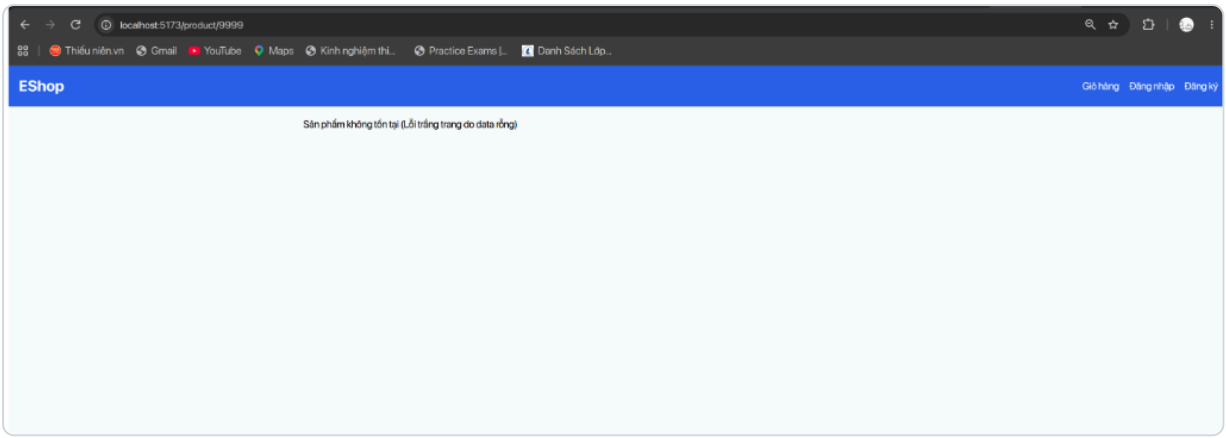
- Endpoint `POST /api/cart` trả về HTTP `200 OK` (`{"message":"Added to cart"}`).
- Gọi `GET /api/cart` phát hiện bản ghi rác `{"id":9999, "price":100000, "quantity":1}` đã bị chèn trực tiếp vào mảng giỏ hàng của user.
- Trên giao diện Web:
  - Route `/product/9999` hiển thị thông báo thô: `"Sản phẩm không tồn tại (Lỗi trắng trang do data rỗng)"` do dev hardcode.
  - Route số nhiều `/products/9999` bị trắng trang hoàn toàn.

6. Bằng chứng kiểm thử (Screenshots & Logs):

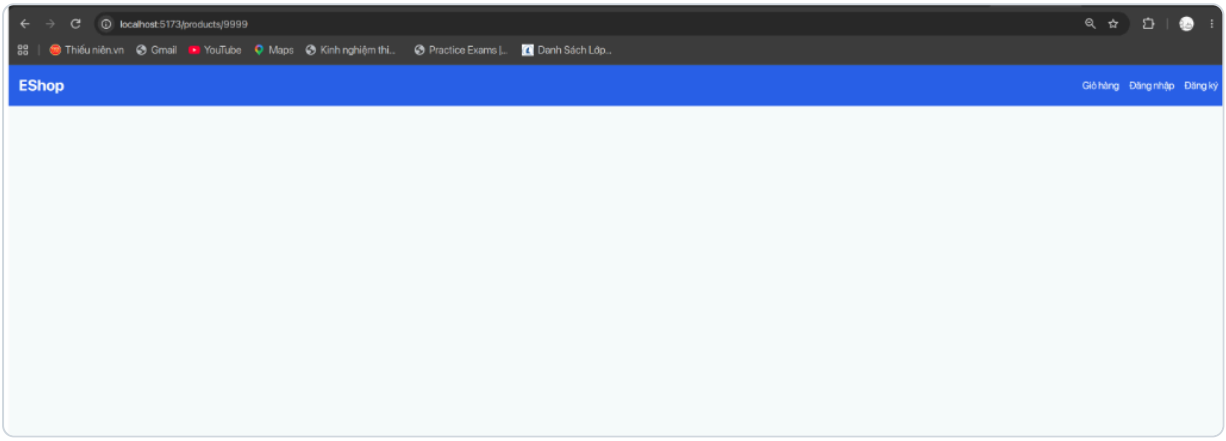
- *Ảnh chụp terminal kiểm thử API (200 OK & chèn bản ghi 9999):*



- *Ảnh chụp Web UI /product/9999:*



- *Ảnh chụp Web UI /products/9999 (Trắng trang):*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/11

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:** File `backend/server.js`, các dòng 290–295.
- **Đoạn mã gây lỗi:**

```
app.post("/api/cart", authenticateToken, (req, res) => {
  const userId = req.user.id;
  if (!userCarts[userId]) userCarts[userId] = [];
  userCarts[userId].push(req.body);
  res.json({ message: "Added to cart" });
});
```

- **Khắc phục:** Thêm bước kiểm tra CSDL SQLite trước khi thêm vào giỏ:

```
app.post("/api/cart", authenticateToken, (req, res) => {
  const userId = req.user.id;
  const { id, quantity } = req.body;
  if (!id) return res.status(400).json({ error: "Product ID is required" });

  db.get("SELECT id, name, price FROM products WHERE id = ?", [id], (err, product) => {
    if (err) return res.status(500).json({ error: err.message });
    if (!product) return res.status(404).json({ error: "Product not found" });

    if (!userCarts[userId]) userCarts[userId] = [];
    userCarts[userId].push({ ...product, quantity: quantity || 1 });
    res.json({ message: "Added to cart" });
  });
});
```

[BUG-FR07-04] Endpoint POST /api/cart chấp nhận ID sai kiểu dữ liệu ("abc") mà không thực hiện Schema Validation

Trường thông tin	Chi tiết
Bug ID	`BUG-FR07-04`
Tiêu đề Bug	`[FR-07][Backend API] Endpoint POST /api/cart accepts malformed non-numeric product ID ("abc") without validation`
Chức năng (Feature)	FR-07: Giỏ hàng (Shopping Cart API - Pool B)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Vi phạm Schema/Type Validation, dẫn tới sai lệch kiểu dữ liệu trong state hệ thống)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR07_04` (Validate rejection when submitting malformed product ID via API)
GitHub Issue Link	Issue #12: [BUG] [FR-07][Backend API] Endpoint POST /api/cart accepts malformed non-numeric product ID ("abc") without validation
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại cổng `:3000`.
- Người dùng `test@eshop.com` có JWT Bearer token hợp lệ.

2. Các bước tái hiện (Steps to Reproduce):

1. Lấy Bearer token đăng nhập cho tài khoản `test@eshop.com`.
2. Gửi request HTTP `POST /api/cart` kèm payload chứa `id = "abc"` (chuỗi ký tự):

```
curl -i -s -X POST http://localhost:3000/api/cart \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{"id": "abc", "price": 100000, "quantity": 1}'
```

3. Gửi request `GET http://localhost:3000/api/cart` để kiểm tra giỏ hàng người dùng.

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "id": "abc",
  "price": 100000,
  "quantity": 1
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-07 & API Spec §4.2):

> *Trích dẫn API Spec §4.2:* "HTTP 400 Bad Request; từ chối xử lý dữ liệu sai kiểu."

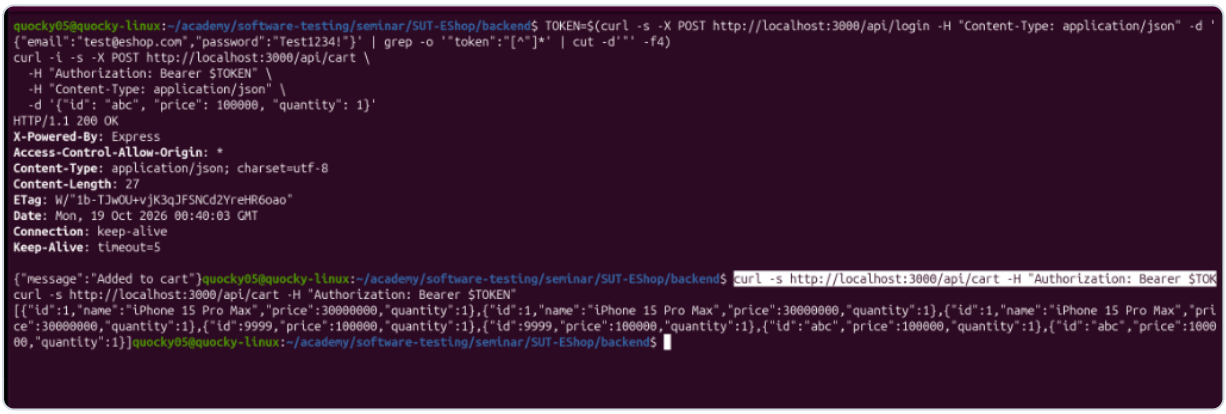
- Backend API bắt buộc phải thực hiện Schema/Type Validation đối với trường `id`.
- Trường `id` phải là số nguyên dương ($id \in \mathbb{Z}^+$).
- Khi nhận ID mang định dạng chuỗi chữ không hợp lệ, hệ thống phải từ chối ngay với mã lỗi HTTP `400 Bad Request` (`{"error": "Invalid product ID format"}`).
- Giỏ hàng của người dùng không được phép lưu trữ phần tử chứa ID sai kiểu.

5. Kết quả thực tế (Actual Result):

- Endpoint `POST /api/cart` trả về HTTP `200 OK` (`{"message":"Added to cart"}`).
- Gọi `GET /api/cart` phát hiện bản ghi malformed `{"id":"abc", "price":100000, "quantity":1}` bị lưu thẳng vào mảng giỏ hàng của user.
- Backend hoàn toàn bỏ qua bước kiểm tra kiểu dữ liệu đầu vào.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp terminal kiểm thử API (200 OK & chèn bản ghi id="abc"):*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/12

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:** File `backend/server.js`, các dòng 290–295.
- **Đoạn mã gây lỗi:**

```
app.post("/api/cart", authenticateToken, (req, res) => {
  const userId = req.user.id;
  if (!userCarts[userId]) userCarts[userId] = [];
  userCarts[userId].push(req.body);
  res.json({ message: "Added to cart" });
});
```

- **Khắc phục:** Bổ sung bước kiểm tra số nguyên dương cho `id`:

```
app.post("/api/cart", authenticateToken, (req, res) => {
  const userId = req.user.id;
  const { id, quantity } = req.body;
  const numId = Number(id);

  if (!id || !Number.isInteger(numId) || numId <= 0) {
    return res.status(400).json({ error: "Invalid product ID format" });
  }

  db.get("SELECT id, name, price FROM products WHERE id = ?", [numId], (err, product) => {
    if (err) return res.status(500).json({ error: err.message });
    if (!product) return res.status(404).json({ error: "Product not found" });

    if (!userCarts[userId]) userCarts[userId] = [];
    userCarts[userId].push({ ...product, quantity: quantity || 1 });
    res.json({ message: "Added to cart" });
  });
});
```

[BUG-FR07-05] Hệ thống chấp nhận số lượng 0 (Boundary Off-point), cho phép lưu bản ghi có thành tiền 0 ₫ vào giỏ hàng

Trường thông tin	Chi tiết
Bug ID	`BUG-FR07-05`
Tiêu đề Bug	`[FR-07][Web UI / API] Quantity zero (0) accepted, rendering zero-priced item and 200 OK`
Chức năng (Feature)	FR-07: Giỏ hàng (Shopping Cart - Pool B)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Lỗi vi phạm giá trị biên BVA Off-point $Q=0$; tạo bản ghi đơn hàng vô nghĩa 0 ₫)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR07_05` (Validate rejection of quantity zero input on Cart item)
GitHub Issue Link	Issue #13: [BUG] [FR-07][Web UI / API] Quantity zero (0) accepted, rendering zero-priced item and 200 OK
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend và frontend-web đang hoạt động bình thường.
- CSDL SQLite có sẵn sản phẩm ID 1 (`iPhone 15 Pro Max`).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở trình duyệt, truy cập `http://localhost:5173/product/1` .
2. Tại ô nhập số lượng, xóa số 1 và nhập số `0` (Boundary Off-point).
3. Bấm nút "Thêm vào giỏ hàng".
4. Điều hướng vào trang giỏ hàng `http://localhost:5173/cart` .
5. Quan sát giá trị hiển thị tại các cột Số lượng, Thành tiền và Tổng tạm tính.
6. (API Verification):

```
curl -i -s -X POST http://localhost:3000/api/cart \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{"id": 1, "price": 30000000, "quantity": 0}'
```

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "id": 1,
  "price": 30000000,
  "quantity": 0
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-06 & FR-07):

> *Trích dẫn SRS FR-06 & FR-07:* "Số lượng sản phẩm trong giỏ hàng phải là số nguyên dương, tối thiểu là 1 ($Q \ge 1$)."

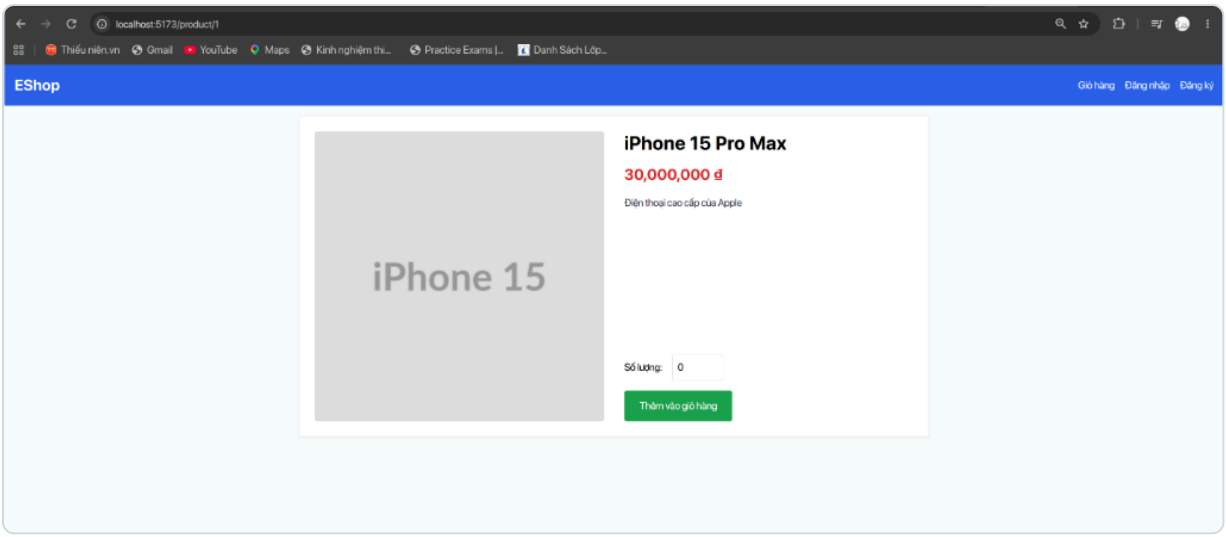
- Ô nhập số lượng trên Web Client phải có thuộc tính `min="1"`, chặn không cho nhập 0 hoặc tự động khôi phục về 1.
- API `POST /api/cart` phải từ chối `quantity = 0` với HTTP `400 Bad Request` (`{"error": "Quantity must be greater than or equal to 1"}`).
- Bảng giỏ hàng tuyệt đối không được phép lưu hoặc hiển thị dòng sản phẩm có $Q = 0$ và thành tiền = 0 ₫.

5. Kết quả thực tế (Actual Result):

- Input số lượng tại `ProductDetail.jsx` cho phép nhập `0` mà không hề có validation chặn lại.
- Bảng giỏ hàng hiển thị dòng sản phẩm với:
  - `Số lượng: 0`
  - `Thành tiền: 0 ₫`
  - `Tổng tạm tính: 0 ₫`
- Endpoint `POST /api/cart` trả về HTTP `200 OK` (`{"message":"Added to cart"}`) và lưu thẳng bản ghi $Q=0$ vào backend state.
- Ngoài ra, bảng `/cart` hiển thị text tĩnh `<td>{item.quantity}</td>`, hoàn toàn thiếu ô input hoặc hai nút `+` và `-` để điều chỉnh số lượng trực tiếp trong giỏ hàng.

6. Bằng chứng kiểm thử (Screenshots & Logs):

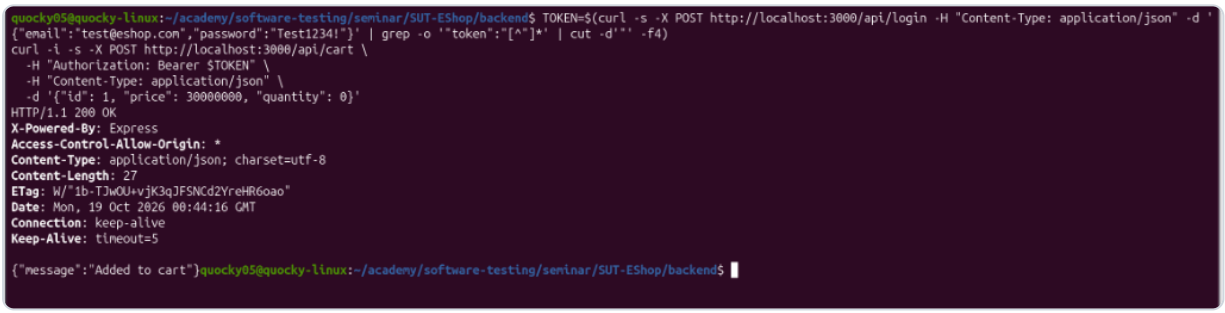
- *Ảnh chụp Web UI nhập Q=0:*



- *Ảnh chụp bảng giỏ hàng lưu Q=0 và 0đ:*



- *Ảnh chụp terminal API trả về 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/13

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - `frontend-web/src/pages/ProductDetail.jsx`, dòng 56–62.
  - `frontend-web/src/pages/Cart.jsx`, dòng 47.
  - `backend/server.js`, dòng 290–295.
- **Khắc phục:**
  - Bổ sung `min="1"` và kiểm tra chặn giá trị `< 1` trên form.
  - Bổ sung validation kiểm tra `quantity >= 1` tại backend `server.js`:

```
if (!quantity || Number(quantity) < 1) {
  return res.status(400).json({ error: "Quantity must be at least 1" });
}
```

[BUG-FR07-06] Hệ thống chấp nhận số lượng âm (-1), hiển thị thành tiền âm và làm sai lệch tổng tiền giỏ hàng

Trường thông tin	Chi tiết
Bug ID	`BUG-FR07-06`

Trường thông tin	Chi tiết
Tiêu đề Bug	`[FR-07][Web UI / API] Negative quantity (-1) accepted, producing negative subtotal and total amount`
Chức năng (Feature)	FR-07: Giỏ hàng (Shopping Cart - Pool B)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Lỗi số học logic nghiêm trọng: cho phép số lượng âm dẫn tới thành tiền âm và tổng tiền âm)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR07_06` (Validate rejection of negative integer quantity input)
GitHub Issue Link	Issue #14: [BUG] [FR-07][Web UI / API] Negative quantity (-1) accepted, producing negative subtotal and total amount
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend và frontend-web đang hoạt động bình thường.
- CSDL SQLite có sẵn sản phẩm ID 1 (`iPhone 15 Pro Max`).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở trình duyệt, truy cập `http://localhost:5173/product/1`.
2. Tại ô nhập số lượng, xóa số 1 và nhập số âm `-1`.
3. Bấm nút "Thêm vào giỏ hàng".
4. Điều hướng vào trang giỏ hàng `http://localhost:5173/cart`.
5. Quan sát giá trị hiển thị tại các cột Số lượng, Thành tiền và Tổng tạm tính.
6. (API Verification):

```
curl -i -s -X POST http://localhost:3000/api/cart \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{"id": 1, "price": 30000000, "quantity": -1}'
```

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "id": 1,
  "price": 30000000,
  "quantity": -1
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-06 & FR-07):

> *Trích dẫn SRS FR-06 & FR-07:* "Số lượng sản phẩm trong giỏ hàng phải là số nguyên dương, tối thiểu là 1 ($Q \in \mathbb{Z}^+, Q \ge 1$)."

- Web UI input phải chặn nhập ký tự âm `-` hoặc tự động reset về 1 kèm cảnh báo lỗi.

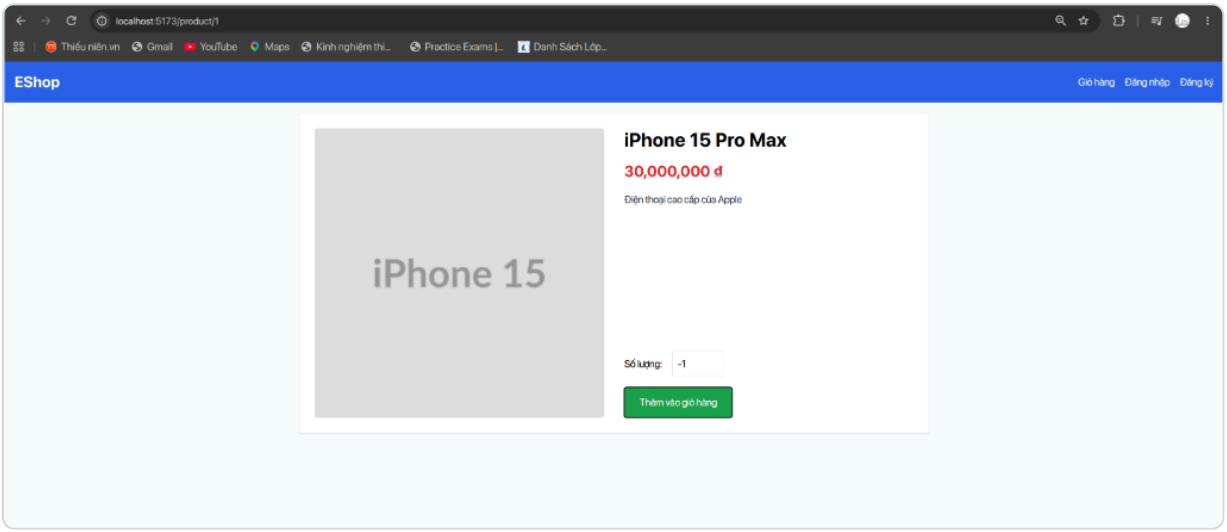
- API `POST /api/cart` phải từ chối `quantity < 0` với HTTP `400 Bad Request` (`{"error": "Quantity must be a positive integer"}`).
- Bảng giỏ hàng tuyệt đối không bao giờ hiển thị số lượng âm hoặc thành tiền mang giá trị âm.

5. Kết quả thực tế (Actual Result):

- Input số lượng tại `ProductDetail.jsx` nhận ký tự âm `-1`.
- Bảng giỏ hàng hiển thị dòng sản phẩm với:
  - `Số lượng: -1`
  - `Thành tiền: -30,000,000 ₫` (tiền âm)
  - `Tổng tạm tính: -30,000,000 ₫` (tổng tiền âm phi lý)
- Endpoint `POST /api/cart` trả về HTTP `200 OK` (`{"message":"Added to cart"}`) và lưu thẳng bản ghi $Q=-1$ vào backend state.

6. Bằng chứng kiểm thử (Screenshots & Logs):

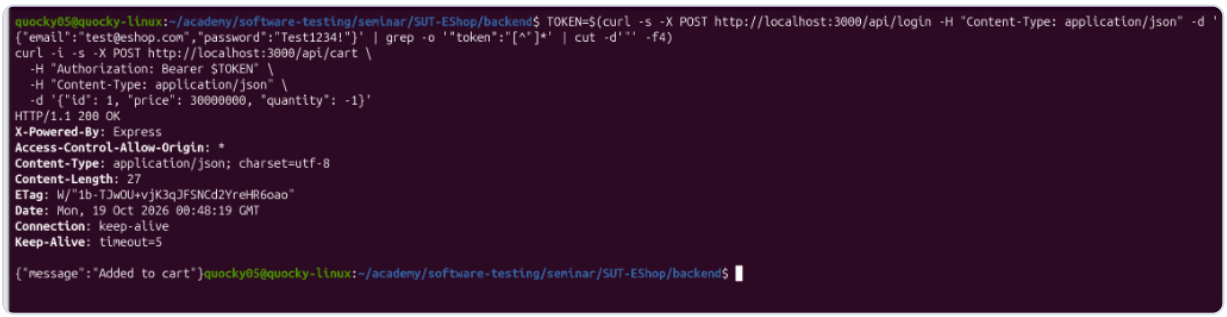
- *Ảnh chụp Web UI nhập Q = -1:*



- *Ảnh chụp bảng giỏ hàng lưu Q=-1 và tiền âm (-30tr):*



- *Ảnh chụp terminal API trả về 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/14

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**

  - `frontend-web/src/pages/ProductDetail.jsx`, dòng 56–62.
  - `backend/server.js`, dòng 290–295.
- **Khắc phục:**
  - Chặn giá trị âm tại input:

```
<input
  type="number"
  min="1"
  value={quantity}
  onChange={(e) => setQuantity(Math.max(1, parseInt(e.target.value) || 1))}
  className="border p-2 w-20 rounded"
/>
```

  - Thêm kiểm tra `quantity > 0` tại backend `server.js`:

```
const numQty = Number(quantity);
if (!Number.isInteger(numQty) || numQty <= 0) {
  return res.status(400).json({ error: "Quantity must be a positive integer" });
}
```

[BUG-FR07-07] Xóa trống ô số lượng khiến giỏ hàng bị tính toán sai thành "NaN ₫" và API chấp nhận chuỗi rỗng

Trường thông tin	Chi tiết
Bug ID	`BUG-FR07-07`
Tiêu đề Bug	`[FR-07][Web UI / API] Empty quantity accepted, corrupting cart table amounts to "NaN ₫"`
Chức năng (Feature)	FR-07: Giỏ hàng (Shopping Cart - Pool B)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Lỗi hiển thị NaN phá vỡ tính năng tính toán giá trị đơn hàng)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR07_07` (Validate rejection of empty or whitespace quantity input)
GitHub Issue Link	Issue #15: [BUG] [FR-07][Web UI / API] Empty quantity accepted, corrupting cart table amounts to "NaN ₫"
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend và frontend-web đang hoạt động bình thường.
- CSDL SQLite có sẵn sản phẩm ID 1 (`iPhone 15 Pro Max`).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở trình duyệt, truy cập `http://localhost:5173/product/1`.
2. Bôi đen toàn bộ số trong ô số lượng và nhấn Backspace để xóa sạch (chuỗi rỗng `""`).
3. Bấm nút "Thêm vào giỏ hàng".
4. Điều hướng vào trang giỏ hàng `http://localhost:5173/cart`.

5. Quan sát giá trị hiển thị tại các cột Số lượng, Thành tiền và Tổng tạm tính.
6. (API Verification):

```
curl -i -s -X POST http://localhost:3000/api/cart \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{"id": 1, "price": 30000000, "quantity": ""}'
```

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "id": 1,
  "price": 30000000,
  "quantity": ""
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-07):

> *Trích dẫn SRS FR-07:* "Số lượng là trường thông tin bắt buộc và phải là số nguyên dương ($Q \ge 1$)."

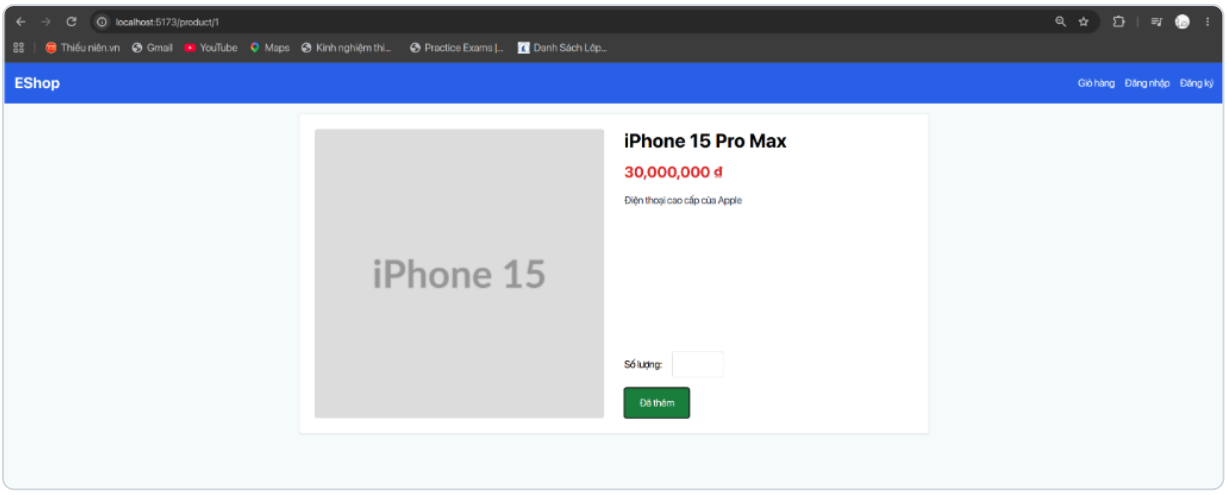
- Khi người dùng xóa rỗng ô số lượng và click ra ngoài hoặc submit, hệ thống phải tự động phục hồi về 1 hoặc chặn submit với cảnh báo trường bắt buộc.
- API `POST /api/cart` phải từ chối `quantity: ""` với HTTP `400 Bad Request` (`{"error": "Quantity is required and cannot be empty"}`).
- Bảng giỏ hàng tuyệt đối không được hiển thị giá trị `NaN` hoặc `NaN ₫`.

5. Kết quả thực tế (Actual Result):

- Ô nhập số lượng cho phép submit chuỗi rỗng `""`. Hàm `parseInt("")` trả về `NaN`.
- Bảng giỏ hàng hiển thị các giá trị lỗi tính toán:
  - `Sô´lượng: NaN`
  - `Thành tiền: NaN ₫`
  - `Tổng tạm tính: NaN ₫`
- Endpoint `POST /api/cart` trả về HTTP `200 OK` cho cả chuỗi rỗng `""` và chuỗi khoảng trắng `" "`.

6. Bằng chứng kiểm thử (Screenshots & Logs):

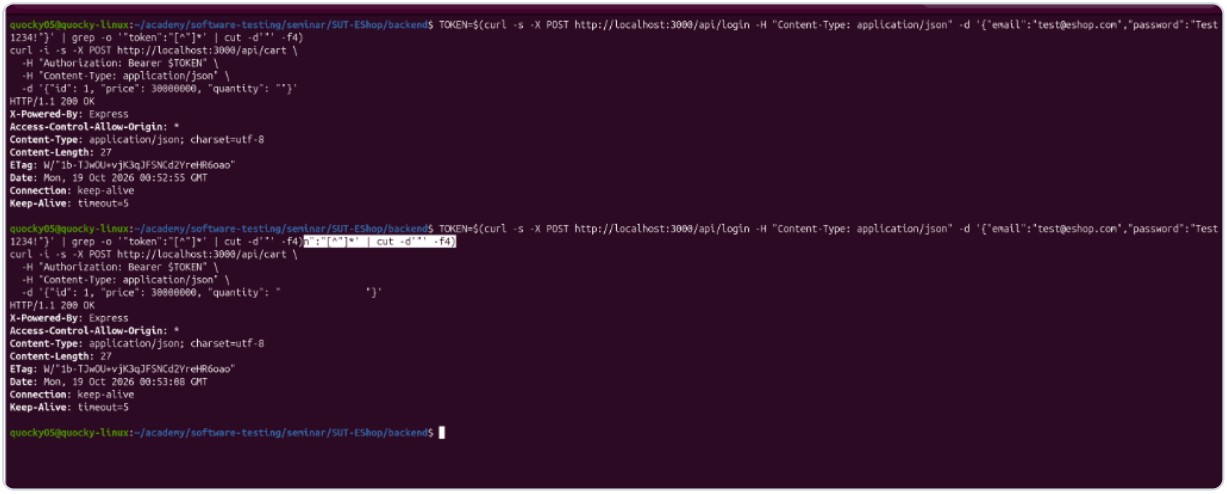
- *Ảnh chụp Web UI xóa trống ô số lượng:*



- *Ảnh chụp bảng giỏ hàng tính ra NaN đ:*

  Bảng giỏ hàng hiển thị NaN đ

- *Ảnh chụp terminal API trả về 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/15

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - `frontend-web/src/pages/ProductDetail.jsx`, dòng 27: `addToCart(product, parseInt(quantity));`.
  - `backend/server.js`, dòng 290–295.
- **Khắc phục:**
  - Trong `ProductDetail.jsx`: Fallback về 1 nếu input là NaN:

```
const parsedQty = parseInt(quantity, 10);
const validQty = isNaN(parsedQty) || parsedQty < 1 ? 1 : parsedQty;
addToCart(product, validQty);
```

  - Trong `backend/server.js`: Bổ sung kiểm tra trường bắt buộc:

```
if (quantity === undefined || quantity === null || String(quantity).trim() === "") {
  return res.status(400).json({ error: "Quantity is required" });
}
```

[BUG-FR07-08] Nhập số lượng thập phân (1.5) được chấp nhận, giao diện tự làm tròn xuống 1 và API trả về 200 OK

Trường thông tin	Chi tiết
Bug ID	`BUG-FR07-08`
Tiêu đề Bug	`[FR-07][Web UI / API] Decimal quantity (1.5) accepted without integer validation, silently truncated on UI and returning 200 OK on API`
Chức năng (Feature)	FR-07: Giỏ hàng (Shopping Cart - Pool B)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Sai lệch dữ liệu số lượng, tự động cắt xén giá trị của người dùng mà không có thông báo/xác nhận)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR07_09` (Validate rejection of decimal quantity near lower boundary)
GitHub Issue Link	Issue #16: [BUG] [FR-07][Web UI / API] Decimal quantity (1.5) accepted without integer validation, silently truncated on UI and returning 200 OK on API
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend và frontend-web đang hoạt động bình thường.
- CSDL SQLite có sẵn sản phẩm ID 1 (`iPhone 15 Pro Max`).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở trình duyệt, truy cập `http://localhost:5173/product/1` .
2. Nhập số lượng thập phân `1.5` vào ô số lượng.
3. Bấm nút "Thêm vào giỏ hàng". Nút đổi sang trạng thái "Đã thêm".
4. Điều hướng vào trang giỏ hàng `http://localhost:5173/cart` .
5. Quan sát cột Số lượng của sản phẩm (bị âm thầm cắt bớt thành `1` mà không hề có bất kỳ cảnh báo nào).
6. (API Verification):

```
curl -i -s -X POST http://localhost:3000/api/cart \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{"id": 1, "price": 30000000, "quantity": 1.5}'
```

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "id": 1,
  "price": 30000000,
  "quantity": 1.5
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-07):

> *Trích dẫn SRS FR-07:* "Số lượng là trường thông tin bắt buộc và phải là số nguyên dương ($Q \ge 1$, $Q \in \mathbb{N}^*$)."

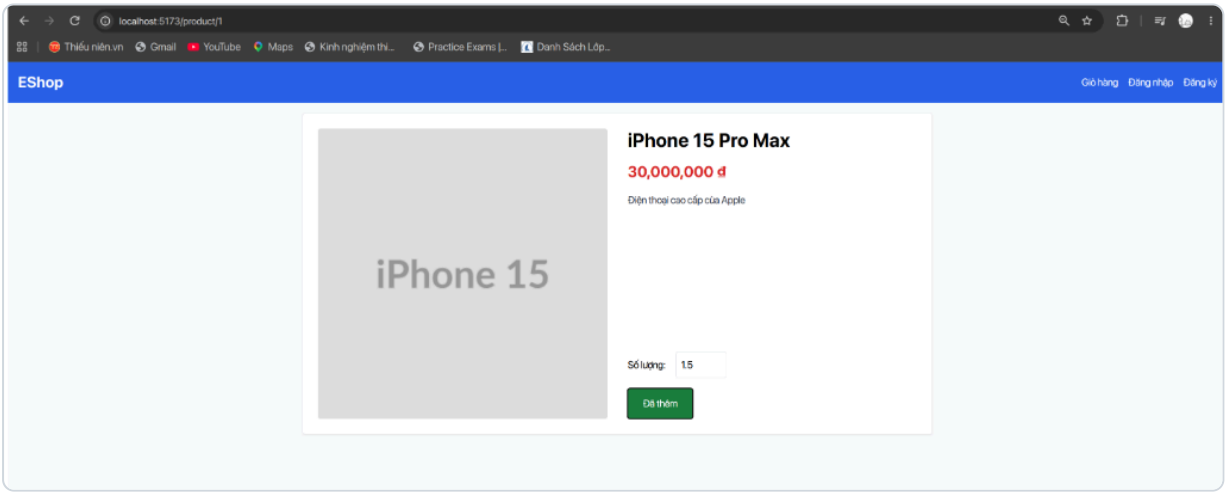
- Form chi tiết sản phẩm trên Web UI phải ràng buộc kiểu số nguyên (ví dụ dùng thuộc tính `step="1"`) hoặc chặn submit và hiển thị thông báo lỗi yêu cầu nhập số nguyên dương.
- Hệ thống tuyệt đối không được tự ý âm thầm cắt bớt phần thập phân làm thay đổi số lượng người dùng yêu cầu mà không thông báo.
- API `POST /api/cart` phải từ chối `quantity: 1.5` với HTTP `400 Bad Request` (`{"error": "Quantity must be a positive integer"}`).

5. Kết quả thực tế (Actual Result):

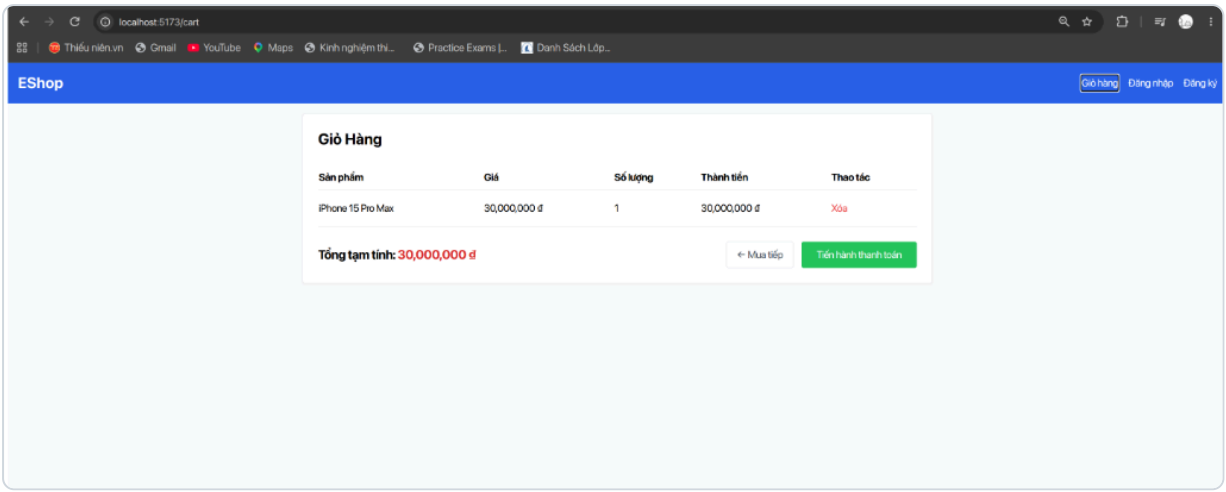
- Web UI cho phép nhập và gửi `1.5`, sau đó hàm `parseInt(quantity, 10)` âm thầm ép kiểu thành `1`, dẫn tới giỏ hàng chỉ có 1 sản phẩm.
- Endpoint `POST /api/cart` trả về HTTP `200 OK` cho `quantity: 1.5` mà không hề có bước validate số nguyên.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp Web UI nhập số lượng 1.5:*



- *Ảnh chụp giỏ hàng bị âm thầm cắt thành 1:*



- *Ảnh chụp terminal API trả về 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/16

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - `frontend-web/src/pages/ProductDetail.jsx`: Thẻ `<input type="number">` thiếu thuộc tính `step="1"`, và gọi `parseInt(quantity)` làm mất phần thập phân thay vì báo lỗi.
  - `backend/server.js`: Chưa kiểm tra điều kiện `Number.isInteger(quantity)`.
- **Khắc phục:**
  - Trong `ProductDetail.jsx`: Thêm `step="1"` và kiểm tra hợp lệ:

```
if (!Number.isInteger(Number(quantity)) || Number(quantity) < 1) {
  alert("Sô´lượng phải là sô´nguyên dương.");
  return;
}
```

  - Trong `backend/server.js`:

```
if (!Number.isInteger(Number(quantity)) || Number(quantity) < 1) {
  return res.status(400).json({ error: "Quantity must be a positive integer" });
}
```

[BUG-FR07-09] Endpoint POST /api/cart chấp nhận payload khuyết hoặc null trường quantity với HTTP 200 OK

Trường thông tin	Chi tiết
Bug ID	`BUG-FR07-09`
Tiêu đề Bug	`[FR-07][REST API] POST /api/cart accepts omitted or null quantity payload with 200 OK without required field validation`
Chức năng (Feature)	FR-07: Giỏ hàng (Shopping Cart - Pool B)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Vi phạm ràng buộc API schema & toàn vẹn dữ liệu giỏ hàng)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR07_10` (Validate API rejection when quantity is omitted or null in payload)
GitHub Issue Link	Issue #17: [BUG] [FR-07][REST API] POST /api/cart accepts omitted or null quantity payload with 200 OK without required field validation
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`.
- Tài khoản người dùng có token xác thực JWT hợp lệ.

2. Các bước tái hiện (Steps to Reproduce):

1. Lấy token xác thực người dùng qua API login:

```
TOKEN=$(curl -s -X POST http://localhost:3000/api/login -H "Content-Type: application/json" -d '{"email":"t
est@eshop.com","password":"Test1234!"}' | grep -o '"token":"[^"]*' | cut -d'"' -f4)
```

2. Gửi request `POST /api/cart` với trường `quantity: null`:

```
curl -i -s -X POST http://localhost:3000/api/cart \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{"id": 1, "price": 30000000, "quantity": null}'
```

3. Gửi request `POST /api/cart` khuyết hoàn toàn trường `quantity`:

```
curl -i -s -X POST http://localhost:3000/api/cart \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{"id": 1, "price": 30000000}'
```

4. Quan sát HTTP response status và body trả về.
5. Gọi `GET /api/cart` để kiểm tra mảng giỏ hàng lưu trong bộ nhớ server.

3. Dữ liệu thử nghiệm (Test Data):

```
// Payload A (quantity null)
{"id": 1, "price": 30000000, "quantity": null}

// Payload B (khuyết quantity)
{"id": 1, "price": 30000000}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-07):

> *Trích dẫn SRS FR-07:* "Số lượng là trường thông tin bắt buộc và phải là số nguyên dương ($Q \ge 1$)."

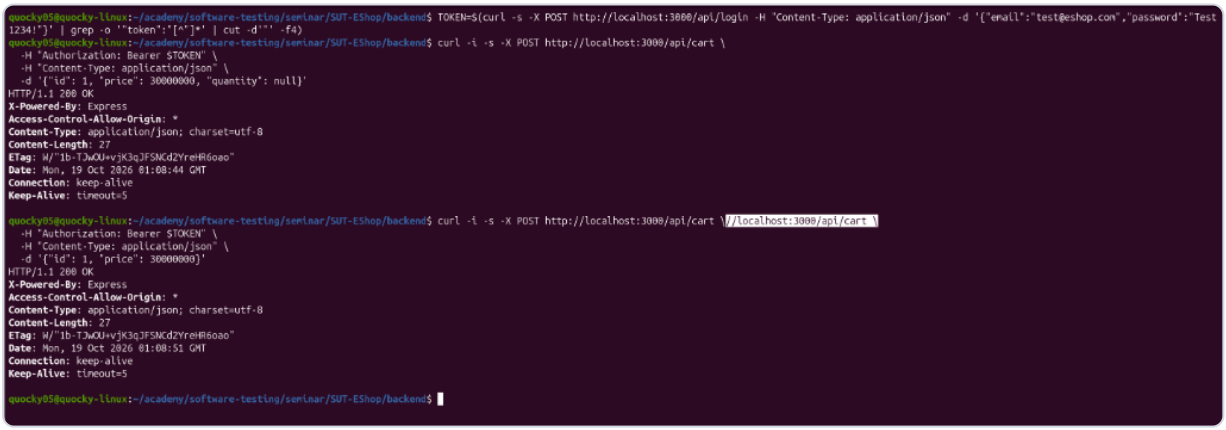
- Backend REST API `POST /api/cart` phải kiểm tra schema dữ liệu đầu vào và từ chối các request thiếu hoặc null trường số lượng với HTTP `400 Bad Request` kèm body lỗi (ví dụ: `{"error": "Quantity is required and must be a positive integer"}`).
- CSDL / Bộ nhớ giỏ hàng không được ghi nhận các item thiếu thông tin số lượng.

5. Kết quả thực tế (Actual Result):

- Endpoint `POST /api/cart` trả về HTTP `200 OK` (`{"message":"Added to cart"}`) cho cả hai payload trên.
- Mảng giỏ hàng lưu trực tiếp các đối tượng lỗi: `{"id":1,"price":30000000,"quantity":null}` và `{"id":1,"price":30000000}`.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp terminal API trả về 200 OK cho cả payload null và khuyết quantity:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/17

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - `backend/server.js`, dòng 290–295: Endpoint `POST /api/cart` thực hiện đẩy thẳng `req.body` vào `userCarts[userId]` mà không có bước validate schema.
- **Khắc phục:**
  - Kiểm tra tính hợp lệ của trường `quantity` trước khi lưu vào giỏ hàng:

```
const { id, quantity } = req.body;
if (quantity === undefined || quantity === null || String(quantity).trim() === "") {
  return res.status(400).json({ error: "Quantity is required" });
}
const numQty = Number(quantity);
if (!Number.isInteger(numQty) || numQty < 1) {
  return res.status(400).json({ error: "Quantity must be a positive integer" });
}
```

[BUG-FR07-10] Bảng giỏ hàng thiếu hoàn toàn nút +/- để điều chỉnh số lượng sản phẩm theo đặc tả

Trường thông tin	Chi tiết
Bug ID	`BUG-FR07-10`
Tiêu đề Bug	`[FR-07][Web UI] Cart table lacks '+' and '-' interactive buttons to adjust product quantity as specified in SRS`
Chức năng (Feature)	FR-07: Giỏ hàng (Shopping Cart - Pool B)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Thiếu tính năng tương tác cốt lõi trên giao diện giỏ hàng)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR07_13`, `TC_FR07_14` (Kiểm chứng nút '-' tại biên số lượng tối thiểu $Q=1$)
GitHub Issue Link	Issue #18: [BUG] [FR-07][Web UI] Cart table lacks '+' and '-' interactive buttons to adjust product quantity as specified in SRS
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend và frontend-web đang hoạt động bình thường.
- Giỏ hàng có sản phẩm `iPhone 15 Pro Max` với số lượng $Q = 2$.

2. Các bước tái hiện (Steps to Reproduce):

1. Mở trình duyệt, truy cập `http://localhost:5173/product/1`.
2. Nhập số lượng `2`, bấm "Thêm vào giỏ hàng".
3. Điều hướng vào trang giỏ hàng `http://localhost:5173/cart`.
4. Quan sát cột "Số lượng" trong bảng danh sách sản phẩm.
5. Tìm kiếm nút bấm tương tác `-` hoặc `+` để điều chỉnh giảm số lượng sản phẩm từ 2 xuống 1.

3. Dữ liệu thử nghiệm (Test Data):

- Sản phẩm: `iPhone 15 Pro Max` (ID 1)
- Số lượng hiện tại: `2`
- Thao tác kỳ vọng: Bấm nút `-` để giảm xuống `1`.

4. Kết quả mong đợi (Expected Result theo SRS FR-07):

> *Trích dẫn SRS FR-07 (Mục 1):* "Giỏ hàng hiển thị danh sách sản phẩm gồm: Tên sản phẩm, Đơn giá, **Số lượng (có nút +/- để chỉnh)**, Thành tiền, và nút Xóa."

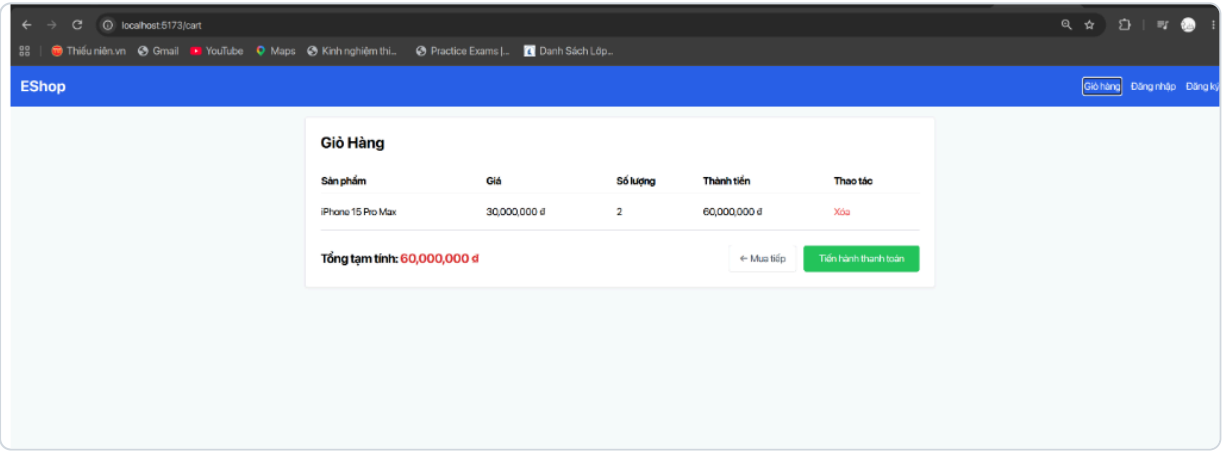
- Tại cột "Số lượng", giao diện phải cung cấp các nút bấm tương tác (nút `-`, số lượng hiển thị, nút `+`) cho phép người dùng thay đổi số lượng trực tiếp trong giỏ mà không cần quay lại trang chi tiết sản phẩm.
- Khi bấm nút `-`, số lượng giảm từ 2 xuống 1, thành tiền và tổng tạm tính cập nhật giảm tương ứng.

5. Kết quả thực tế (Actual Result):

- Cột "Số lượng" trong file `Cart.jsx` chỉ render text thuần: `<td>{item.quantity}</td>`.
- Hoàn toàn không có bất kỳ nút `-` hay `+` nào trên bảng giỏ hàng. Người dùng không thể điều chỉnh số lượng sản phẩm.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp bảng giỏ hàng chỉ có số lượng tĩnh, thiếu nút +/-:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/18

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - `frontend-web/src/pages/Cart.jsx`, dòng 47: `<td>{item.quantity}</td>`.
  - `frontend-web/src/context/CartContext.jsx`: Chưa xây dựng hàm cập nhật số lượng (`updateQuantity`).
- **Khắc phục:**
  - Trong `CartContext.jsx`, bổ sung hàm cập nhật số lượng:

```
const updateQuantity = (index, delta) => {
  setCart((prev) =>
    prev.map((item, i) => {
      if (i === index) {
        const newQty = item.quantity + delta;
        return newQty > 0 ? { ...item, quantity: newQty } : item;
      }
      return item;
    })
  );
};
```

- Trong `Cart.jsx`, thay thế dòng hiển thị số lượng bằng bộ điều khiển tương tác:

```
<td className="py-2">
  <div className="flex items-center gap-2">
    <button
      onClick={() => updateQuantity(index, -1)}
      className="px-2 py-1 bg-gray-200 hover:bg-gray-300 rounded text-sm font-bold"
    >
      -
    </button>
    <span className="w-8 text-center">{item.quantity}</span>
    <button
      onClick={() => updateQuantity(index, 1)}
      className="px-2 py-1 bg-gray-200 hover:bg-gray-300 rounded text-sm font-bold"
    >
      +
    </button>
  </div>
</td>
```

[BUG-FR07-11] Nút Xóa sản phẩm xóa trực tiếp không có dialog xác nhận theo yêu cầu SRS

Trường thông tin	Chi tiết
Bug ID	`BUG-FR07-11`
Tiêu đề Bug	`[FR-07][Web UI] Delete product button executes immediate deletion without required confirmation dialog`
Chức năng (Feature)	FR-07: Giỏ hàng (Shopping Cart - Pool B)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Vi phạm an toàn thao tác người dùng, nguy cơ mất dữ liệu giỏ hàng do click nhầm)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR07_15`, `TC_FR07_16`, `TC_FR07_19` (Kiểm chứng an toàn thao tác xóa & hủy xóa qua dialog xác nhận)
GitHub Issue Link	Issue #19: [BUG] [FR-07][Web UI] Delete product button executes immediate deletion without required confirmation dialog
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend và frontend-web đang hoạt động bình thường.
- Giỏ hàng có ít nhất 2 sản phẩm (ví dụ: `Samsung Galaxy S24 Ultra` và `MacBook Pro M3`).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở trình duyệt, truy cập `http://localhost:5173/cart`.
2. Định vị sản phẩm đầu tiên trong bảng giỏ hàng.
3. Nhấn nút màu đỏ "Xóa".
4. Quan sát: Xem hệ thống có bật hộp thoại xác nhận (modal hoặc `window.confirm`) trước khi xóa không.

3. Dữ liệu thử nghiệm (Test Data):

- Sản phẩm: `Samsung Galaxy S24 Ultra` (28.000.000 ₫)
- Thao tác: Bấm nút "Xóa"

4. Kết quả mong đợi (Expected Result theo SRS FR-07):

> *Trích dẫn SRS FR-07 (Mục 3):* "Nút Xóa sản phẩm phải có dialog xác nhận trước khi thực hiện."

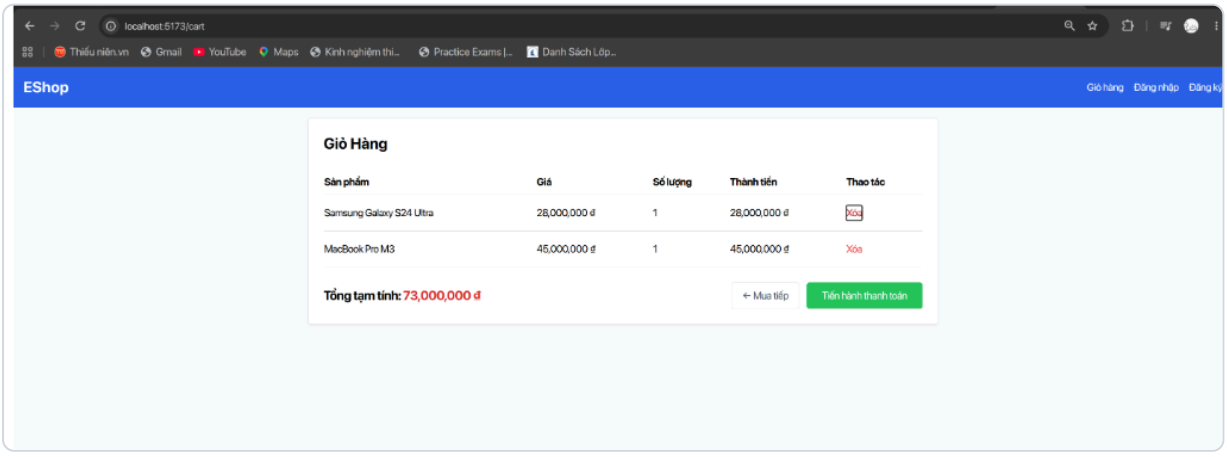
- Khi người dùng nhấn nút "Xóa", hệ thống bắt buộc phải hiển thị một hộp thoại cảnh báo/xác nhận (ví dụ: *"Bạn có chắc chắn muốn xóa sản phẩm này khỏi giỏ hàng?"*).
- Chỉ khi người dùng bấm "OK / Xác nhận", sản phẩm mới bị xóa khỏi giỏ. Nếu bấm "Hủy", sản phẩm vẫn được giữ nguyên.

5. Kết quả thực tế (Actual Result):

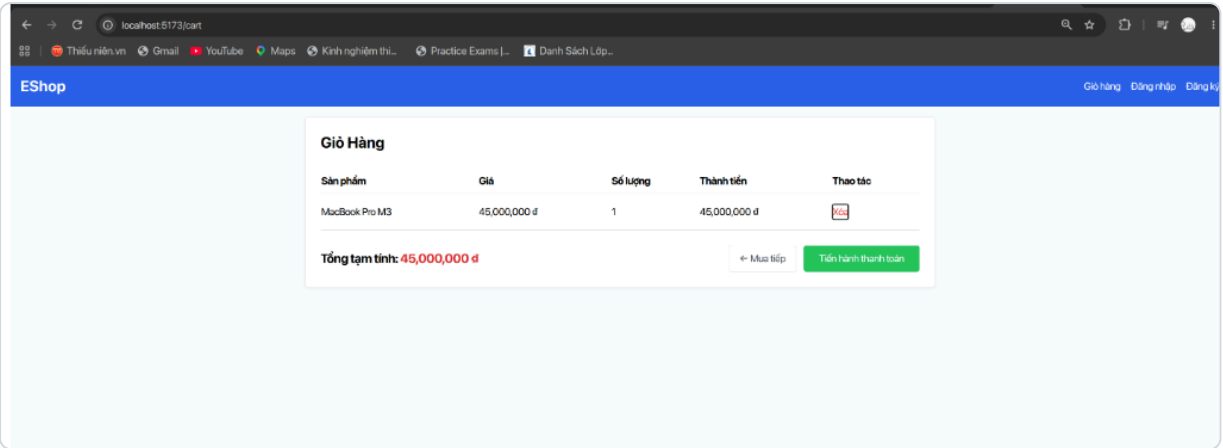
- Nút "Xóa" gắn trực tiếp hàm `removeFromCart(index)`.
- Không hề có hộp thoại xác nhận nào xuất hiện; sản phẩm bị xóa biến mất ngay lập tức khi người dùng vừa click chuột. Bất kỳ click nhầm nào cũng sẽ xóa mất sản phẩm của khách hàng mà không có cơ hội hủy thao tác.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp giỏ hàng trước khi bấm Xóa (2 sản phẩm):*



- *Ảnh chụp giỏ hàng ngay sau khi bấm Xóa (sản phẩm biến mất không qua xác nhận):*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/19

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - `frontend-web/src/pages/Cart.jsx`, dòng 50–55:

```
<button
  onClick={() => removeFromCart(index)}
  className="text-red-500 hover:text-red-700"
>
  Xóa
</button>
```

- **Khắc phục:**
  - Bổ sung hàm kiểm tra xác nhận trước khi gọi `removeFromCart`:

```
const handleDeleteItem = (index, itemName) => {
  if (window.confirm(`Bạn có chắc chắn muốn xóa "${itemName}" khỏi giỏ hàng?`)) {
    removeFromCart(index);
  }
};
```

    và gắn vào nút: `<button onClick={() => handleDeleteItem(index, item.name)} ...>`

[BUG-FR07-12] Giao diện giỏ hàng trống chỉ có text thuần, thiếu hình ảnh minh họa theo đặc tả

Trường thông tin	Chi tiết
Bug ID	`BUG-FR07-12`
Tiêu đề Bug	`[FR-07][Web UI] Empty cart state lacks required illustration image/graphic specified in SRS FR-07`
Chức năng (Feature)	FR-07: Giỏ hàng (Shopping Cart - Pool B)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Medium** (Thiếu thành phần đồ họa minh họa theo quy chuẩn thiết kế UI của SRS)
Mức ưu tiên (Priority)	**Medium (P2)**

Trường thông tin	Chi tiết
Test Case phát hiện	`TC_FR07_17` (Verify empty cart state display upon deleting last remaining item)
GitHub Issue Link	Issue #20: [BUG] [FR-07][Web UI] Empty cart state lacks required illustration image/graphic specified in SRS FR-07
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend và frontend-web đang hoạt động bình thường.
- Giỏ hàng ở trạng thái rỗng ($Items = 0$).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở trình duyệt, truy cập `http://localhost:5173/cart`.
2. Nếu giỏ đang có hàng, xóa hết để đưa giỏ về rỗng.
3. Quan sát giao diện thông báo giỏ hàng trống trên màn hình.
4. Kiểm tra sự hiện diện của hình ảnh đồ họa hoặc vector SVG minh họa giỏ hàng rỗng.

3. Dữ liệu thử nghiệm (Test Data):

- Trạng thái giỏ hàng: $Items = 0$

4. Kết quả mong đợi (Expected Result theo SRS FR-07):

> *Trích dẫn SRS FR-07 (Mục 6):* "Giỏ hàng trống phải có **hình minh họa** và thông báo rõ ràng."

- Trang giỏ hàng trống phải hiển thị hình ảnh đồ họa hoặc icon minh họa (thẻ `<img>` hoặc SVG) trực quan bên cạnh thông báo chữ và đường dẫn tiếp tục mua sắm.

5. Kết quả thực tế (Actual Result):

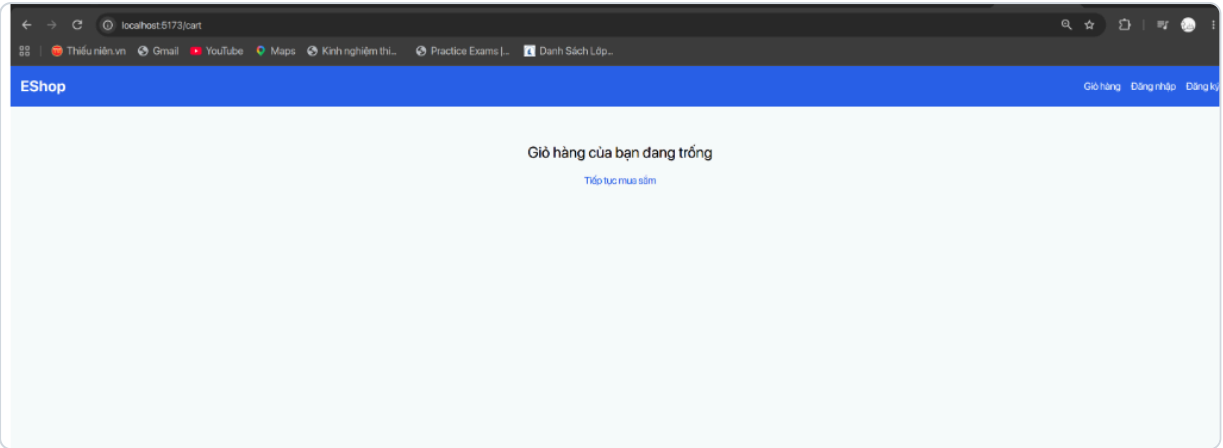
- Trong `Cart.jsx`, component chỉ render 2 dòng chữ đơn giản (`<h2>` và `<Link>`) ở giữa khoảng trắng:

```
<div className="text-center mt-10">
  <h2 className="text-2xl mb-4">Giỏ hàng của bạn đang trống</h2>
  <Link to="/" className="text-blue-600 hover:underline">Tiếp tục mua sắm</Link>
</div>
```

- Hoàn toàn không có hình ảnh hoặc icon minh họa nào được render.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp giao diện giỏ hàng trống thiếu hình minh họa:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/20

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - `frontend-web/src/pages/Cart.jsx`, dòng 20–27.
- **Khắc phục:**
  - Bổ sung tài nguyên ảnh minh họa và căn chỉnh giao diện:

```
if (cart.length === 0) {
  return (
    <div className="text-center mt-10 flex flex-col items-center">
      <img
        src="/empty-cart.svg"
        alt="Giỏ hàng trống"
        className="w-48 h-48 mb-4 opacity-75"
      />
      <h2 className="text-2xl mb-4 font-semibold text-gray-700">Giỏ hàng của bạn đang trống</h2>
      <Link to="/" className="bg-blue-600 text-white px-6 py-2 rounded hover:bg-blue-700">
        Tiếp tục mua sắm
      </Link>
    </div>
  );
}
```

[BUG-FR07-13] Footer giỏ hàng hiển thị nhãn "Tổng tạm tính" thay vì "Tổng cộng" theo đặc tả

Trường thông tin	Chi tiết
Bug ID	`BUG-FR07-13`
Tiêu đề Bug	`[FR-07][Web UI] Cart footer displays incorrect label "Tổng tạm tính" instead of required "Tổng cộng" as specified in SRS FR-07`
Chức năng (Feature)	FR-07: Giỏ hàng (Shopping Cart - Pool B)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Medium** (Sai lệch nhãn hiển thị theo quy định kiểm thử định danh SRS)
Mức ưu tiên (Priority)	**Medium (P2)**

Trường thông tin	Chi tiết
Test Case phát hiện	`TC_FR07_18` (Validate total amount UI label matches required "Tổng cộng" text)
GitHub Issue Link	Issue #21: [BUG] [FR-07][Web UI] Cart footer displays incorrect label "Tổng tạm tính" instead of required "Tổng cộng" as specified in SRS FR-07
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend và frontend-web đang hoạt động bình thường.
- Giỏ hàng có ít nhất 1 sản phẩm.

2. Các bước tái hiện (Steps to Reproduce):

1. Mở trình duyệt, truy cập `http://localhost:5173/cart`.
2. Quan sát phần tổng kết thành tiền ở góc dưới bên trái của bảng giỏ hàng.
3. Đọc nhãn văn bản đi kèm số tiền tổng.

3. Dữ liệu thử nghiệm (Test Data):

- Nhãn hiển thị tổng tiền tại footer giỏ hàng

4. Kết quả mong đợi (Expected Result theo SRS FR-07):

> *Trích dẫn SRS FR-07 (Mục 5):* "Tổng tiền hiển thị nhãn chính xác: **'Tổng cộng' (không phải 'Tổng tạm tính')**."

- Nhãn văn bản hiển thị phải là `"Tổng cộng"` hoặc `"Tổng cộng:"`.
- Tuyệt đối không hiển thị `"Tổng tạm tính"` hay `"Subtotal"`.

5. Kết quả thực tế (Actual Result):

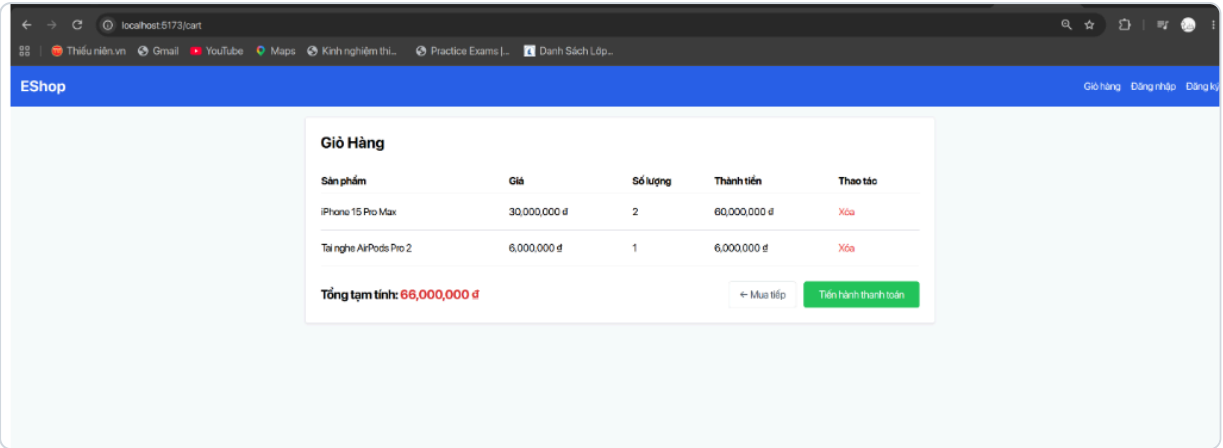
- Giao diện giỏ hàng trong `Cart.jsx` render dòng chữ hardcode:

```
<div className="text-xl font-bold">
  Tổng tạm tính: <span className="text-red-600">{cartTotal.toLocaleString()} ₫</span>
</div>
```

- Nhãn hiển thị thực tế là `"Tổng tạm tính:"`, vi phạm trực diện điều cấm của đặc tả SRS FR-07.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp nhãn hiển thị sai thành Tổng tạm tính:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/21

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - `frontend-web/src/pages/Cart.jsx`, dòng 63.
- **Khắc phục:**
  - Đổi chuỗi text thành `"Tổng cộng:"`:

```
<div className="text-xl font-bold">
  Tổng cộng: <span className="text-red-600">{cartTotal.toLocaleString()} đ</span>
</div>
```

2.3 Các lỗi thuộc Pool C: FR-17 – Quản lý Mã Giảm Giá (Admin)

[BUG-FR17-01] Tạo trùng mã coupon gây lỗi unhandled HTTP 500 rò rỉ ngoại lệ SQLite

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-01`
Tiêu đề Bug	`[FR-17][Admin Web & API] Creating duplicate coupon code results in unhandled HTTP 500 error leaking raw SQLite constraint`
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Lỗi sập server 500 không được kiểm soát và rò rỉ thông tin kỹ thuật hạ tầng)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR17_10` (Tạo mã trùng lặp `SAVE10`)
GitHub Issue Link	Issue #22: [BUG] [FR-17][Admin Web & API] Creating duplicate coupon code results in unhandled HTTP 500 error leaking raw SQLite constraint
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- Mã giảm giá `SAVE10` đã tồn tại sẵn trong CSDL SQLite (`coupons.code = 'SAVE10'`).
- SUT backend đang chạy tại `http://localhost:3000`, Admin Web tại `http://localhost:5174`.
- Đã đăng nhập tài khoản Quản trị viên (`admin@eshop.com`).

2. Các bước tái hiện (Steps to Reproduce):

1. Truy cập Admin Web tại `http://localhost:5174`, điều hướng vào mục "Mã Giảm Giá".
2. Tại form "Tạo mã giảm giá mới", điền thông tin:
    - Mã coupon: `SAVE10` (trùng mã đã tồn tại)
    - Loại: `Phần trăm (%)`
    - Giá trị: `15`
    - Đơn tối thiểu: `100000`
    - Ngày hết hạn: `2026-12-31`
    - Giới hạn/người: `1`
3. Nhấn nút "Tạo mã" (kích hoạt `POST /api/admin/coupons`).
4. Quan sát mã phản hồi HTTP trong DevTools Network tab và popup alert trên giao diện.

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "code": "SAVE10",
  "type": "percent",
  "discount_value": 15,
  "min_order_amount": 100000,
  "expired_at": "2026-12-31",
  "max_uses_per_user": 1
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-17):

> *Trích dẫn SRS FR-17:* "Các trường bắt buộc: `code` (duy nhất), `type` (percent/fixed), `discount_value` (dương)..."

- Endpoint `POST /api/admin/coupons` phải kiểm tra tính duy nhất và trả về client error HTTP 400 Bad Request hoặc 409 Conflict với thông báo lỗi thân thiện (ví dụ: `{"error": "Mã giảm giá này đã tồn tại trong hệ thống"}`).
- Giao diện Admin Web hiển thị thông báo nghiệp vụ rõ ràng cho người dùng; tuyệt đối không ném lỗi unhandled HTTP 500 hay làm lộ exception CSDL thô.
- Trong CSDL SQLite, bảng `coupons` giữ nguyên bản ghi ban đầu, không tạo bản ghi mới.

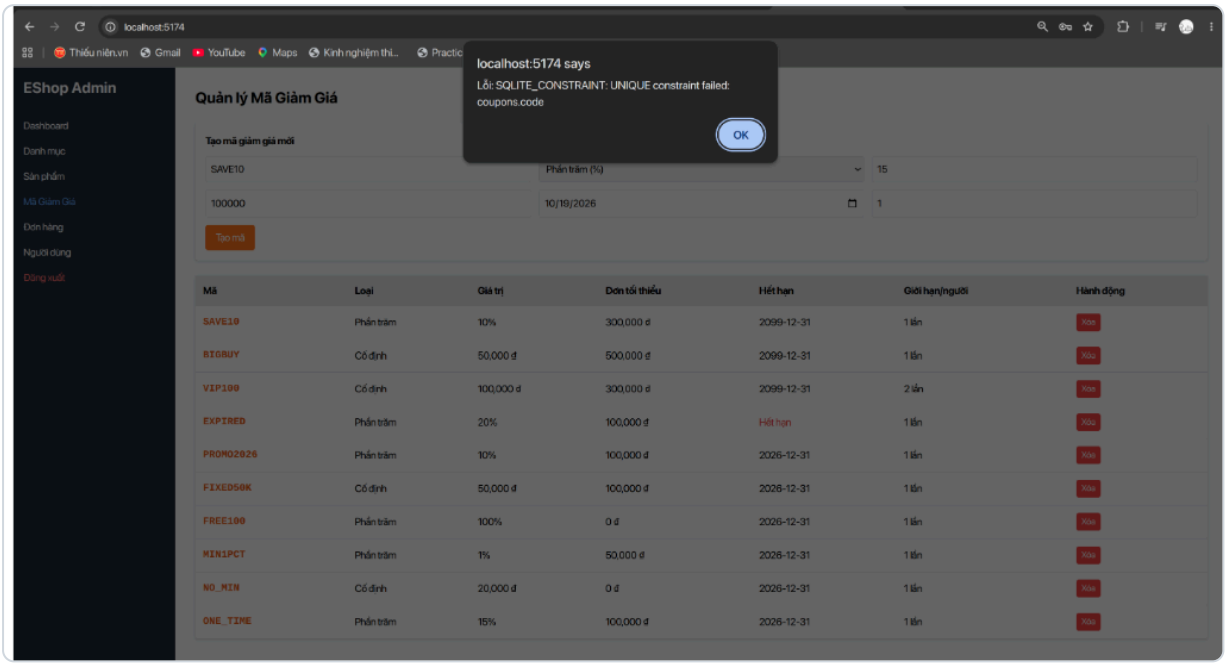
5. Kết quả thực tế (Actual Result):

- Endpoint `POST /api/admin/coupons` trả về mã lỗi **`HTTP 500 Internal Server Error`**.
- Response payload: `{"error":"SQLITE_CONSTRAINT: UNIQUE constraint failed: coupons.code"}`.
- Giao diện Admin Web bật popup cảnh báo lỗi thô: `Lỗi: SQLITE_CONSTRAINT: UNIQUE constraint failed: coupons.code`.

- Tên bảng và cấu trúc schema CSDL (`coupons.code`) bị rò rỉ trực tiếp tới client.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp popup cảnh báo trên Admin Web:*



- *Ảnh chụp terminal thực thi API và mã lỗi 500:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/22

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:** File `backend/server.js` , dòng 477.
- **Đoạn mã gây lỗi:**

```
db.run(
  "INSERT INTO coupons (code, type, discount_value, min_order_amount, expired_at, max_uses_per_user) VALUES
(?, ?, ?, ?, ?, ?)",
  [code, type, discount_value, min_order_amount, expired_at, max_uses_per_user || 1],
  function (err) {
    if (err) return res.status(500).json({ error: err.message });
    res.json({ message: "Coupon created", id: this.lastID });
  }
);
```

- **Khắc phục:** Bổ sung bước kiểm tra trùng mã trước khi insert hoặc bắt lỗi `SQLITE_CONSTRAINT` để trả về HTTP 409 Conflict:

```
db.get("SELECT id FROM coupons WHERE code = ?", [code], (err, row) => {
  if (err) return res.status(500).json({ error: "Lỗi hệ thống CSDL" });
  if (row) return res.status(409).json({ error: "Mã giảm giá này đã tồn tại trong hệ thống" });
  // Tiến hành INSERT khi mã chưa tồn tại...
});
```

[BUG-FR17-02] Endpoint POST /api/admin/coupons chấp nhận mã rỗng tạo coupon thành công

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-02`
Tiêu đề Bug	`[FR-17][REST API] Endpoint POST /api/admin/coupons accepts empty string code and creates coupon with HTTP 200 OK`
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Thiếu validation tầng API cho trường bắt buộc theo đặc tả, cho phép chèn coupon vô danh vào CSDL)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR17_11` (Biên Off-point chuỗi rỗng `code = ""`)
GitHub Issue Link	Issue #23: [BUG] [FR-17][REST API] Endpoint POST /api/admin/coupons accepts empty string code and creates coupon with HTTP 200 OK
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`, Admin Web tại `http://localhost:5174`.
- Đã đăng nhập tài khoản Quản trị viên (`admin@eshop.com`).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở Admin Web `:5174`, vào mục "Mã Giảm Giá", để trống ô "Mã coupon", điền các trường còn lại và bấm "Tạo mã" $\to$ Giao diện HTML5 hiển thị tooltip *"Please fill out this field"*.
2. Gửi request trực tiếp tới API endpoint `POST /api/admin/coupons` với payload chứa `code: ""` kèm JWT Admin:

```
curl -i -s -X POST http://localhost:3000/api/admin/coupons \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $ADMIN_TOKEN" \
  -d '{"code":"","type":"percent","discount_value":10,"min_order_amount":100000,"expired_at":"2026-12-3
1","max_uses_per_user":1}'
```

3. Truy vấn kiểm tra CSDL SQLite: `SELECT * FROM coupons WHERE code='';`.

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "code": "",
  "type": "percent",
  "discount_value": 10,
  "min_order_amount": 100000,
  "expired_at": "2026-12-31",
  "max_uses_per_user": 1
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-17):

> *Trích dẫn SRS FR-17:* "Các trường bắt buộc: `code` (duy nhất), `type` (percent/fixed), `discount_value` (dương)..."

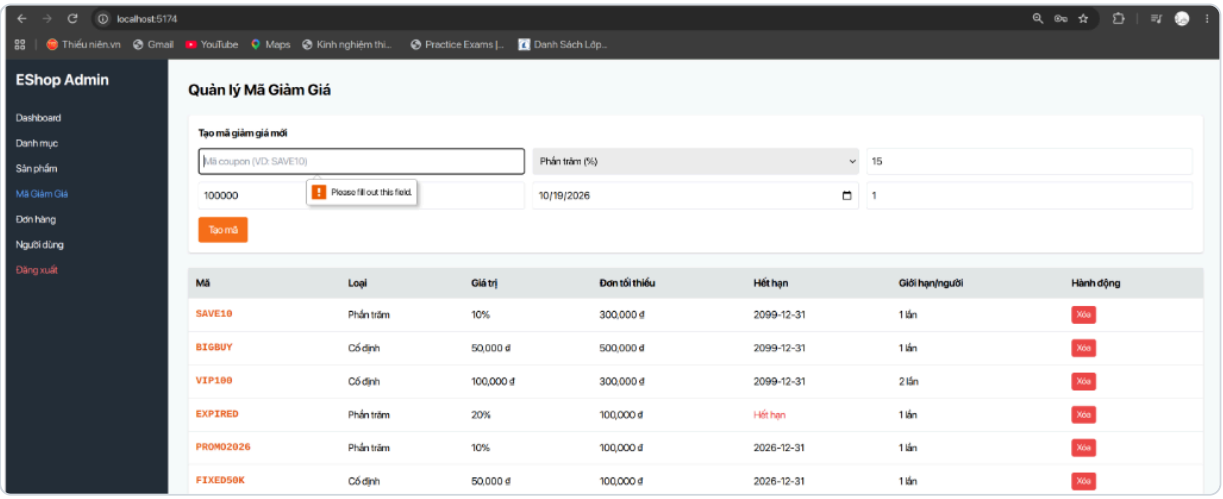
- Tầng backend API phải kiểm tra các trường bắt buộc; từ chối chuỗi rỗng với HTTP 400 Bad Request (`{"error": "Mã coupon là trường bắt buộc và không được để trống"}`).
- Không tạo bất kỳ bản ghi coupon nào với mã rỗng trong CSDL.

5. Kết quả thực tế (Actual Result):

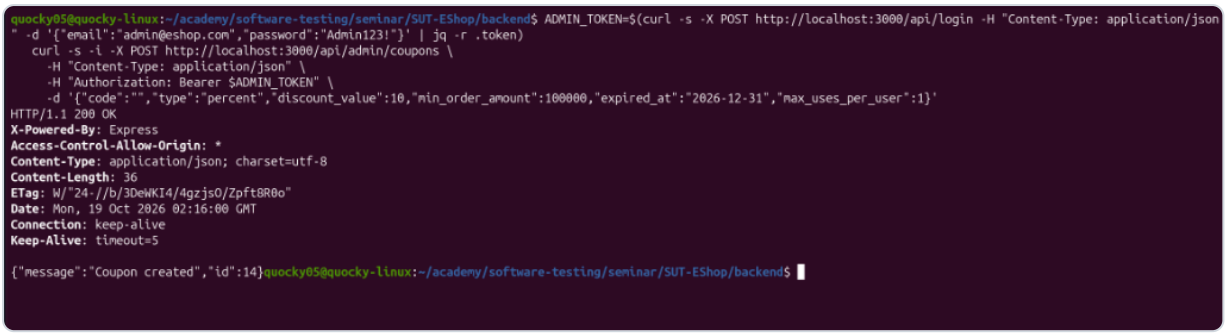
- Endpoint `POST /api/admin/coupons` trả về mã **`HTTP 200 OK`**: `{"message":"Coupon created","id":14}`.
- CSDL SQLite lưu thành công bản ghi coupon với trường `code = ''`.
- Giao diện Admin chỉ dựa vào validation phía client (thuộc tính `required` của HTML5); backend hoàn toàn thiếu validation phòng thủ, cho phép bypass dễ dàng.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp tooltip kiểm tra client-side trên Admin Web:*



- *Ảnh chụp terminal thực thi API và mã HTTP 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/23

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:** File `backend/server.js`, dòng 457–481.
- **Đoạn mã gây lỗi:**

```
app.post("/api/admin/coupons", authenticateToken, (req, res) => {
  const { code, type, discount_value, min_order_amount, expired_at, max_uses_per_user } = req.body;
  db.run(
    "INSERT INTO coupons (code, type, discount_value, min_order_amount, expired_at, max_uses_per_user) VALU
ES (?, ?, ?, ?, ?, ?)",
    ...
  );
});
```

- **Khắc phục:** Thêm kiểm tra validation ở đầu handler trước khi gọi CSDL:

```
if (!code || typeof code !== "string" || !code.trim()) {
  return res.status(400).json({ error: "Mã coupon là trường bắt buộc và không được để trống" });
}
```

[BUG-FR17-03] Form Admin và API chấp nhận mã coupon chỉ chứa khoảng trắng, tạo dòng rỗng trên bảng quản lý

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-03`
Tiêu đề Bug	`[FR-17][Admin Web & API] Coupon creation accepts whitespace-only code and displays blank coupons in management table`
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Bypass validation qua khoảng trắng, tạo mã voucher rỗng vô dụng và làm biến dạng giao diện quản lý)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR17_12` (Mã chỉ chứa 5 khoảng trắng `" "`)

Trường thông tin	Chi tiết
GitHub Issue Link	Issue #24: [BUG] [FR-17][Admin Web & API] Coupon creation accepts whitespace-only code and displays blank coupons in management table
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`, Admin Web tại `http://localhost:5174`.
- Đã đăng nhập tài khoản Quản trị viên (`admin@eshop.com`).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở Admin Web `:5174`, vào tab "Mã Giảm Giá".
2. Tại form "Tạo mã giảm giá mới", nhập chuỗi gồm 5 dấu cách `" "` vào ô "Mã coupon".
3. Điền các trường còn lại hợp lệ (Phần trăm, 15%, Đơn tối thiểu 100.000 ₫, Hạn dùng 2026-12-31, 1 lần/người).
4. Nhấn nút "Tạo mã" $\to$ Form submit thành công mà không bị chặn hay hiển thị cảnh báo.
5. Hoặc gửi request API trực tiếp:

```
curl -i -s -X POST http://localhost:3000/api/admin/coupons \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $ADMIN_TOKEN" \
  -d '{"code":"     ","type":"percent","discount_value":10,"min_order_amount":100000,"expired_at":"2026-12-31","max_uses_per_user":1}'
```

6. Quan sát bảng danh sách mã giảm giá bên dưới form.

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "code": "     ",
  "type": "percent",
  "discount_value": 10,
  "min_order_amount": 100000,
  "expired_at": "2026-12-31",
  "max_uses_per_user": 1
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-17):

> *Trích dẫn SRS FR-17:* "Các trường bắt buộc: `code` (duy nhất)..."

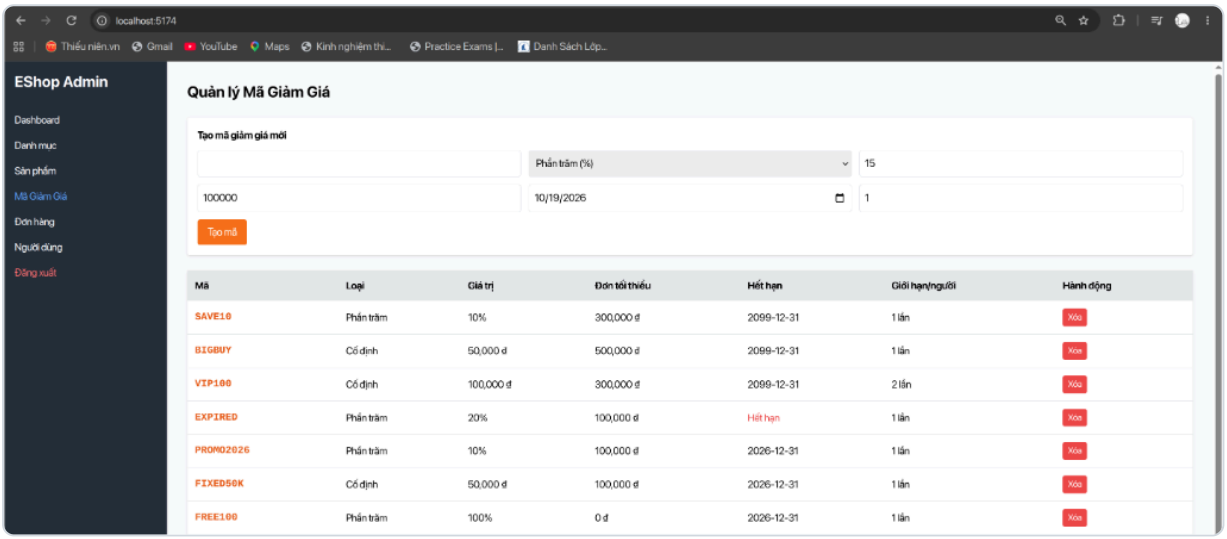
- Cả giao diện người dùng và backend API phải tự động cắt bỏ khoảng trắng thừa (`trim()`); từ chối chuỗi chỉ gồm khoảng trắng với HTTP 400 Bad Request (`{"error": "Mã coupon không được để trống hoặc chỉ chứa khoảng trắng"}`).
- Giao diện Admin phải chặn form submit và hiển thị thông báo lỗi yêu cầu nhập mã hợp lệ.
- Không lưu bất kỳ bản ghi nào có mã khoảng trắng vào CSDL SQLite.

5. Kết quả thực tế (Actual Result):

- Giao diện Admin cho phép submit vì thuộc tính `required` của HTML5 chỉ kiểm tra độ dài thô (`length > 0`) mà không trim khoảng trắng.
- Endpoint `POST /api/admin/coupons` trả về **`HTTP 200 OK`**: `{"message":"Coupon created","id":17}`.
- Bảng CSDL SQLite lưu trữ bản ghi có `code = ' '`.
- Bảng hiển thị trên trang Admin xuất hiện các dòng coupon có cột Mã hoàn toàn trống, khiến người quản trị không thể nhận biết hay phân biệt mã, và khách hàng không thể áp dụng.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp form nhập 5 khoảng trắng:*



- *Ảnh chụp terminal thực thi API và mã HTTP 200 OK:*



- *Ảnh chụp bảng Admin hiển thị các dòng coupon rỗng mã:*



Mã	Loại	Giá trị	Đơn tối thiểu	Hết hạn	Giới hạn/người	Hành động
SAVE10	Phần trăm	10%	300,000 đ	2099-12-31	1 lần	Xóa
BIGBUY	Cố định	50,000 đ	500,000 đ	2099-12-31	1 lần	Xóa
VIP100	Cố định	100,000 đ	300,000 đ	2099-12-31	2 lần	Xóa
EXPIRED	Phần trăm	20%	100,000 đ	Hết hạn	1 lần	Xóa
PROMO2026	Phần trăm	10%	100,000 đ	2026-12-31	1 lần	Xóa
FIXED50K	Cố định	50,000 đ	100,000 đ	2026-12-31	1 lần	Xóa
FREE100	Phần trăm	100%	0 đ	2026-12-31	1 lần	Xóa
MIN1PCT	Phần trăm	1%	50,000 đ	2026-12-31	1 lần	Xóa
NO_MIN	Cố định	20,000 đ	0 đ	2026-12-31	1 lần	Xóa
ONE_TIME	Phần trăm	15%	100,000 đ	2026-12-31	1 lần	Xóa
	Phần trăm	15%	100,000 đ	Hết hạn	1 lần	Xóa
	Phần trăm	15%	100,000 đ	Hết hạn	1 lần	Xóa
	Phần trăm	10%	100,000 đ	2026-12-31	1 lần	Xóa

- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/24

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `frontend-admin/src/App.jsx`, dòng 641–646: Chỉ gọi `toUpperCase()` mà không `trim()`.
  - File `backend/server.js`, dòng 457–481: Gán trực tiếp chuỗi vào câu lệnh SQL mà không kiểm tra tính hợp lệ của chuỗi sau khi cắt khoảng trắng.
- **Khắc phục:**
  - Frontend: Bổ sung kiểm tra `if (!couponForm.code.trim()) { alert("Mã coupon không được chỉ chứa khoảng trăńg!"); return; }`.
  - Backend: Thêm `if (!code || typeof code !== "string" || !code.trim()) return res.status(400).json({ error: "Mã coupon không được đê̂trôńg hoặc chỉ chứa khoảng trăńg" });`.

[BUG-FR17-04] Endpoint POST /api/admin/coupons chấp nhận loại giảm giá (type) không hợp lệ, lưu vào CSDL 200 OK

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-04`
Tiêu đề Bug	`[FR-17][REST API] Endpoint POST /api/admin/coupons accepts invalid coupon type enum and creates coupon with HTTP 200 OK`
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Vi phạm toàn vẹn enum dữ liệu khiến luồng tính toán tài chính đơn hàng bị sai lệch)
Mức ưu tiên (Priority)	**High (P1)**

Trường thông tin	Chi tiết
Test Case phát hiện	`TC_FR17_13` (Enum không hợp lệ `type = "free_shipping"`)
GitHub Issue Link	Issue #25: [BUG] [FR-17][REST API] Endpoint POST /api/admin/coupons accepts invalid coupon type enum and creates coupon with HTTP 200 OK
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`, Admin Web tại `http://localhost:5174`.
- Đã đăng nhập tài khoản Quản trị viên (`admin@eshop.com`).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở Admin Web `:5174`, vào tab "Mã Giảm Giá", kiểm tra dropdown loại giảm giá chỉ cho phép chọn `Phần trăm (%)` và `Số tiền cố định (đ)`.
2. Gửi request trực tiếp tới API endpoint `POST /api/admin/coupons` với payload chứa giá trị enum không hỗ trợ `type: "free_shipping"` kèm JWT Admin:

```
curl -i -s -X POST http://localhost:3000/api/admin/coupons \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $ADMIN_TOKEN" \
  -d '{"code":"FREESHIP","type":"free_shipping","discount_value":20000,"min_order_amount":100000,"expired_a
t":"2026-12-31","max_uses_per_user":1}'
```

3. Truy vấn kiểm tra CSDL SQLite: `SELECT * FROM coupons WHERE code='FREESHIP';`.

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "code": "FREESHIP",
  "type": "free_shipping",
  "discount_value": 20000,
  "min_order_amount": 100000,
  "expired_at": "2026-12-31",
  "max_uses_per_user": 1
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-17):

> *Trích dẫn SRS FR-17:* "Các trường bắt buộc: ... `type` (percent/fixed)..."

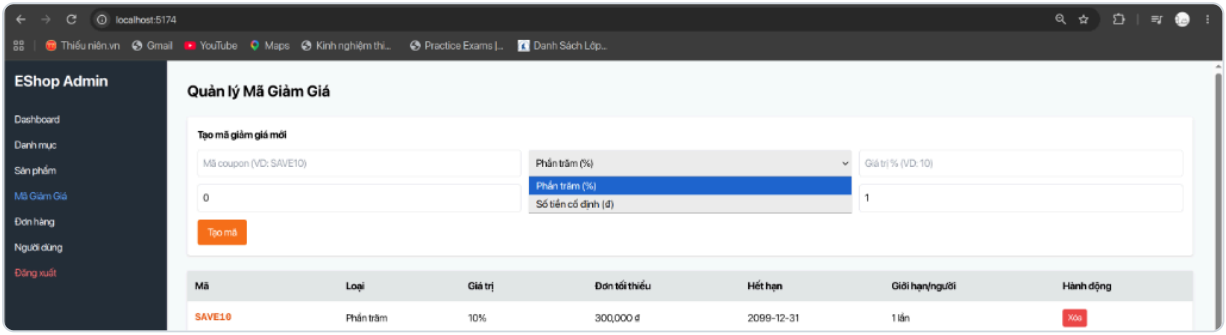
- Tầng backend API phải kiểm tra chặt chẽ giá trị enum của `type` nằm trong tập hợp hợp lệ `['percent', 'fixed']`.
- Từ chối các giá trị ngoài tập hợp với mã lỗi **HTTP 400 Bad Request** (`{"error": "Loại coupon không hợp lệ. Chỉ chấp nhận 'percent' hoặc 'fixed'"}`).
- Không chèn bất kỳ bản ghi nào có enum sai vào CSDL.

5. Kết quả thực tế (Actual Result):

- Endpoint `POST /api/admin/coupons` chấp nhận bất kỳ chuỗi nào cho `type` và trả về mã **`HTTP 200 OK`**: `{"message":"Coupon created","id":19}`.
- CSDL SQLite lưu trữ bản ghi mang `type = 'free_shipping'`.
- Khi tính toán coupon tại Checkout (`/api/apply-coupon`), logic phân nhánh kiểm tra `coupon.type === "percent"`, dẫn đến việc coi mọi loại không phải percent thành `fixed` và trừ trực tiếp `discount_value` vào tổng tiền, gây sai lệch nghiêm trọng về tài chính đơn hàng.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp dropdown chọn loại mã trên Admin Web:*



- *Ảnh chụp terminal thực thi API và mã HTTP 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/25

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:** File `backend/server.js`, dòng 457–481.
- **Đoạn mã gây lỗi:**

```
app.post("/api/admin/coupons", authenticateToken, (req, res) => {
  const { code, type, discount_value, min_order_amount, expired_at, max_uses_per_user } = req.body;
  db.run(
    "INSERT INTO coupons (code, type, discount_value, min_order_amount, expired_at, max_uses_per_user) VALU
ES (?, ?, ?, ?, ?, ?)",
    [code, type, discount_value, min_order_amount, expired_at, max_uses_per_user || 1],
    ...
  );
});
```

- **Khắc phục:** Thêm kiểm tra enum ở đầu route handler:

```
const validTypes = ["percent", "fixed"];
if (!type || !validTypes.includes(type)) {
  return res.status(400).json({ error: "Loại mã giảm giá không hợp lệ. Chỉ chấp nhận 'percent' hoặc 'fixe
d'" });
}
```

[BUG-FR17-05] Form Admin và API cho phép tạo coupon giảm giá 0%, lưu và hiển thị trên hệ thống

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-05`
Tiêu đề Bug	`[FR-17][Admin Web & API] Coupon creation accepts discount_value = 0 and creates 0% discount coupon in database`
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Vi phạm ràng buộc giá trị giảm dương $V > 0$ của đặc tả, tạo mã voucher 0% vô nghĩa)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR17_14` (Biên On-point $V = 0%$)
GitHub Issue Link	Issue #26: [BUG] [FR-17][Admin Web & API] Coupon creation accepts discount_value = 0 and creates 0% discount coupon in database
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`, Admin Web tại `http://localhost:5174`.
- Đã đăng nhập tài khoản Quản trị viên (`admin@eshop.com`).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở Admin Web `:5174`, vào tab "Mã Giảm Giá".
2. Tại form "Tạo mã giảm giá mới", điền thông tin:
   - Mã coupon: `PCTZERO`
   - Loại: `Phần trăm (%)`
   - Giá trị %: `0`
   - Đơn tối thiểu: `100000`
   - Ngày hết hạn: `10/21/2026`
   - Giới hạn/người: `1`
3. Nhấn nút "Tạo mã" $\to$ Form cho phép submit thành công, bảng bên dưới hiển thị dòng mã `PCTZERO` với `Giá trị: 0%`.
4. Hoặc gửi request trực tiếp qua curl tới API backend:

```
curl -i -s -X POST http://localhost:3000/api/admin/coupons \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $ADMIN_TOKEN" \
  -d '{"code":"PCTZERO0","type":"percent","discount_value":0,"min_order_amount":100000,"expired_at":"2026-12-31","max_uses_per_user":1}'
```

5. Kiểm tra CSDL SQLite: `SELECT * FROM coupons WHERE discount_value=0;`.

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "code": "PCTZERO",
  "type": "percent",
  "discount_value": 0,
  "min_order_amount": 100000,
  "expired_at": "2026-12-31",
  "max_uses_per_user": 1
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-17):

> *Trích dẫn SRS FR-17:* "Các trường bắt buộc: ... `discount_value` (dương)..."

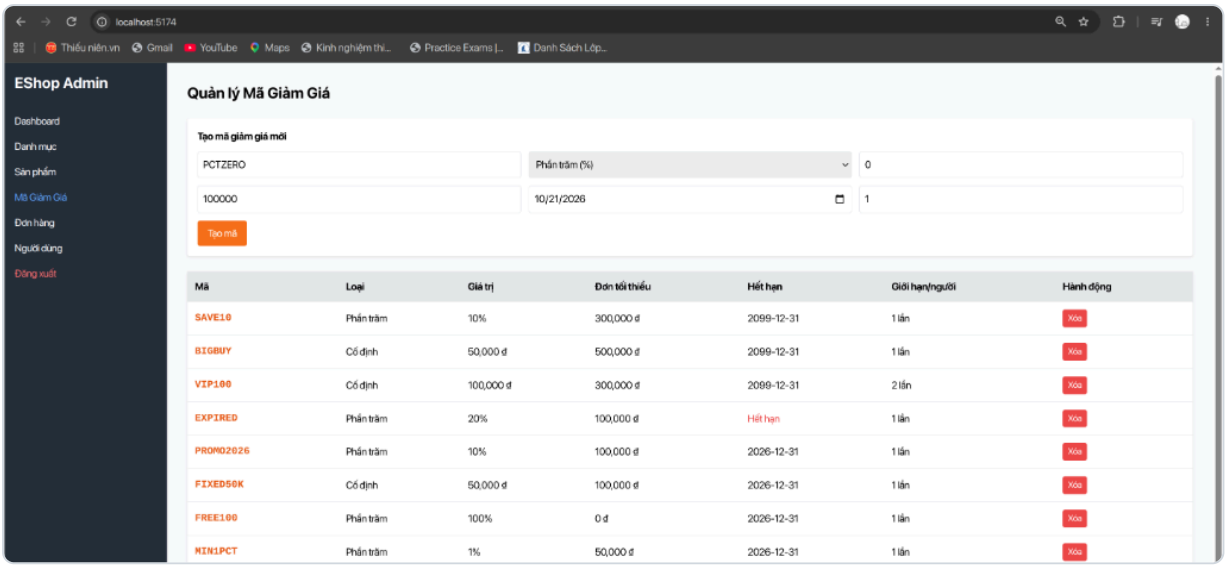
- Trong toán học và chuẩn kiểm thử giá trị biên ISTQB, thuật ngữ "dương" bắt buộc giá trị $V > 0$.
- Ô nhập liệu giao diện Admin phải bổ sung thuộc tính `min="1"` (cho %) hoặc `min="1000"` (cho cố định).
- Cả UI và backend API phải từ chối `discount_value <= 0` với mã lỗi **HTTP 400 Bad Request** (`{"error": "Giá trị giảm giá phải lớn hơn 0"}`).
- Không lưu bất kỳ bản ghi coupon nào có giá trị giảm bằng 0 vào CSDL.

5. Kết quả thực tế (Actual Result):

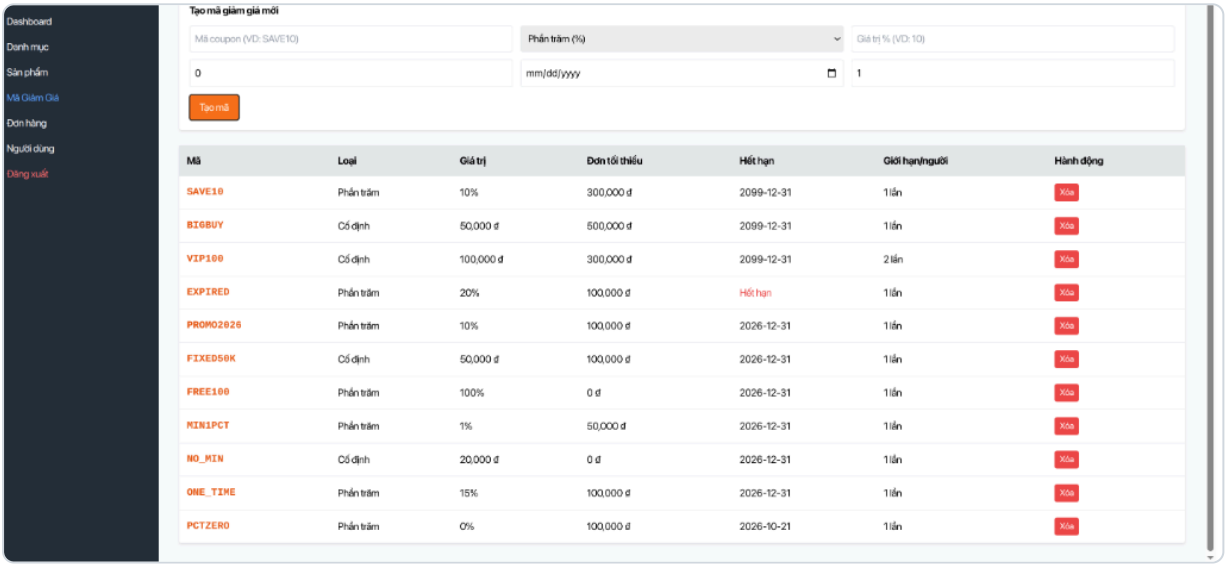
- Ô nhập `discount_value` trên Admin Web thiếu thuộc tính `min="1"`, cho phép người dùng nhập và submit số `0`.
- Endpoint `POST /api/admin/coupons` trả về **`HTTP 200 OK`**: `{"message":"Coupon created","id":22}`.
- Bảng CSDL SQLite lưu trữ bản ghi có `discount_value = 0`.
- Bảng quản trị hiển thị dòng coupon `PCTZERO` với `Giá trị: 0%`, hoàn toàn không mang lại giá trị giảm giá cho khách hàng khi áp dụng.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp form nhập giá trị 0:*



- *Ảnh chụp bảng Admin hiển thị coupon 0%:*



- *Ảnh chụp terminal thực thi API và mã HTTP 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/26

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `frontend-admin/src/App.jsx`, dòng 665–675: Ô input chỉ có `type="number"` và `required`, không có `min="1"`.

  - File `backend/server.js`, dòng 457–481: Không kiểm tra `Number(discount_value) > 0` trước khi insert.
- **Khắc phục:**
  - Frontend: Thêm `min={couponForm.type === 'percent' ? "1" : "1000"}` vào thẻ input.
  - Backend: Thêm `if (discount_value === undefined || discount_value === null || Number(discount_value) <= 0) return res.status(400).json({ error: "Giá trị giảm giá phải lớn hơn 0" });`.

[BUG-FR17-06] Form Admin và API cho phép tạo coupon có giá trị giảm âm (-10%), gây sai lệch số học tài chính

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-06`
Tiêu đề Bug	`[FR-17][Admin Web & API] Coupon creation accepts negative discount_value and creates negative percentage coupon`
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Vi phạm ràng buộc giá trị giảm dương $V > 0$ của đặc tả, tạo mã voucher có giá trị âm)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR17_15` (Miền giá trị âm $V < 0$, IEP)
GitHub Issue Link	Issue #27: [BUG] [FR-17][Admin Web & API] Coupon creation accepts negative discount_value and creates negative percentage coupon
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`, Admin Web tại `http://localhost:5174`.
- Đã đăng nhập tài khoản Quản trị viên (`admin@eshop.com`).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở Admin Web `:5174`, vào tab "Mã Giảm Giá".
2. Tại form "Tạo mã giảm giá mới", điền thông tin:
   - Mã coupon: `PCTNEG`
   - Loại: `Phần trăm (%)`
   - Giá trị %: `-10`
   - Đơn tối thiểu: `100000`
   - Ngày hết hạn: `10/22/2026`
   - Giới hạn/người: `1`
3. Nhấn nút "Tạo mã" $\to$ Form submit thành công, bảng bên dưới hiển thị dòng mã `PCTNEG` với `Giá trị: -10%`.
4. Hoặc gửi request trực tiếp qua curl tới API backend:

```
curl -i -s -X POST http://localhost:3000/api/admin/coupons \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $ADMIN_TOKEN" \
  -d '{"code":"PCTNEGG","type":"percent","discount_value":-10,"min_order_amount":100000,"expired_at":"2026-12-31","max_uses_per_user":1}'
```

5. Kiểm tra CSDL SQLite: `SELECT * FROM coupons WHERE discount_value < 0;`.

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "code": "PCTNEG",
  "type": "percent",
  "discount_value": -10,
  "min_order_amount": 100000,
  "expired_at": "2026-12-31",
  "max_uses_per_user": 1
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-17):

> *Trích dẫn SRS FR-17:* "Các trường bắt buộc: ... `discount_value` (dương)..."

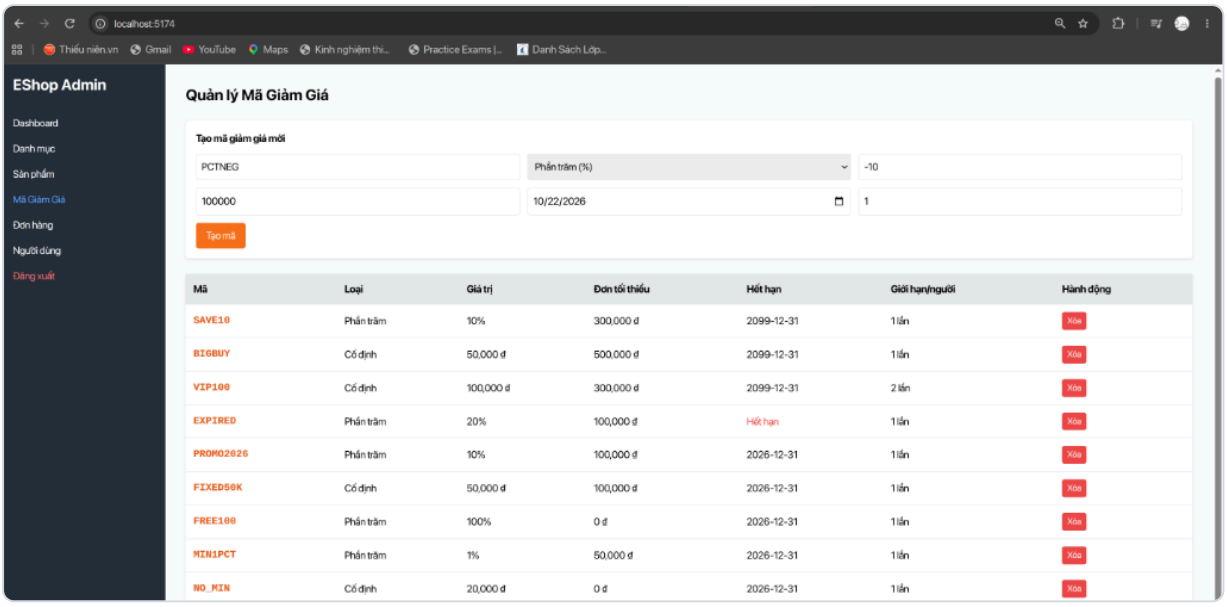
- Trong toán học và chuẩn kiểm thử ISTQB, giá trị dương bắt buộc $V > 0$. Miền giá trị âm $V < 0$ thuộc Invalid Equivalence Partition.
- Ô nhập liệu giao diện Admin phải chặn nhập số âm (`min="1"`).
- Cả UI và backend API phải từ chối `discount_value < 0` với mã lỗi **HTTP 400 Bad Request** (`{"error": "Giá trị giảm giá phải lớn hơn 0"}`).
- Không lưu bất kỳ bản ghi coupon nào có giá trị âm vào CSDL.

5. Kết quả thực tế (Actual Result):

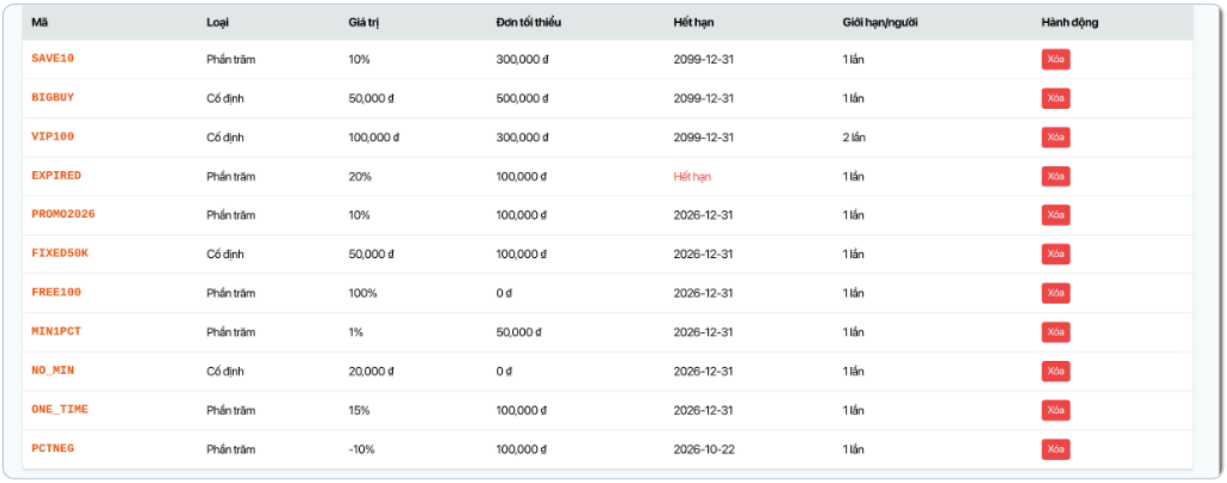
- Ô nhập `discount_value` trên Admin Web thiếu thuộc tính `min="1"`, cho phép người dùng nhập và submit số âm `-10`.
- Endpoint `POST /api/admin/coupons` trả về **`HTTP 200 OK`**: `{"message":"Coupon created","id":25}`.
- Bảng CSDL SQLite lưu trữ bản ghi có `discount_value = -10`.
- Bảng quản trị hiển thị dòng coupon `PCTNEG` với `Giá trị: -10%`, gây biến dạng số học tài chính khi tính tiền giỏ hàng/thanh toán.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp form nhập giá trị âm:*



- *Ảnh chụp bảng Admin hiển thị coupon -10%:*



- *Ảnh chụp terminal thực thi API và mã HTTP 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/27

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `frontend-admin/src/App.jsx`, dòng 665–675: Ô input chỉ có `type="number"` và `required`, không có `min="1"`.
  - File `backend/server.js`, dòng 457–481: Không kiểm tra `Number(discount_value) > 0` trước khi insert.
- **Khắc phục:**

- Frontend: Thêm `min={couponForm.type === 'percent' ? "1" : "1000"}` vào thẻ input.
- Backend: Thêm `if (discount_value === undefined || discount_value === null || Number(discount_value) <= 0) return res.status(400).json({ error: "Giá trị giảm giá phải lớn hơn 0" });`.

[BUG-FR17-07] Form Admin và API cho phép tạo coupon có tỷ lệ giảm giá vượt 100% (101%)

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-07`
Tiêu đề Bug	`[FR-17][Admin Web & API] Coupon creation accepts discount_value > 100% and creates 101% discount coupon`
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Vi phạm ràng buộc tỷ lệ phần trăm tối đa 100% của đặc tả, tạo mã voucher giảm vượt quá giá trị đơn hàng)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR17_16` (Biên Off-point $V = 101%$, BVA & Conditional IEP)
GitHub Issue Link	Issue #28: [BUG] [FR-17][Admin Web & API] Coupon creation accepts discount_value > 100% and creates 101% discount coupon
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`, Admin Web tại `http://localhost:5174`.
- Đã đăng nhập tài khoản Quản trị viên (`admin@eshop.com`).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở Admin Web `:5174`, vào tab "Mã Giảm Giá".
2. Tại form "Tạo mã giảm giá mới", điền thông tin:
   - Mã coupon: `OVER101`
   - Loại: `Phần trăm (%)`
   - Giá trị %: `101`
   - Đơn tối thiểu: `100000`
   - Ngày hết hạn: `10/31/2026`
   - Giới hạn/người: `1`
3. Nhấn nút "Tạo mã" $\to$ Form submit thành công, bảng bên dưới hiển thị dòng mã `OVER101` với `Giá trị: 101%`.
4. Hoặc gửi request trực tiếp qua curl tới API backend:

```
curl -i -s -X POST http://localhost:3000/api/admin/coupons \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $ADMIN_TOKEN" \
  -d '{"code":"OVER101","type":"percent","discount_value":101,"min_order_amount":100000,"expired_at":"2026-12-31","max_uses_per_user":1}'
```

5. Kiểm tra CSDL SQLite: `SELECT * FROM coupons WHERE discount_value > 100;`.

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "code": "OVER101",
  "type": "percent",
  "discount_value": 101,
  "min_order_amount": 100000,
  "expired_at": "2026-12-31",
  "max_uses_per_user": 1
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-17):

> *Trích dẫn SRS FR-17:* "Các trường bắt buộc: ... `discount_value` (dương)... Tỷ lệ phần trăm giảm giá tối đa 100%."

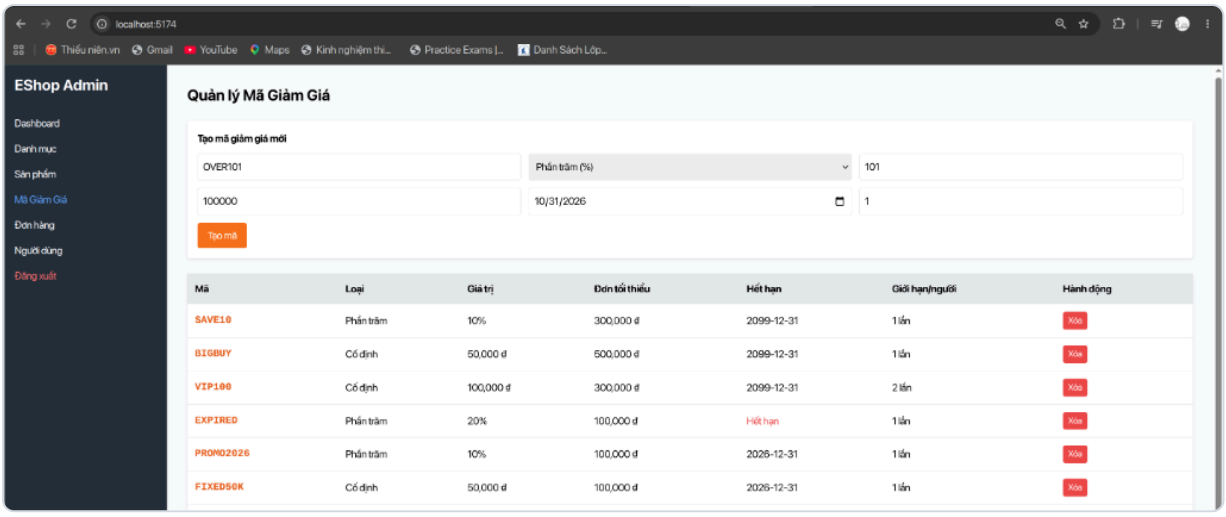
- Trong toán học và phân tích biên ISTQB, tỷ lệ giảm giá theo phần trăm bắt buộc $V \le 100%$. Điểm biên $V = 101%$ thuộc Invalid Equivalence Partition (`EP-17-19`, `BVA-17-04-OFF`).
- Ô nhập liệu giao diện Admin phải có thuộc tính `max="100"` khi chọn loại `percent`.
- Cả UI và backend API phải từ chối giá trị phần trăm > 100 với mã lỗi **HTTP 400 Bad Request** (`{"error": "Tỷ lệ giảm giá theo phần trăm không được vượt quá 100%"}`).
- Không lưu bất kỳ bản ghi coupon nào có tỷ lệ phần trăm $> 100%$ vào CSDL.

5. Kết quả thực tế (Actual Result):

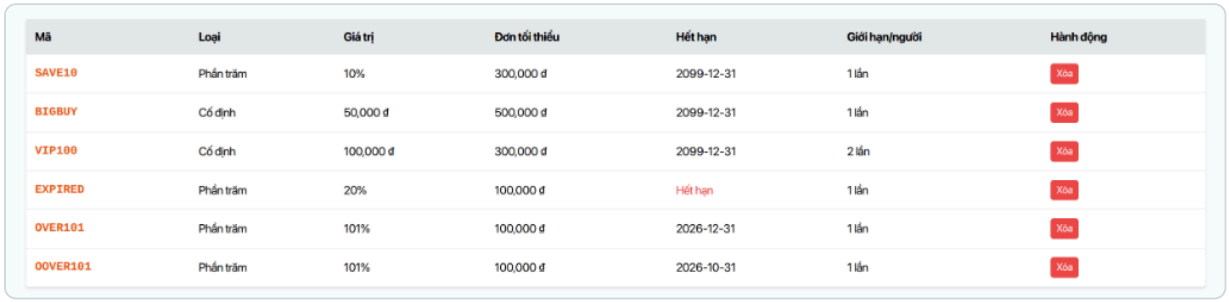
- Ô nhập `discount_value` trên Admin Web thiếu thuộc tính `max="100"`, cho phép người dùng nhập và submit số `101`.
- Endpoint `POST /api/admin/coupons` trả về **`HTTP 200 OK`**: `{"message":"Coupon created","id":5}`.
- Bảng CSDL SQLite lưu trữ bản ghi có `type = 'percent'` và `discount_value = 101`.
- Bảng quản trị hiển thị dòng coupon `OVER101` với `Giá trị: 101%`, gây trừ vượt giá trị đơn hàng khi thanh toán.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp form nhập giá trị 101%:*



- *Ảnh chụp bảng Admin hiển thị coupon 101%:*



Mã	Loại	Giá trị	Đơn tối thiểu	Hết hạn	Giới hạn/người	Hành động
SAVE10	Phần trăm	10%	300,000 đ	2099-12-31	1 lần	Xóa
BIGBUY	Cố định	50,000 đ	500,000 đ	2099-12-31	1 lần	Xóa
VIP100	Cố định	100,000 đ	300,000 đ	2099-12-31	2 lần	Xóa
EXPIRED	Phần trăm	20%	100,000 đ	Hết hạn	1 lần	Xóa
OVER101	Phần trăm	101%	100,000 đ	2026-12-31	1 lần	Xóa
OOVER101	Phần trăm	101%	100,000 đ	2026-10-31	1 lần	Xóa

- *Ảnh chụp terminal thực thi API và mã HTTP 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/28

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `frontend-admin/src/App.jsx`, dòng 659–675: Ô input chỉ có `type="number"` và `required`, không có `max={couponForm.type === 'percent' ? "100" : undefined}`.
  - File `backend/server.js`, dòng 457–481: Không kiểm tra `if (type === 'percent' && Number(discount_value) > 100)` trước khi insert.
- **Khắc phục:**
  - Frontend: Thêm `max={couponForm.type === 'percent' ? "100" : undefined}` vào thẻ input.
  - Backend: Thêm `if (type === 'percent' && Number(discount_value) > 100) return res.status(400).json({ error: "Tỷ lệ giảm giá theo phần trăm không được vượt quá 100%" });`.

[BUG-FR17-08] Form Admin và API cho phép tạo coupon giảm giá 0 ₫ (discount_value = 0) cho loại fixed

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-08`
Tiêu đề Bug	`[FR-17][Admin Web & API] Coupon creation accepts discount_value = 0 for fixed type and creates 0 ₫ coupon`
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Vi phạm ràng buộc giá trị giảm dương $V > 0$ của đặc tả, tạo mã voucher 0 ₫ vô nghĩa)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR17_17` (Biên On-point $V = 0\text{ ₫}$)
GitHub Issue Link	Issue #29: [BUG] [FR-17][Admin Web & API] Coupon creation accepts discount_value = 0 for fixed type and creates 0 ₫ coupon
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`, Admin Web tại `http://localhost:5174`.
- Đã đăng nhập tài khoản Quản trị viên (`admin@eshop.com`).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở Admin Web `:5174`, vào tab "Mã Giảm Giá".
2. Tại form "Tạo mã giảm giá mới", điền thông tin:
   - Mã coupon: `FIXZERO`
   - Loại: `Số tiền cố định (₫)`
   - Giá trị: `0`
   - Đơn tối thiểu: `100000`
   - Ngày hết hạn: `10/29/2026`
   - Giới hạn/người: `1`
3. Nhấn nút "Tạo mã" $\to$ Form submit thành công, bảng bên dưới hiển thị dòng mã `FIXZERO` với `Giá trị: 0 ₫`.
4. Hoặc gửi request trực tiếp qua curl tới API backend:

```
curl -i -s -X POST http://localhost:3000/api/admin/coupons \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $ADMIN_TOKEN" \
  -d '{"code":"FIXZERO","type":"fixed","discount_value":0,"min_order_amount":100000,"expired_at":"2026-12-31","max_uses_per_user":1}'
```

5. Kiểm tra CSDL SQLite: `SELECT * FROM coupons WHERE discount_value = 0;`.

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "code": "FIXZERO",
  "type": "fixed",
  "discount_value": 0,
  "min_order_amount": 100000,
  "expired_at": "2026-12-31",
  "max_uses_per_user": 1
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-17):

> *Trích dẫn SRS FR-17:* "Các trường bắt buộc: ... `discount_value` (dương)..."

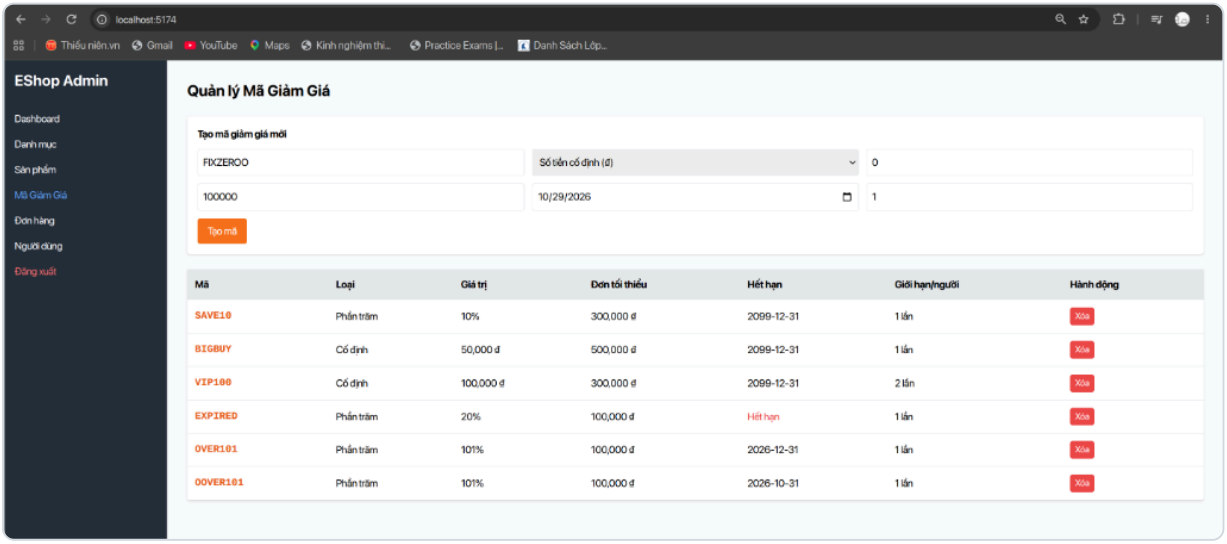
- Trong toán học và chuẩn kiểm thử giá trị biên ISTQB, thuật ngữ "dương" bắt buộc giá trị $V > 0$. Điểm biên $V = 0\text{ đ}$ thuộc Invalid Equivalence Partition (`EP-17-17`, `BVA-17-05-ON`).
- Ô nhập liệu giao diện Admin phải có thuộc tính `min="1000"` (hoặc `min="1"`) cho loại tiền cố định.
- Cả UI và backend API phải từ chối `discount_value <= 0` với mã lỗi **HTTP 400 Bad Request** (`{"error": "Số tiền giảm giá cố định phải lớn hơn 0 đ"}`).
- Không lưu bất kỳ bản ghi coupon nào có giá trị giảm bằng 0 đ vào CSDL.

5. Kết quả thực tế (Actual Result):

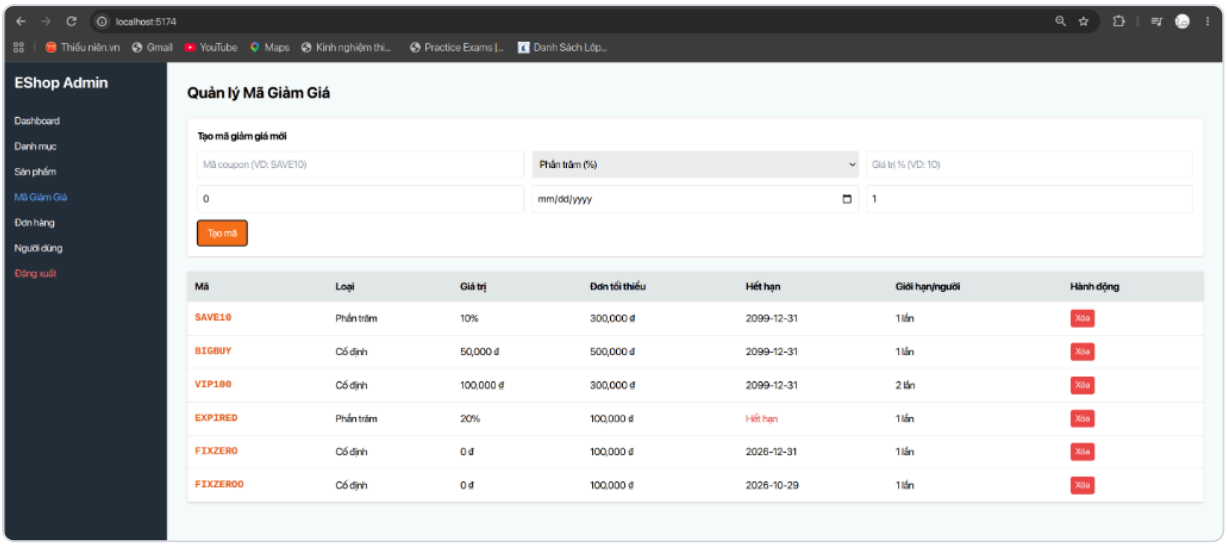
- Ô nhập `discount_value` trên Admin Web thiếu thuộc tính `min="1000"` hoặc `min="1"`, cho phép người dùng nhập và submit số `0`.
- Endpoint `POST /api/admin/coupons` trả về `HTTP 200 OK`: `{"message":"Coupon created","id":5}`.
- Bảng CSDL SQLite lưu trữ bản ghi có `type = 'fixed'` và `discount_value = 0`.
- Bảng quản trị hiển thị dòng coupon `FIXZERO` với `Giá trị: 0 đ`, hoàn toàn không mang lại giá trị giảm giá cho khách hàng khi áp dụng.

6. Bằng chứng kiểm thử (Screenshots & Logs):

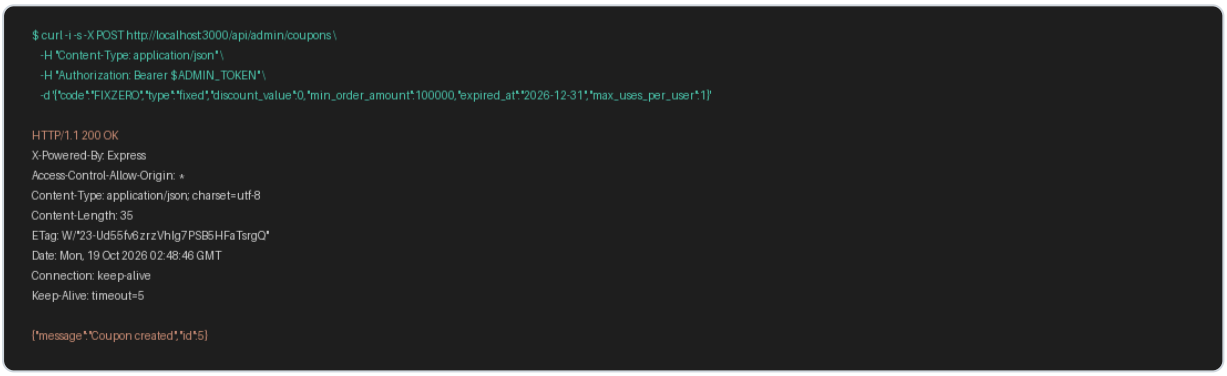
- *Ảnh chụp form nhập giá trị 0 đ:*



- *Ảnh chụp bảng Admin hiển thị coupon 0 đ:*



- *Ảnh chụp terminal thực thi API và mã HTTP 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/29

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `frontend-admin/src/App.jsx`, dòng 659–675: Ô input chỉ có `type="number"` và `required`, không có `min={couponForm.type === 'percent' ? "1" : "1000"}`.
  - File `backend/server.js`, dòng 457–481: Không kiểm tra `Number(discount_value) > 0` trước khi insert.
- **Khắc phục:**
  - Frontend: Thêm `min={couponForm.type === 'percent' ? "1" : "1000"}` vào thẻ input.
  - Backend: Thêm `if (discount_value === undefined || discount_value === null || Number(discount_value) <= 0) return res.status(400).json({ error: "Giá trị giảm giá phải lớn hơn 0" });`.

[BUG-FR17-09] Form Admin và API cho phép tạo coupon có giá trị đơn tối thiểu âm (-1 ₫)

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-09`
Tiêu đề Bug	`[FR-17][Admin Web & API] Coupon creation accepts negative min_order_amount (-1) and persists in database`

Trường thông tin	Chi tiết
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Vi phạm ràng buộc giá trị đơn tối thiểu phi âm $M \ge 0$ của đặc tả, tạo mã voucher có điều kiện áp dụng âm)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR17_18` (Biên Off-point $M = -1\text{ đ}$, BVA)
GitHub Issue Link	Issue #30: [BUG] [FR-17][Admin Web & API] Coupon creation accepts negative min_order_amount (-1) and persists in database
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`, Admin Web tại `http://localhost:5174`.
- Đã đăng nhập tài khoản Quản trị viên (`admin@eshop.com`).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở Admin Web `:5174`, vào tab "Mã Giảm Giá".
2. Tại form "Tạo mã giảm giá mới", điền thông tin:
   - Mã coupon: `NEGMIN`
   - Loại: `Phần trăm (%)`
   - Giá trị %: `10`
   - Đơn tối thiểu: `-1`
   - Ngày hết hạn: `10/19/2026`
   - Giới hạn/người: `1`
3. Nhấn nút "Tạo mã" $\to$ Form submit thành công, bảng bên dưới hiển thị dòng mã `NEGMIN` với `Đơn tối thiểu: -1 ₫`.
4. Hoặc gửi request trực tiếp qua curl tới API backend:

```
curl -i -s -X POST http://localhost:3000/api/admin/coupons \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $ADMIN_TOKEN" \
  -d '{"code":"NEGMIN","type":"percent","discount_value":10,"min_order_amount":-1,"expired_at":"2026-12-3
1","max_uses_per_user":1}'
```

5. Kiểm tra CSDL SQLite: `SELECT * FROM coupons WHERE min_order_amount < 0;`.

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "code": "NEGMIN",
  "type": "percent",
  "discount_value": 10,
  "min_order_amount": -1,
  "expired_at": "2026-12-31",
  "max_uses_per_user": 1
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-17):

> *Trích dẫn SRS FR-17:* "Các trường bắt buộc: ... `min_order_amount` (>= 0)..."

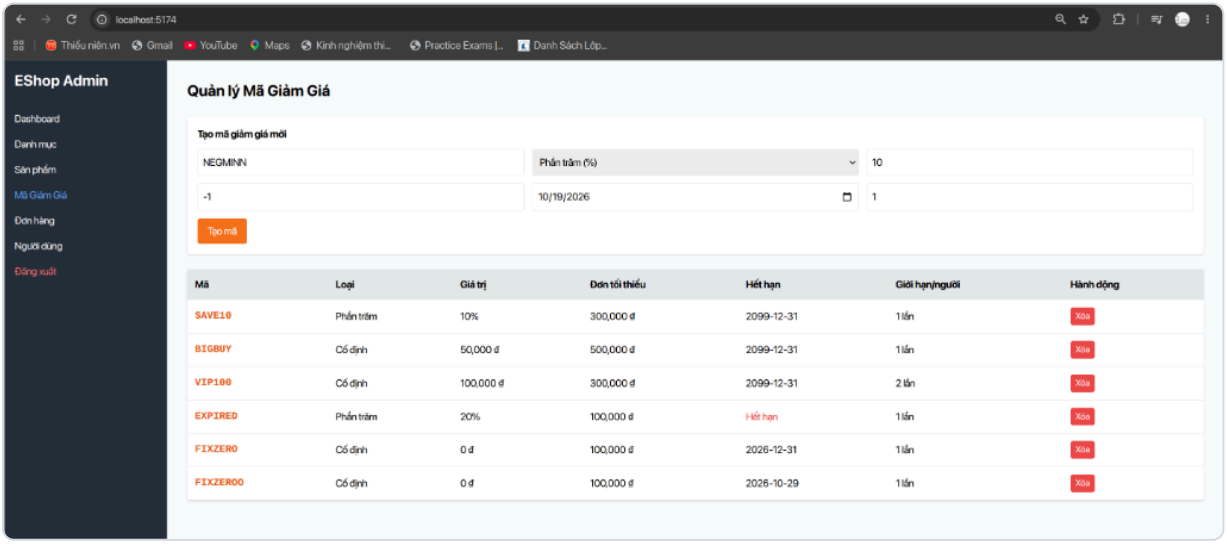
- Trong kiểm thử giá trị biên ISTQB, điểm biên On-point là $M = 0\text{ đ}$ và Off-point là $M = -1\text{ đ}$ thuộc Invalid Equivalence Partition (`EP-17-28`, `BVA-17-06-OFF`).
- Ô nhập liệu "Đơn tối thiểu (đ)" trên giao diện Admin phải có thuộc tính `min="0"` để ngăn nhập số âm.
- Cả UI và backend API phải từ chối `min_order_amount < 0` với mã lỗi **HTTP 400 Bad Request** (`{"error": "Đơn hàng tối thiểu không được âm"}`).
- Không lưu bất kỳ bản ghi coupon nào có giá trị đơn tối thiểu âm vào CSDL.

5. Kết quả thực tế (Actual Result):

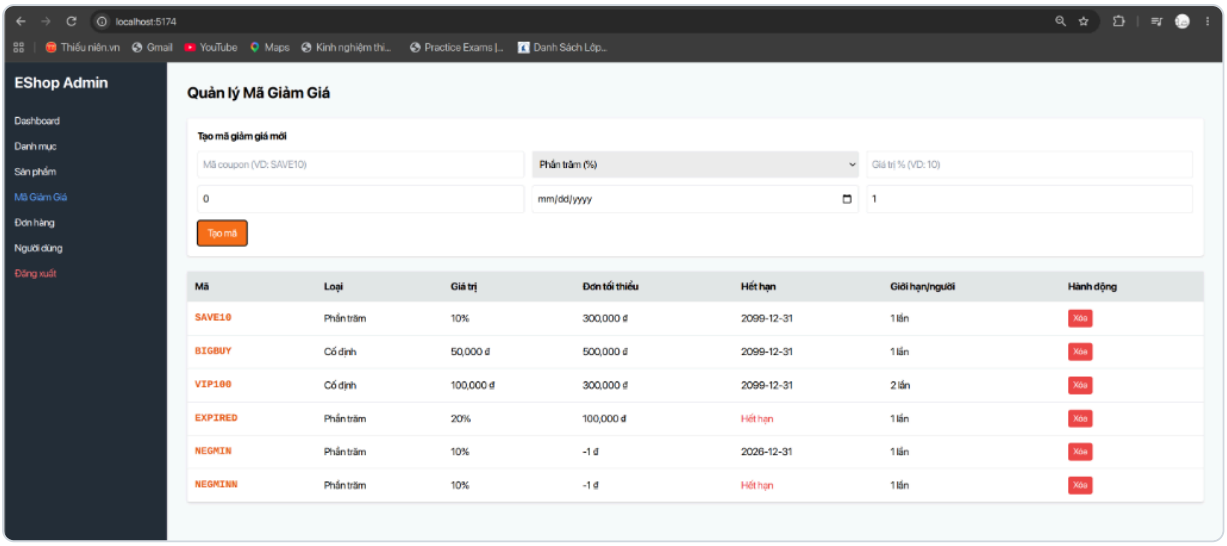
- Ô nhập `min_order_amount` trên Admin Web thiếu thuộc tính `min="0"`, cho phép người dùng nhập và submit số `-1`.
- Endpoint `POST /api/admin/coupons` trả về `HTTP 200 OK`: `{"message":"Coupon created","id":7}`.
- Bảng CSDL SQLite lưu trữ bản ghi có `min_order_amount = -1`.
- Bảng quản trị hiển thị dòng coupon `NEGMIN` với `Đơn tối thiểu: -1 ₫`, làm sai lệch quy tắc số học kinh doanh của hệ thống.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp form nhập giá trị đơn tối thiểu âm:*



- *Ảnh chụp bảng Admin hiển thị coupon có đơn tối thiểu -1 ₫:*



- *Ảnh chụp terminal thực thi API và mã HTTP 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/30

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `frontend-admin/src/App.jsx`, dòng 676–687: Ô input chỉ có `type="number"` và `required`, không có `min="0"`.
  - File `backend/server.js`, dòng 457–481: Không kiểm tra `Number(min_order_amount) >= 0` trước khi insert.
- **Khắc phục:**
  - Frontend: Thêm `min="0"` vào thẻ input của `min_order_amount`.
  - Backend: Thêm `if (min_order_amount !== undefined && min_order_amount !== null && Number(min_order_amount) < 0) return res.status(400).json({ error: "Đơn hàng tối thiểu không được âm" });`.

[BUG-FR17-10] Endpoint POST /api/admin/coupons chấp nhận max_uses_per_user = 0 và tự ép thành 1 thay vì trả về HTTP 400

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-10`

Trường thông tin	Chi tiết
Tiêu đề Bug	`[FR-17][Backend API] Endpoint POST /api/admin/coupons accepts max_uses_per_user = 0 and silently coerces to 1 via falsy fallback instead of rejecting with HTTP 400`
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Vi phạm ràng buộc giá trị số lần sử dụng tối thiểu $U \ge 1$ của đặc tả, bỏ qua kiểm tra dữ liệu API và tự ý thay đổi dữ liệu người dùng)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR17_19` (Biên Off-point $U = 0$, BVA)
GitHub Issue Link	Issue #31: [BUG] [FR-17][Backend API] Endpoint POST /api/admin/coupons accepts max_uses_per_user = 0 and silently coerces to 1 via falsy fallback instead of rejecting with HTTP 400
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`, Admin Web tại `http://localhost:5174`.
- Đã đăng nhập tài khoản Quản trị viên (`admin@eshop.com`).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở Admin Web `:5174`, vào tab "Mã Giảm Giá", nhập `max_uses_per_user = 0` $\to$ Trình duyệt hiển thị HTML5 validation tooltip chặn submit form: *"Value must be greater than or equal to 1"*.
2. Gửi request trực tiếp qua curl tới API backend bypass UI validation:

```
curl -i -s -X POST http://localhost:3000/api/admin/coupons \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $ADMIN_TOKEN" \
  -d '{"code":"ZEROUSESS","type":"percent","discount_value":10,"min_order_amount":100000,"expired_at":"2026
-12-31","max_uses_per_user":0}'
```

3. Quan sát phản hồi HTTP status code và body.
4. Kiểm tra CSDL SQLite:

```
node -e "const sqlite3 = require('./backend/node_modules/sqlite3'); const db = new sqlite3.Database('./back
end/database.sqlite'); db.all('SELECT id, code, max_uses_per_user FROM coupons WHERE code=\"ZEROUSESS\"',
(err, rows) => console.log(rows));"
```

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "code": "ZEROUSESS",
  "type": "percent",
  "discount_value": 10,
  "min_order_amount": 100000,
  "expired_at": "2026-12-31",
  "max_uses_per_user": 0
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-17):

> *Trích dẫn SRS FR-17:* "Các trường bắt buộc: ... `max_uses_per_user` (>= 1)..."

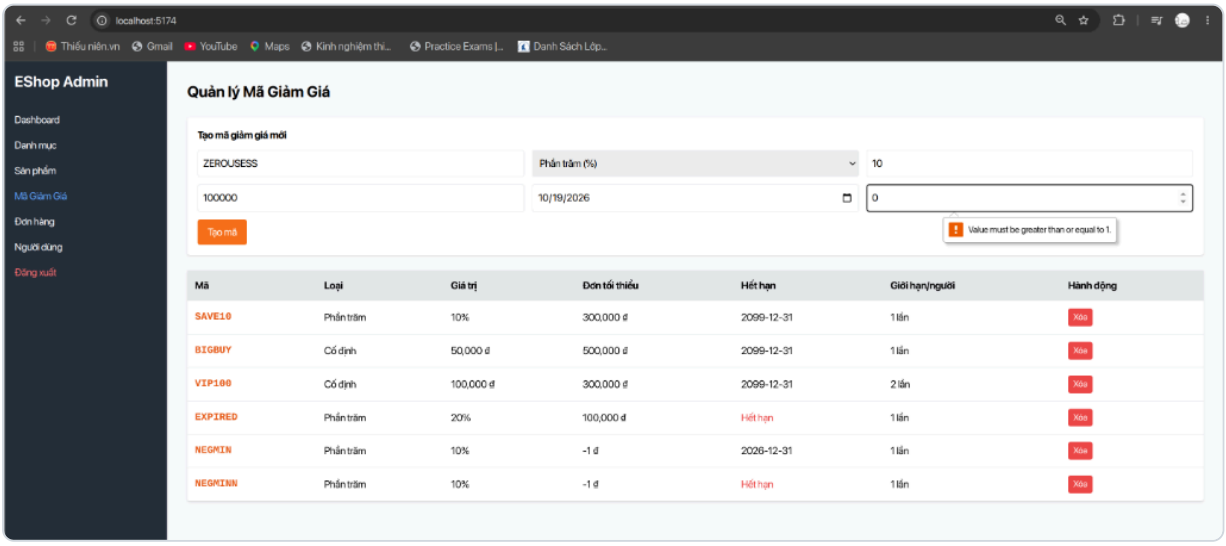
- Trong kiểm thử giá trị biên ISTQB, điểm biên On-point là $U = 1$ và Off-point là $U = 0$ thuộc Invalid Equivalence Partition (`EP-17-32`, `BVA-17-07-OFF`).
- Backend API bắt buộc phải validate `Number(max_uses_per_user) >= 1`. Khi nhận giá trị bằng 0, API phải từ chối với mã lỗi **HTTP 400 Bad Request** (`{"error": "Số lần sử dụng tối đa mỗi người phải từ 1 trở lên"}`).
- Hệ thống không được phép tự ý thay đổi dữ liệu đầu vào của client (Silent Coercion).
- Không tạo bản ghi coupon mới trong CSDL khi payload không hợp lệ.

5. Kết quả thực tế (Actual Result):

- Trên Admin Web UI, trường input có `min="1"` nên trình duyệt kích hoạt HTML5 validation tooltip chặn gửi form.
- Tuy nhiên trên tầng backend API `POST /api/admin/coupons`, hệ thống bỏ qua kiểm tra và trả về `HTTP 200 OK`: `{"message":"Coupon created","id":10}`.
- Bảng CSDL SQLite lưu trữ bản ghi với `max_uses_per_user = 1` do mã nguồn backend sử dụng toán tử fallback `max_uses_per_user || 1` (trong JS, số `0` là *falsy* nên `0 || 1` tự đánh giá thành `1`).
- Hành vi này vi phạm nguyên tắc thiết kế REST API, âm thầm thay đổi dữ liệu đầu vào và cho phép bypass kiểm tra nghiệp vụ từ tầng client.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp tooltip trình duyệt chặn submit trên UI Admin:*



- *Ảnh chụp terminal thực thi API và nhận mã HTTP 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/31

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `backend/server.js`, dòng 474:

    ```
    max_uses_per_user || 1,
    ```

    Toán tử `||` coi `0` là falsy và tự động gán thành `1`, dẫn đến bỏ qua hoàn toàn việc kiểm tra ràng buộc $U \ge 1$.
- **Khắc phục:**
  - Thêm kiểm tra đầu vào trước khi insert:

    ```
    if (max_uses_per_user !== undefined && max_uses_per_user !== null && Number(max_uses_per_user) < 1)
    {
      return res.status(400).json({ error: "Số lần sử dụng tối đa mỗi người phải từ 1 trở lên" });
    }
    ```

[BUG-FR17-11] Endpoint POST /api/admin/coupons chấp nhận max_uses_per_user âm (-1) với HTTP 200 OK và lưu vào CSDL

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-11`
Tiêu đề Bug	`[FR-17][Backend API] Endpoint POST /api/admin/coupons accepts negative max_uses_per_user (-1) with HTTP 200 OK and stores in SQLite`
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Vi phạm ràng buộc giá trị số lần sử dụng tối thiểu $U \ge 1$ của đặc tả, lưu giá trị âm làm phá vỡ logic kiểm tra điều kiện áp dụng mã)
Mức ưu tiên (Priority)	**High (P1)**

Trường thông tin	Chi tiết
Test Case phát hiện	`TC_FR17_20` (Miền giá trị âm $U < 0$, IEP)
GitHub Issue Link	Issue #32: [BUG] [FR-17][Backend API] Endpoint POST /api/admin/coupons accepts negative max_uses_per_user (-1) with HTTP 200 OK and stores in SQLite
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`, Admin Web tại `http://localhost:5174`.
- Đã đăng nhập tài khoản Quản trị viên (`admin@eshop.com`).

2. Các bước tái hiện (Steps to Reproduce):

1. Mở Admin Web `:5174`, vào tab "Mã Giảm Giá", nhập `max_uses_per_user = -1` $\to$ Trình duyệt hiển thị HTML5 validation tooltip chặn submit form.
2. Gửi request trực tiếp qua curl tới API backend bypass UI validation:

```
curl -i -s -X POST http://localhost:3000/api/admin/coupons \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $ADMIN_TOKEN" \
  -d '{"code":"NEGUSES2","type":"percent","discount_value":10,"min_order_amount":100000,"expired_at":"2026-12-31","max_uses_per_user":-1}'
```

3. Quan sát phản hồi HTTP status code và body.
4. Kiểm tra CSDL SQLite:

```
node -e "const sqlite3 = require('./backend/node_modules/sqlite3'); const db = new sqlite3.Database('./backend/database.sqlite'); db.all('SELECT id, code, max_uses_per_user FROM coupons WHERE code=\"NEGUSES2\"', (err, rows) => console.log(rows));"
```

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "code": "NEGUSES2",
  "type": "percent",
  "discount_value": 10,
  "min_order_amount": 100000,
  "expired_at": "2026-12-31",
  "max_uses_per_user": -1
}
```

4. Kết quả mong đợi (Expected Result theo SRS FR-17):

> *Trích dẫn SRS FR-17:* "Các trường bắt buộc: ... `max_uses_per_user` (>= 1)..."

- Giá trị âm ($U < 0$) thuộc Invalid Equivalence Partition (`EP-17-33`).
- Backend API bắt buộc phải validate `Number(max_uses_per_user) >= 1`. Khi nhận giá trị âm, API phải từ chối với mã lỗi **HTTP 400 Bad Request** (`{"error": "Sô´lâ`n sư’dụng tôí đa môĩ người phải từ 1 trở lên"}`).

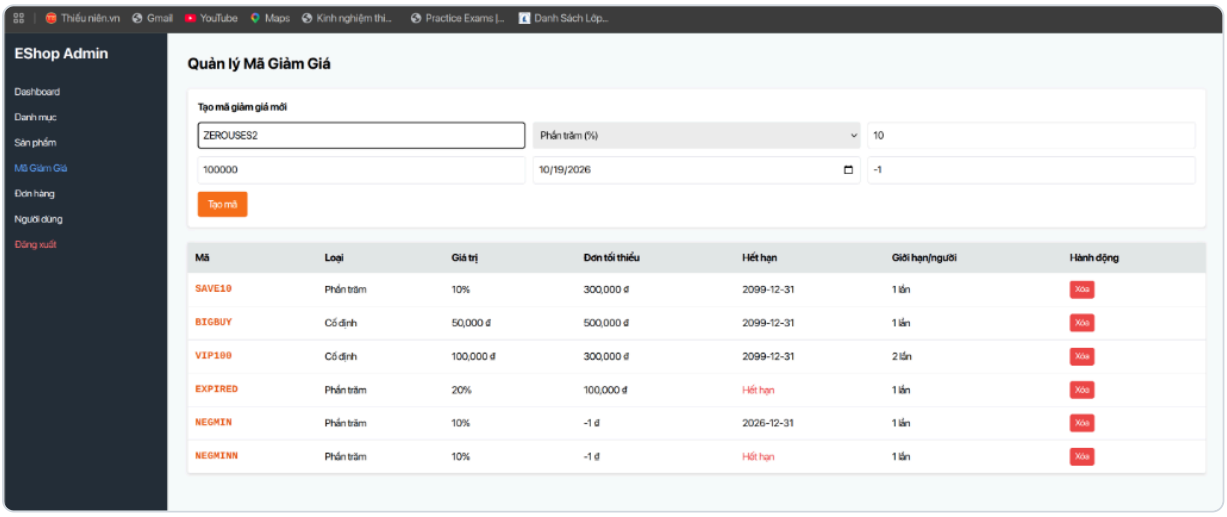
- Không lưu bất kỳ bản ghi coupon nào có số lần dùng âm vào CSDL.

5. Kết quả thực tế (Actual Result):

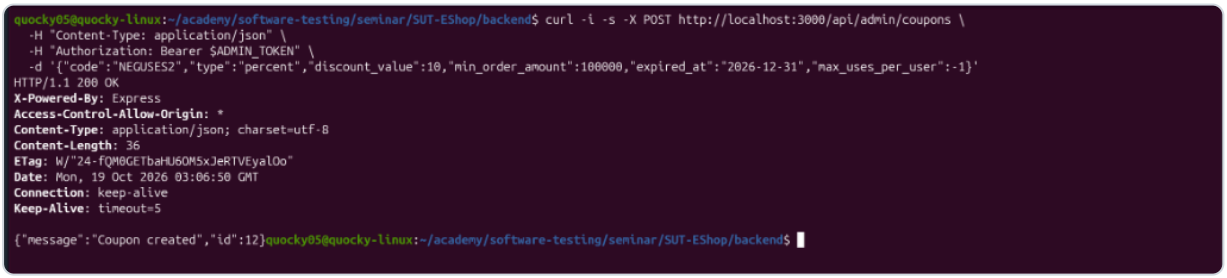
- Trên Admin Web UI, trường input có `min="1"` nên chặn gửi form từ trình duyệt.
- Tuy nhiên trên tầng backend API `POST /api/admin/coupons`, hệ thống chấp nhận request và trả về `HTTP 200 OK`: `{"message":"Coupon created","id":12}`.
- Bảng CSDL SQLite lưu trữ bản ghi với `max_uses_per_user = -1`. Do `-1` là giá trị *truthy* trong JavaScript, biểu thức `max_uses_per_user || 1` giữ nguyên giá trị `-1` và insert trực tiếp vào SQL.
- Khi người dùng sử dụng mã này, phép so sánh số lần đã dùng với số lần tối đa (`usage_count < max_uses_per_user`, ví dụ `0 < -1` $\to$ false) khiến mã bị vô hiệu hóa hoặc gây sai lệch logic đếm số lượt.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp form nhập giá trị âm trên UI Admin:*



- *Ảnh chụp terminal thực thi API và nhận mã HTTP 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/32

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `backend/server.js`, dòng 474:

    ```
    max_uses_per_user || 1,
    ```

    Thiếu hoàn toàn bước kiểm tra `Number(max_uses_per_user) < 1`.
- **Khắc phục:**

- Thêm kiểm tra đầu vào trước khi insert:

```
if (max_uses_per_user !== undefined && max_uses_per_user !== null && Number(max_uses_per_user) < 1)
{
  return res.status(400).json({ error: "Sô´lâ`n sư’dụng tôí đa môĩ người phải từ 1 trở lên" });
}
```

[BUG-FR17-12] Endpoint POST /api/admin/coupons thiếu authorizeAdmin cho phép user thường (role='user') tạo coupon

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-12`
Tiêu đề Bug	`[SEC-03][BUG] [FR-17][Backend API] Missing authorizeAdmin guard allows regular users (role='user') to create coupons via POST /api/admin/coupons`
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá & Bảo mật RBAC API (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Critical** (Lỗ hổng leo thang đặc quyền - Privilege Escalation / BOLA Security Vulnerability)
Mức ưu tiên (Priority)	**High (P0 - Security Hotspot)**
Test Case phát hiện	`TC_FR17_23` (SEC-03 RBAC Bypass)
GitHub Issue Link	Issue #33: [SEC-03][BUG] [FR-17][Backend API] Missing authorizeAdmin guard allows regular users (role='user') to create coupons via POST /api/admin/coupons
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`.
- Tài khoản người dùng thông thường (`test@eshop.com` / `Test1234!`, `role: 'user'`).

2. Các bước tái hiện (Steps to Reproduce):

1. Đăng nhập bằng tài khoản người dùng thông thường để lấy JWT token:

```
USER_TOKEN=$(curl -s -X POST http://localhost:3000/api/login \
  -H "Content-Type: application/json" \
  -d '{"email":"test@eshop.com","password":"Test1234!"}' | jq -r .token)
```

2. Gửi request tạo mã coupon Admin bằng token của user thông thường:

```
curl -i -s -X POST http://localhost:3000/api/admin/coupons \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $USER_TOKEN" \
  -d '{"code":"HACKEDD99","type":"percent","discount_value":99,"min_order_amount":0,"expired_at":"2026-12-3
1","max_uses_per_user":1}'
```

3. Quan sát phản hồi HTTP status code và body.
4. Kiểm tra CSDL SQLite:

```
node -e "const sqlite3 = require('./backend/node_modules/sqlite3'); const db = new sqlite3.Database('./back
end/database.sqlite'); db.all('SELECT * FROM coupons WHERE code=\"HACKEDD99\"', (err, rows) => console.log
(rows));"
```

3. Dữ liệu thử nghiệm (Test Data):

```
{
  "code": "HACKEDD99",
  "type": "percent",
  "discount_value": 99,
  "min_order_amount": 0,
  "expired_at": "2026-12-31",
  "max_uses_per_user": 1
}
```

4. Kết quả mong đợi (Expected Result theo SRS Mục 5.3 & SEC-03):

> *Trích dẫn SRS Mục 5.3 & SEC-03:* "Chỉ user có role='admin' mới được gọi API Admin... Tất cả các route quản trị `/api/admin/*` bắt buộc phải kiểm tra quyền quản trị viên."

- Endpoint `POST /api/admin/coupons` bắt buộc phải kiểm tra `req.user.role === 'admin'`.
- Người dùng thông thường không có quyền admin phải bị từ chối với mã lỗi **HTTP 403 Forbidden** (`{"error": "Forbidden: Admin access required"}`).
- Tuyệt đối không tạo bản ghi coupon mới trong CSDL từ request của user thường.

5. Kết quả thực tế (Actual Result):

- Endpoint `POST /api/admin/coupons` bỏ qua hoàn toàn kiểm tra phân quyền vai trò (RBAC).
- Backend chấp nhận request và phản hồi **`HTTP 200 OK`**: `{"message":"Coupon created","id":15}`.
- Bảng CSDL SQLite lưu trữ bản ghi `HACKEDD99` do user thông thường tạo ra với mức giảm giá 99%.
- **Mức độ ảnh hưởng an ninh:** Đây là lỗ hổng leo thang đặc quyền nghiêm trọng (Broken Object Level Authorization / Privilege Escalation), cho phép bất kỳ khách hàng nào tự tạo voucher giảm giá 99% - 100% để trục lợi mua hàng miễn phí.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp terminal thực thi API bằng token user thường và nhận mã HTTP 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/33

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `backend/server.js`, dòng 457:

    ```
    // ADMIN: CRUD Coupons
    app.post("/api/admin/coupons", authenticateToken, (req, res) => {
    ```

    Khai báo route chỉ có `authenticateToken`, thiếu middleware `authorizeAdmin` hoặc thiếu kiểm tra `if (!req.user || req.user.role !== 'admin')`.
- **Khắc phục:**
  - Bổ sung kiểm tra vai trò admin:

    ```
    app.post("/api/admin/coupons", authenticateToken, (req, res) => {
      if (!req.user || req.user.role !== "admin") {
        return res.status(403).json({ error: "Forbidden: Admin access required" });
      }
      // ...
    ```

[BUG-FR17-13] Endpoint DELETE /api/admin/coupons/:id trả về 200 OK khi xóa ID không tồn tại (9999) thay vì 404 Not Found

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-13`
Tiêu đề Bug	`[FR-17][Backend API] Endpoint DELETE /api/admin/coupons/:id returns HTTP 200 OK for non-existent ID 9999 instead of HTTP 404 Not Found`
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Medium** (Vi phạm chuẩn thiết kế REST API & Resource Handling)
Mức ưu tiên (Priority)	**Medium (P2)**

Trường thông tin	Chi tiết
Test Case phát hiện	`TC_FR17_24` (Tài nguyên không tồn tại, Single Fault)
GitHub Issue Link	Issue #34: [BUG] [FR-17][Backend API] Endpoint DELETE /api/admin/coupons/:id returns HTTP 200 OK for non-existent ID 9999 instead of HTTP 404 Not Found
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`.
- Đã đăng nhập tài khoản Quản trị viên (`admin@eshop.com`).
- Bảng `coupons` không chứa bản ghi nào có `id = 9999`.

2. Các bước tái hiện (Steps to Reproduce):

1. Đăng nhập tài khoản Admin lấy token xác thực:

```
ADMIN_TOKEN=$(curl -s -X POST http://localhost:3000/api/login \
  -H "Content-Type: application/json" \
  -d '{"email":"admin@eshop.com","password":"Admin123!"}' | jq -r .token)
```

2. Gửi request DELETE tới coupon ID 9999 không tồn tại:

```
curl -i -s -X DELETE http://localhost:3000/api/admin/coupons/9999 \
  -H "Authorization: Bearer $ADMIN_TOKEN"
```

3. Quan sát phản hồi HTTP status code và body.

3. Dữ liệu thử nghiệm (Test Data):

- Route: `DELETE /api/admin/coupons/9999`
- Header: `Authorization: Bearer $ADMIN_TOKEN`

4. Kết quả mong đợi (Expected Result theo SRS FR-17 & API Spec §6.4):

> *Trích dẫn SRS FR-17:* "Quản trị viên có thể xóa mã giảm giá... Hệ thống phải phản hồi mã lỗi chuẩn RESTful khi tài nguyên không tồn tại."

- Backend API bắt buộc phải kiểm tra số dòng bị ảnh hưởng (`this.changes === 0`).
- Khi xóa ID không tồn tại, API phải trả về mã lỗi **HTTP 404 Not Found** (`{"error": "Mã giảm giá không tồn tại"}`).
- Không được thông báo thành công giả ("Coupon deleted") khi không có bản ghi nào bị xóa.

5. Kết quả thực tế (Actual Result):

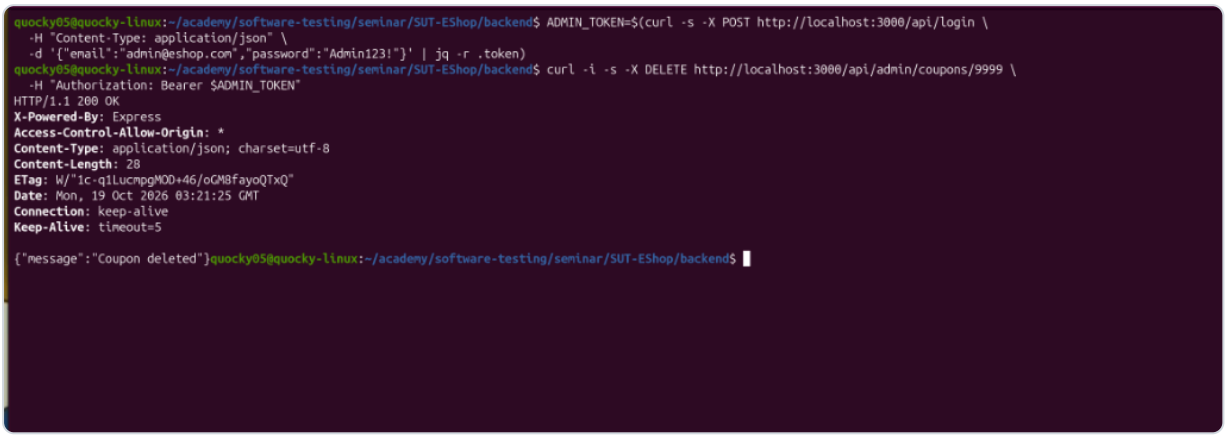
- Endpoint `DELETE /api/admin/coupons/:id` bỏ qua việc kiểm tra `this.changes`.
- Do SQLite không phát sinh lỗi khi câu lệnh `DELETE` không khớp dòng nào (`err` là null), route trả về **`HTTP/1.1 200 OK`**:

```
{"message":"Coupon deleted"}
```

- Hệ thống báo thành công giả, vi phạm nguyên tắc thiết kế REST API đối với tài nguyên không tồn tại.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp terminal thực thi DELETE ID 9999 và nhận HTTP 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/34

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `backend/server.js`, dòng 483–487:

```
app.delete("/api/admin/coupons/:id", authenticateToken, (req, res) => {
  db.run("DELETE FROM coupons WHERE id = ?", [req.params.id], function (err) {
    if (err) return res.status(500).json({ error: err.message });
    res.json({ message: "Coupon deleted" });
  });
});
```

  Không kiểm tra `if (this.changes === 0)`.
- **Khắc phục:**
  - Bổ sung kiểm tra số bản ghi bị ảnh hưởng:

```
app.delete("/api/admin/coupons/:id", authenticateToken, (req, res) => {
  db.run("DELETE FROM coupons WHERE id = ?", [req.params.id], function (err) {
    if (err) return res.status(500).json({ error: err.message });
    if (this.changes === 0) {
      return res.status(404).json({ error: "Mã giảm giá không tồn tại" });
    }
    res.json({ message: "Coupon deleted" });
  });
});
```

[BUG-FR17-14] Endpoint DELETE /api/admin/coupons/:id chấp nhận ID âm (-1) trả về 200 OK thay vì 400/404

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-14`

Trường thông tin	Chi tiết
Tiêu đề Bug	`[FR-17][Backend API] Endpoint DELETE /api/admin/coupons/:id accepts negative ID -1 with HTTP 200 OK instead of HTTP 400/404`
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Medium** (Vi phạm chuẩn thiết kế REST API & Input Parameter Validation)
Mức ưu tiên (Priority)	**Medium (P2)**
Test Case phát hiện	`TC_FR17_25` (Giá trị biên âm, Single Fault)
GitHub Issue Link	Issue #35: [BUG] [FR-17][Backend API] Endpoint DELETE /api/admin/coupons/:id accepts negative ID -1 with HTTP 200 OK instead of HTTP 400/404
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`.
- Đã đăng nhập tài khoản Quản trị viên (`admin@eshop.com`).

2. Các bước tái hiện (Steps to Reproduce):

1. Đăng nhập tài khoản Admin lấy token xác thực:

```
ADMIN_TOKEN=$(curl -s -X POST http://localhost:3000/api/login \
  -H "Content-Type: application/json" \
  -d '{"email":"admin@eshop.com","password":"Admin123!"}' | jq -r .token)
```

2. Gửi request DELETE tới coupon với ID âm `-1`:

```
curl -i -s -X DELETE http://localhost:3000/api/admin/coupons/-1 \
  -H "Authorization: Bearer $ADMIN_TOKEN"
```

3. Quan sát phản hồi HTTP status code và body.

3. Dữ liệu thử nghiệm (Test Data):

- Route: `DELETE /api/admin/coupons/-1`
- Header: `Authorization: Bearer $ADMIN_TOKEN`

4. Kết quả mong đợi (Expected Result theo SRS FR-17 & API Spec §6.4):

> *Trích dẫn SRS FR-17:* "Quản trị viên có thể xóa mã giảm giá... Tham số định danh tài nguyên (ID) phải là số nguyên dương."

- Khóa chính cơ sở dữ liệu quan hệ luôn là số nguyên dương ($ID \ge 1$). Giá trị âm `:id = -1` thuộc Lớp tương đương không hợp lệ (`RES-17-03`).
- Backend API bắt buộc phải validate `req.params.id` và từ chối ID âm với mã lỗi **HTTP 400 Bad Request** (`{"error": "ID mã giảm giá không hợp lệ"}`) hoặc **HTTP 404 Not Found**.
- Không được thông báo thành công giả ("Coupon deleted").

5. Kết quả thực tế (Actual Result):

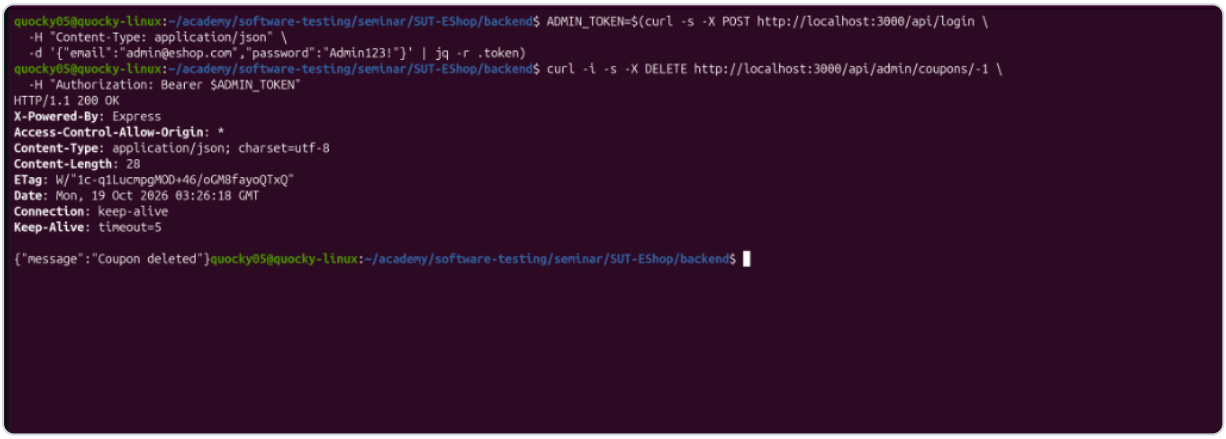
- Endpoint `DELETE /api/admin/coupons/:id` hoàn toàn không có bước xác thực tham số `:id` .
- Hệ thống trả về `HTTP/1.1 200 OK` :

```
{"message":"Coupon deleted"}
```

- Báo thành công xóa tài nguyên đối với một ID số âm phi lý.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp terminal thực thi DELETE ID -1 và nhận HTTP 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/35

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `backend/server.js` , dòng 483–487:

```
app.delete("/api/admin/coupons/:id", authenticateToken, (req, res) => {
  db.run("DELETE FROM coupons WHERE id = ?", [req.params.id], function (err) {
    if (err) return res.status(500).json({ error: err.message });
    res.json({ message: "Coupon deleted" });
  });
});
```

    Trực tiếp truyền `req.params.id` vào SQLite mà không kiểm tra tính hợp lệ của ID (`id <= 0`) hay kiểm tra `this.changes === 0` .
- **Khắc phục:**
  - Bổ sung xác thực tham số `id` và kiểm tra `this.changes` :

```
app.delete("/api/admin/coupons/:id", authenticateToken, (req, res) => {
  const id = Number(req.params.id);
  if (isNaN(id) || id <= 0) {
    return res.status(400).json({ error: "ID mã giảm giá không hợp lệ" });
  }
  db.run("DELETE FROM coupons WHERE id = ?", [id], function (err) {
    if (err) return res.status(500).json({ error: err.message });
    if (this.changes === 0) {
      return res.status(404).json({ error: "Mã giảm giá không tồn tại" });
    }
    res.json({ message: "Coupon deleted" });
  });
});
```

[BUG-FR17-15] Endpoint DELETE /api/admin/coupons/:id chấp nhận ID dạng chuỗi ('abc') trả về 200 OK thay vì 400 Bad Request

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-15`
Tiêu đề Bug	`[FR-17][Backend API] Endpoint DELETE /api/admin/coupons/:id accepts malformed string ID 'abc' with HTTP 200 OK instead of HTTP 400 Bad Request`
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Medium** (Vi phạm chuẩn thiết kế REST API & Route Parameter Validation)
Mức ưu tiên (Priority)	**Medium (P2)**
Test Case phát hiện	`TC_FR17_26` (Chuỗi ký tự không hợp lệ, Single Fault)
GitHub Issue Link	Issue #36: [BUG] [FR-17][Backend API] Endpoint DELETE /api/admin/coupons/:id accepts malformed string ID 'abc' with HTTP 200 OK instead of HTTP 400 Bad Request
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`.
- Đã đăng nhập tài khoản Quản trị viên (`admin@eshop.com`).

2. Các bước tái hiện (Steps to Reproduce):

1. Đăng nhập tài khoản Admin lấy token xác thực:

```
ADMIN_TOKEN=$(curl -s -X POST http://localhost:3000/api/login \
  -H "Content-Type: application/json" \
  -d '{"email":"admin@eshop.com","password":"Admin123!"}' | jq -r .token)
```

2. Gửi request DELETE tới coupon với ID chuỗi `'abc'`:

```
curl -i -s -X DELETE http://localhost:3000/api/admin/coupons/abc \
  -H "Authorization: Bearer $ADMIN_TOKEN"
```

3. Quan sát phản hồi HTTP status code và body.

3. Dữ liệu thử nghiệm (Test Data):

- Route: `DELETE /api/admin/coupons/abc`
- Header: `Authorization: Bearer $ADMIN_TOKEN`

4. Kết quả mong đợi (Expected Result theo SRS FR-17 & API Spec §6.4):

> *Trích dẫn SRS FR-17:* "Quản trị viên có thể xóa mã giảm giá... Tham số định danh tài nguyên (ID) phải là số nguyên dương."

- Khóa chính định danh tài nguyên bắt buộc là số nguyên dương ($ID \ge 1$). Chuỗi ký tự không phải số `:id = 'abc'` thuộc Lớp tương đương không hợp lệ (`RES-17-05`).
- Backend API bắt buộc phải validate kiểu dữ liệu tham số và từ chối với mã lỗi **HTTP 400 Bad Request** (`{"error": "ID mã giảm giá không hợp lệ"}`).
- Không được thông báo thành công giả ("Coupon deleted").

5. Kết quả thực tế (Actual Result):

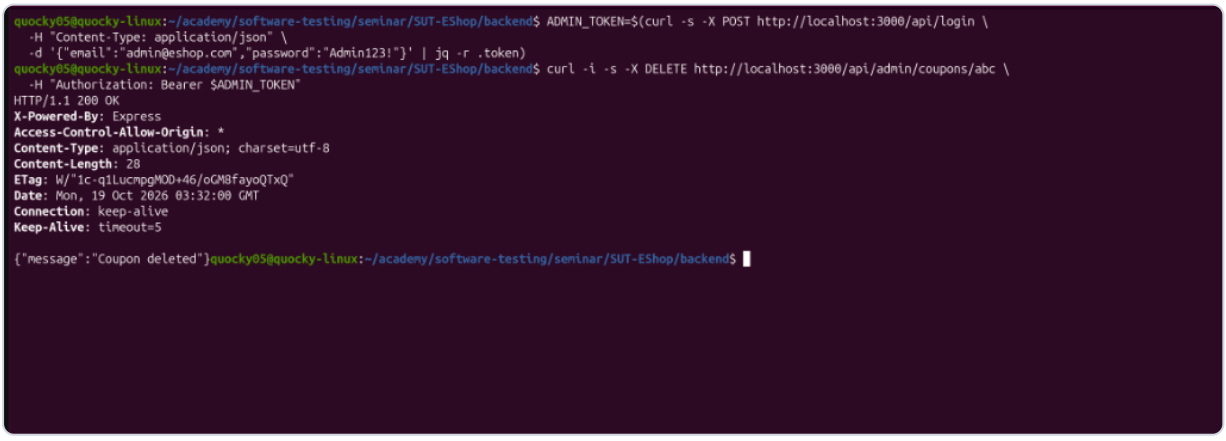
- Endpoint `DELETE /api/admin/coupons/:id` hoàn toàn không có bước kiểm tra kiểu dữ liệu của tham số `:id`.
- Hệ thống trả về **`HTTP/1.1 200 OK`**:

```
{"message":"Coupon deleted"}
```

- Báo thành công xóa tài nguyên đối với một ID chuỗi ký tự phi lý.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp terminal thực thi DELETE ID 'abc' và nhận HTTP 200 OK:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/36

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `backend/server.js`, dòng 483–487:

    ```
    app.delete("/api/admin/coupons/:id", authenticateToken, (req, res) => {
      db.run("DELETE FROM coupons WHERE id = ?", [req.params.id], function (err) {
        if (err) return res.status(500).json({ error: err.message });
        res.json({ message: "Coupon deleted" });
      });
    });
    ```

    Trực tiếp chuyển `req.params.id` vào truy vấn SQLite mà không parse sang số hay kiểm tra `isNaN(id)`.
- **Khắc phục:**
  - Parse và kiểm tra `isNaN` trước khi truy vấn:

    ```
    app.delete("/api/admin/coupons/:id", authenticateToken, (req, res) => {
      const id = Number(req.params.id);
      if (isNaN(id) || id <= 0) {
        return res.status(400).json({ error: "ID mã giảm giá không hợp lệ" });
      }
      db.run("DELETE FROM coupons WHERE id = ?", [id], function (err) {
        if (err) return res.status(500).json({ error: err.message });
        if (this.changes === 0) {
          return res.status(404).json({ error: "Mã giảm giá không tồn tại" });
        }
        res.json({ message: "Coupon deleted" });
      });
    });
    ```

[BUG-FR17-16] Công thức tính tiền giảm giá coupon loại percent bị đảo ngược khiến tổng thanh toán tăng gấp 10 lần

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-16`
Tiêu đề Bug	`[FR-17][Checkout] Percent coupon discount calculation formula is inverted causing 10x order total increase`
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá & FR-09: Áp dụng mã giảm giá tại Checkout (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Critical** (Lỗi tính toán số học tài chính / Chiết khấu âm làm đội giá đơn hàng nghiêm trọng)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR17_27` (Tính toán số học chiết khấu phần trăm, Quy tắc `CPN-BR-01`)
GitHub Issue Link	Issue #37: [BUG] [FR-17][Checkout] Percent coupon discount calculation formula is inverted causing 10x order total increase
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`.

- Web Frontend đang chạy tại `http://localhost:5173`.
- Mã giảm giá theo phần trăm `SAVE10` đang kích hoạt (`type="percent"`, `discount_value=10`, `min_order_amount=300000`).
- Đã đăng nhập tài khoản Khách hàng (`test@eshop.com`).

2. Các bước tái hiện (Steps to Reproduce):

1. Đăng nhập Web Client tại `http://localhost:5173/login`.
2. Thêm sản phẩm (ví dụ: iPhone 15 Pro Max) vào giỏ hàng và tiến hành vào trang Xác nhận Đơn hàng (`http://localhost:5173/checkout`).
3. Giá trị đơn hàng là `30.000.000 ₫`.
4. Tại ô "Mã Giảm Giá", nhập `SAVE10` và bấm nút **"Áp dụng"**.
5. Quan sát dòng thông báo giảm giá, số tiền tiết kiệm và tổng thanh toán hiển thị.

3. Dữ liệu thử nghiệm (Test Data):

- Tổng đơn hàng: `30.000.000 ₫`
- Mã coupon: `SAVE10` (`type="percent"`, `discount_value=10`)
- Endpoint API: `POST /api/apply-coupon` với payload `{"code":"SAVE10","total_amount":30000000,"user_id":2}`

4. Kết quả mong đợi (Expected Result theo SRS FR-09 & FR-17 / CPN-BR-01):

> *Trích dẫn SRS FR-09 & FR-17:* "Khi áp dụng mã theo phần trăm, số tiền giảm = Tổng giá trị đơn hàng * (Phần trăm giảm / 100). Tổng thanh toán sau giảm = Tổng đơn hàng - Số tiền giảm."

- Với đơn hàng `30.000.000 ₫` và mã giảm giá `10%`:
  - Số tiền tiết kiệm (giảm giá): $30.000.000 \times 10% = 3.000.000\text{ ₫}$.
  - Tổng thanh toán: $30.000.000 - 3.000.000 = 27.000.000\text{ ₫}$.

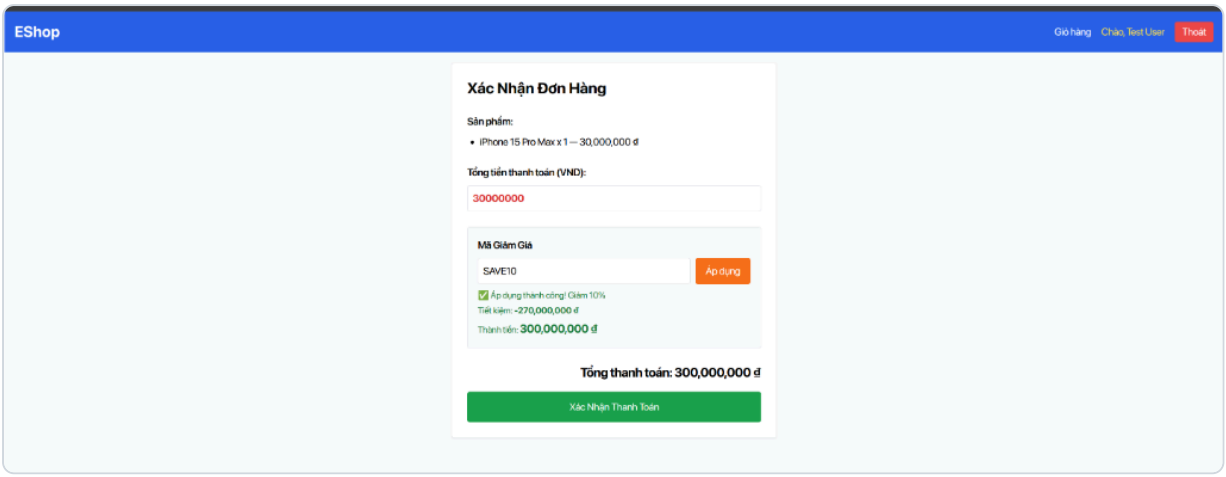
5. Kết quả thực tế (Actual Result):

- Hệ thống tính toán sai lệch hoàn toàn về mặt số học tài chính:
  - Thông báo: `✅ Áp dụng thành công! Giảm 10%`
  - Tiết kiệm: **`-270.000.000 ₫`** (Chiết khấu thành một số âm 270 triệu đồng!)
  - Thành tiền: **`300.000.000 ₫`** (Tăng vọt gấp 10 lần so với đơn gốc!)
  - Tổng thanh toán: **`300.000.000 ₫`**
- Phản hồi từ Backend API `POST /api/apply-coupon`:


```
{"success":true,"coupon_id":1,"discount_amount":-270000000,"final_amount":300000000,"message":"Áp dụng thành công! Giảm 10%"}
```


6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp màn hình Web Checkout áp dụng mã SAVE10 bị tính âm tiền tiết kiệm và đội giá gấp 10 lần:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/37

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `backend/server.js`, dòng 398–406 và 418–425:

```
let discount_amount = 0;
if (coupon.type === "percent") {
  discount_amount = Math.floor(
    total_amount * (1 - coupon.discount_value),
  );
} else {
  discount_amount = coupon.discount_value;
}
const final_amount = total_amount - discount_amount;
```

  Trường `discount_value` được lưu trong CSDL dưới dạng số nguyên (ví dụ: `10` cho 10%). Biểu thức `total_amount * (1 - coupon.discount_value)` tính ra $30.000.000 \times (1 - 10) = -270.000.000\text{ đ}$. Kế đó `final_amount = total_amount - discount_amount` tính ra $30.000.000 - (-270.000.000) = 300.000.000\text{ đ}$.
- **Khắc phục:**
  - Viết lại công thức tính tỷ lệ phần trăm chính xác:

```
let discount_amount = 0;
if (coupon.type === "percent") {
  discount_amount = Math.floor(total_amount * (coupon.discount_value / 100));
} else {
  discount_amount = coupon.discount_value;
}
const final_amount = Math.max(0, total_amount - discount_amount);
```

[BUG-FR17-17] Endpoint /api/apply-coupon từ chối đơn hàng bằng đúng ngưỡng tối thiểu tại điểm biên On-point

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-17`
Tiêu đề Bug	`[FR-17][Checkout] Endpoint /api/apply-coupon rejects orders matching exact min_order_amount at boundary On-point`

Trường thông tin	Chi tiết
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá & FR-09: Áp dụng mã giảm giá tại Checkout (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Major** (Lỗi giá trị biên Off-by-one / Vi phạm quy tắc nghiệp vụ C3)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR17_30` (BVA On-point $M = 300.000\text{ ₫}$, Quy tắc `CPN-BR-04`)
GitHub Issue Link	Issue #38: [BUG] [FR-17][Checkout] Endpoint /api/apply-coupon rejects orders matching exact min_order_amount at boundary On-point
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`.
- Web Frontend đang chạy tại `http://localhost:5173`.
- Mã giảm giá `VIP100` đang kích hoạt (`min_order_amount = 300000`, giảm cố định 100.000 ₫).
- Đã đăng nhập tài khoản Khách hàng (`test@eshop.com`).

2. Các bước tái hiện (Steps to Reproduce):

1. Đăng nhập Web Client tại `http://localhost:5173/login`.
2. Chuyển đến trang Xác nhận Đơn hàng (`http://localhost:5173/checkout`).
3. Điền ô "Tổng tiền thanh toán (VND)" bằng đúng `300000` (bằng đúng giá trị `min_order_amount = 300.000 ₫`).
4. Tại ô "Mã Giảm Giá", nhập `VIP100` và bấm nút **"Áp dụng"**.
5. Quan sát thông báo lỗi hiển thị trên giao diện và mã phản hồi HTTP.

3. Dữ liệu thử nghiệm (Test Data):

- Tổng đơn hàng: `300.000 ₫`
- Mã coupon: `VIP100` (`min_order_amount = 300000`)
- Endpoint API: `POST /api/apply-coupon` với payload `{"code":"VIP100","total_amount":300000,"user_id":2}`

4. Kết quả mong đợi (Expected Result theo SRS FR-09 Điều kiện C3 & FR-17 / CPN-BR-04):

> *Trích dẫn SRS FR-09:* "Điều kiện áp dụng mã giảm giá: Tổng giá trị đơn hàng >= Giá trị đơn hàng tối thiểu (min_order_amount)."

- Điểm biên On-point: $Total = min_order_amount = 300.000\text{ ₫}$.
- Biểu thức điều kiện $300.000 \ge 300.000$ có kết quả `true`, hệ thống bắt buộc phải **chấp nhận** áp dụng coupon thành công (**`HTTP 200 OK`**).

5. Kết quả thực tế (Actual Result):

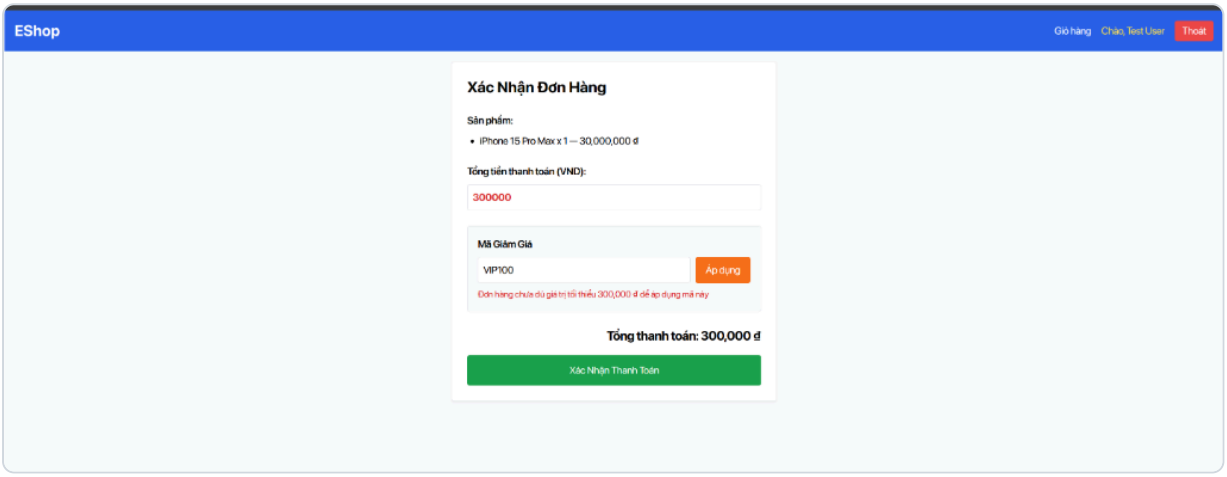
- Hệ thống từ chối áp dụng coupon với mã lỗi **`HTTP 400 Bad Request`**:

```
{"error":"Đơn hàng chưa đủ giá trị tối thiểu 300,000 ₫ để áp dụng mã này"}
```

- Trên giao diện Checkout xuất hiện thông báo lỗi màu đỏ: `Đơn hàng chưa đủ giá trị tối thiểu 300,000 ₫ để áp dụng mã này`.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp màn hình Web Checkout nhập đúng 300.000 ₫ nhưng bị từ chối coupon VIP100:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/38

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `backend/server.js`, dòng 379:

```
if (total_amount > coupon.min_order_amount) {
```

    Lập trình viên sử dụng toán tử lớn hơn ngặt (`>`) thay vì lớn hơn hoặc bằng (`>=`), dẫn đến việc loại trừ chính xác điểm biên On-point thỏa mãn điều kiện kinh doanh.
- **Khắc phục:**
  - Thay đổi toán tử so sánh sang `>=`:

```
if (total_amount >= coupon.min_order_amount) {
```

[BUG-FR17-18] Endpoint /api/apply-coupon cho phép số tiền thanh toán bị âm khi mức giảm vượt quá giá trị đơn

Trường thông tin	Chi tiết
Bug ID	`BUG-FR17-18`
Tiêu đề Bug	`[FR-17][Checkout] Endpoint /api/apply-coupon allows negative final order amount when fixed discount exceeds order total`

Trường thông tin	Chi tiết
Chức năng (Feature)	FR-17: Quản lý Mã Giảm Giá & FR-09: Áp dụng mã giảm giá tại Checkout (Pool C)
Môi trường thử nghiệm	Web: `http://localhost:5173` • Admin: `http://localhost:5174` • Backend: `http://localhost:3000` • Node v24.21 • Linux
Mức độ (Severity)	**Critical** (Lỗ hổng an toàn tài chính / Chiết khấu âm làm âm tổng tiền đơn hàng)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_FR17_34` (Boundary Underflow $Discount > Total$, Quy tắc `CPN-BR-10`)
GitHub Issue Link	Issue #39: [BUG] [FR-17][Checkout] Endpoint /api/apply-coupon allows negative final order amount when fixed discount exceeds order total
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`.
- Web Frontend đang chạy tại `http://localhost:5173`.
- Tồn tại mã giảm giá có giá trị giảm cố định lớn hơn giá trị đơn hàng (ví dụ: `BIG50K` giảm 50.000 ₫, đơn tối thiểu 0 ₫).
- Đã đăng nhập tài khoản Khách hàng (`test@eshop.com`).

2. Các bước tái hiện (Steps to Reproduce):

1. Đăng nhập Web Client tại `http://localhost:5173/login`.
2. Mở trang Xác nhận Đơn hàng (`http://localhost:5173/checkout`).
3. Nhập tổng giá trị đơn hàng là `30000` (nhỏ hơn mức giảm 50.000 ₫).
4. Tại ô "Mã Giảm Giá", nhập `BIG50K` và bấm nút **"Áp dụng"**.
5. Quan sát số tiền tiết kiệm, thành tiền và tổng thanh toán.

3. Dữ liệu thử nghiệm (Test Data):

- Tổng đơn hàng: `30.000 ₫`
- Mã coupon: `BIG50K` (`discount_value = 50000`, `min_order_amount = 0`)
- Endpoint API: `POST /api/apply-coupon` với payload `{"code":"BIG50K","total_amount":30000,"user_id":2}`

4. Kết quả mong đợi (Expected Result theo SRS FR-09 & FR-08 / CPN-BR-10):

> *Trích dẫn SRS FR-09 & FR-08:* "Tổng thanh toán sau giảm giá không bao giờ được nhỏ hơn 0 ₫. Nếu số tiền giảm lớn hơn tổng giá trị đơn hàng, số tiền giảm tối đa chỉ bằng giá trị đơn hàng và tổng thanh toán phải bằng 0 ₫."

- Đơn hàng 30.000 ₫ áp dụng mã giảm 50.000 ₫:
  - Mức giảm giá tối đa: `30.000 ₫`.
  - Tổng thanh toán: **`0 ₫`** (không được âm tiền).

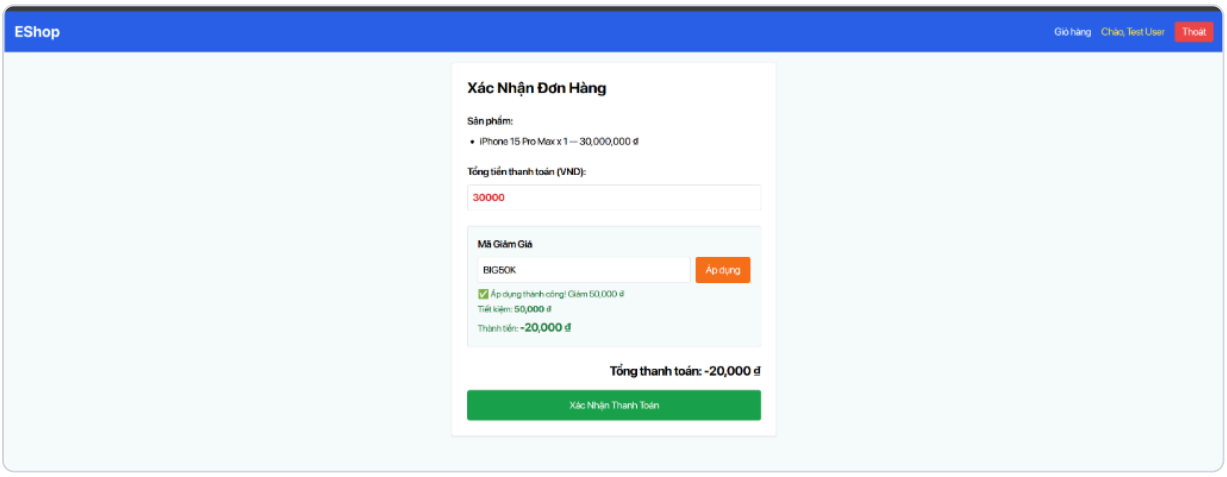
5. Kết quả thực tế (Actual Result):

- Hệ thống trừ thẳng tiền mà không có cơ chế chặn dưới 0:
  - Thông báo: `✅ Áp dụng thành công! Giảm 50,000 ₫`
  - Tiết kiệm: `50,000 ₫`
  - Thành tiền: `-20.000 ₫`
  - Tổng thanh toán: `-20.000 ₫` (Đơn hàng bị âm tiền!)
- Phản hồi từ Backend API `POST /api/apply-coupon`:


```
{"success":true,"coupon_id":16,"discount_amount":50000,"final_amount":-20000,"message":"Áp dụng thành công! Giảm 50,000 ₫"}
```


6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp màn hình Web Checkout bị âm tiền tổng thanh toán (-20.000 ₫):*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/39

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `backend/server.js`, dòng 403–406 và 423–426:

```
discount_amount = coupon.discount_value;
const final_amount = total_amount - discount_amount;
```

    Thiếu bước chuẩn hóa mức giảm không vượt quá tổng đơn hàng (`Math.min`) và chặn dưới bằng `Math.max(0, ...)`.
- **Khắc phục:**
  - Cập nhật công thức:

```
discount_amount = Math.min(total_amount, coupon.discount_value);
const final_amount = Math.max(0, total_amount - discount_amount);
```

2.4 Các lỗi thuộc Pool D: Mobile (FR-20 & FR-10) – Hủy đơn hàng theo trạng thái

[BUG-FR20-01] Endpoint PUT /api/orders/:id/cancel cho phép khách hàng tự hủy đơn ở trạng thái shipping

Trường thông tin	Chi tiết
Bug ID	`BUG-FR20-01`
Tiêu đề Bug	`[FR-20][Backend API] Endpoint PUT /api/orders/:id/cancel allows customer to cancel orders in 'shipping' status`
Chức năng (Feature)	FR-20: Tra cứu & Hủy đơn hàng Mobile / FR-10: Máy trạng thái Đơn hàng
Môi trường thử nghiệm	Backend: `http://localhost:3000` • SQLite 3 • Node v24.21 • Linux
Mức độ (Severity)	**Critical** (Vi phạm tính toàn vẹn State Machine, cho phép can thiệp đơn hàng đã xuất kho)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_MOB_05` (Bypass UI Probe / State Transition Boundary)
GitHub Issue Link	Issue #40: [BUG] [FR-20][Backend API] Endpoint PUT /api/orders/:id/cancel allows customer to cancel orders in 'shipping' status
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`.
- Trong bảng `orders`, tồn tại đơn hàng `#103` thuộc sở hữu của User 1 (`user_id = 1`) có `status = 'shipping'`.
- Người dùng User 1 đã đăng nhập thành công và sở hữu token JWT hợp lệ.

2. Các bước tái hiện (Steps to Reproduce):

1. Đăng nhập qua API `POST /api/login` với thông tin User 1 để lấy JWT Bearer token.
2. Kiểm tra CSDL xác nhận đơn hàng `#103` đang ở trạng thái `'shipping'`:

```
SELECT id, user_id, status FROM orders WHERE id = 103;
```

3. Gửi trực tiếp HTTP PUT request để yêu cầu hủy đơn `#103`:

```
curl -i -X PUT http://localhost:3000/api/orders/103/cancel \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{}'
```

4. Quan sát mã phản hồi HTTP và dữ liệu JSON trả về.
5. Kiểm tra lại trạng thái đơn hàng `#103` trong SQLite DB.

3. Dữ liệu thử nghiệm (Test Data):

- Endpoint: `PUT /api/orders/103/cancel`

- Headers: `Authorization: Bearer <user1_jwt>`, `Content-Type: application/json`
- Body: `{}`

4. Kết quả mong đợi (Expected Result theo SRS FR-10 & FR-20):

> *Trích dẫn SRS FR-10:* "Khi đơn hàng đã ở trạng thái `shipping`, User không được phép tự hủy — chỉ Admin mới có thể thao tác."

- Tầng API: Trả về HTTP Status **`400 Bad Request`** (hoặc `403 Forbidden`) kèm thông báo lỗi như `{"error": "Cannot cancel this order."}`.
- Tầng CSDL: Trường `orders.status` của đơn `#103` **bắt buộc giữ nguyên `'shipping'`**, tuyệt đối không được chuyển đổi sang `'canceled'`.

5. Kết quả thực tế (Actual Result):

- Backend chấp nhận yêu cầu và phản hồi HTTP **`200 OK`**:

```
{"message": "Order canceled successfully"}
```

- Tầng CSDL: Bản ghi đơn hàng `#103` bị cập nhật trường `status` từ `'shipping'` sang **`'canceled'`**.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp terminal thực thi API và truy vấn CSDL SQLite:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/40

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `backend/server.js`, dòng 328–331:

```
// Lẽ ra phải là: if (order.status !== 'pending' && order.status !== 'confirmed')
if (order.status === "delivered" || order.status === "canceled") {
  return res.status(400).json({ error: "Cannot cancel this order." });
}
```

Backend chỉ từ chối hai trạng thái `delivered` và `canceled`. Khi đơn hàng ở trạng thái `shipping` (đang giao), điều kiện `if` bị bỏ qua và câu lệnh `UPDATE orders SET status = 'canceled'` được thực thi.

- **Khắc phục:**
  - Sửa lại điều kiện kiểm tra chỉ cho phép hủy khi trạng thái là `pending` hoặc `confirmed`:

```
if (order.status !== "pending" && order.status !== "confirmed") {
  return res.status(400).json({ error: "Cannot cancel this order." });
}
```

[BUG-FR20-02] Endpoint PUT /api/orders/:id/cancel chấp nhận trạng thái dị thường (corrupted_state) và đổi thành canceled

Trường thông tin	Chi tiết
Bug ID	`BUG-FR20-02`
Tiêu đề Bug	`[FR-20][Backend API] Endpoint PUT /api/orders/:id/cancel mutates orders with corrupted/unknown status to 'canceled'`
Chức năng (Feature)	FR-20: Tra cứu & Hủy đơn hàng Mobile / FR-10: Máy trạng thái Đơn hàng
Môi trường thử nghiệm	Backend: `http://localhost:3000` • SQLite 3 • Node v24.21 • Linux
Mức độ (Severity)	**Medium** (Thiếu phòng thủ Robustness khi trạng thái đơn không nằm trong tập hợp trạng thái hợp lệ)
Mức ưu tiên (Priority)	**Medium (P2)**
Test Case phát hiện	`TC_MOB_08` (Robustness & State Integrity Verification)
GitHub Issue Link	Issue #41: [BUG] [FR-20][Backend API] Endpoint PUT /api/orders/:id/cancel mutates orders with corrupted/unknown status to 'canceled'
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- SUT backend đang chạy tại `http://localhost:3000`.
- Trong bảng `orders`, đơn hàng `#106` thuộc sở hữu của User 1 (`user_id = 1`) có `status = 'corrupted_state'`.
- Người dùng User 1 đã đăng nhập thành công và sở hữu token JWT hợp lệ.

2. Các bước tái hiện (Steps to Reproduce):

1. Kiểm tra CSDL xác nhận đơn hàng `#106` mang trạng thái dị thường `'corrupted_state'`:

```
SELECT id, user_id, status FROM orders WHERE id = 106;
```

2. Gửi HTTP PUT request đến endpoint hủy đơn:

```
curl -i -X PUT http://localhost:3000/api/orders/106/cancel \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{}'
```

3. Quan sát mã phản hồi HTTP và dữ liệu JSON trả về.
4. Kiểm tra lại trạng thái đơn hàng `#106` trong SQLite DB.

3. Dữ liệu thử nghiệm (Test Data):

- Endpoint: `PUT /api/orders/106/cancel`
- Headers: `Authorization: Bearer <user1_jwt>`, `Content-Type: application/json`
- Body: `{}`

4. Kết quả mong đợi (Expected Result theo SRS FR-10):

> *Trích dẫn SRS FR-10:* "Hệ thống chỉ cho phép hủy đơn hàng khi trạng thái hiện tại là `pending` hoặc `confirmed`. Mọi trạng thái khác không nằm trong danh mục chuyển đổi hợp lệ đều phải bị từ chối và giữ nguyên trạng thái cũ."

- Tầng API: Trả về HTTP Status **`400 Bad Request`** kèm thông báo lỗi từ chối.
- Tầng CSDL: Trường `orders.status` của đơn `#106` **bắt buộc giữ nguyên** **`'corrupted_state'`**, không bị ghi đè.

5. Kết quả thực tế (Actual Result):

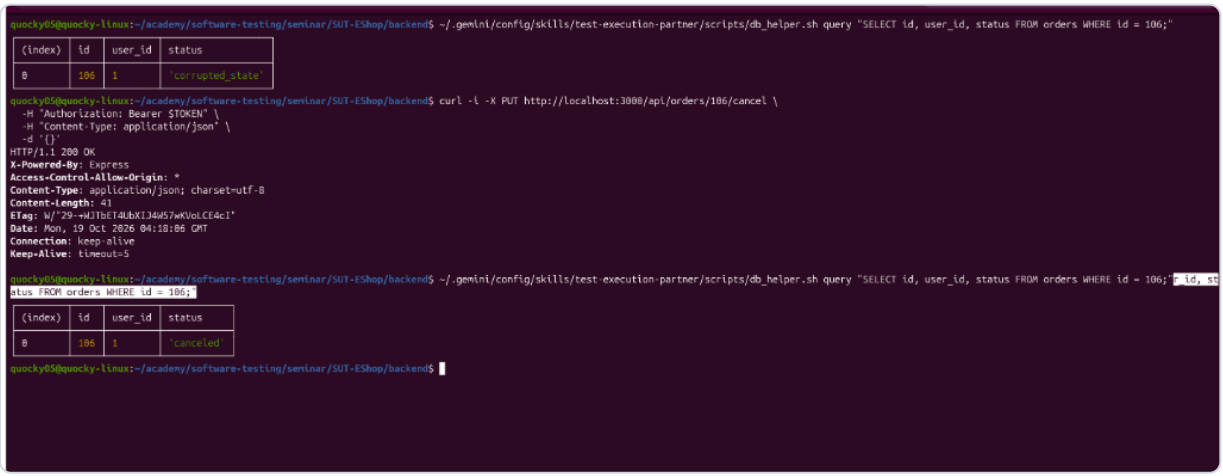
- Backend chấp nhận yêu cầu và phản hồi HTTP **`200 OK`**:

```
{"message": "Order canceled successfully"}
```

- Tầng CSDL: Bản ghi đơn hàng `#106` bị cập nhật trường `status` từ `'corrupted_state'` sang **`'canceled'`**.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp terminal thực thi API và truy vấn CSDL SQLite:*



- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/41

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `backend/server.js`, dòng 328–331:

    ```
    // Lẽ ra phải là: if (order.status !== 'pending' && order.status !== 'confirmed')
    if (order.status === "delivered" || order.status === "canceled") {
      return res.status(400).json({ error: "Cannot cancel this order." });
    }
    ```

    Logic kiểm tra áp dụng chiến lược Blacklisting không triệt để thay vì Whitelisting. Khi gặp các trạng thái dị thường ngoài mong đợi, backend vẫn cho phép cập nhật đơn sang `canceled`.
- **Khắc phục:**
  - Áp dụng nguyên tắc Whitelisting nghiêm ngặt:

    ```
    if (order.status !== "pending" && order.status !== "confirmed") {
      return res.status(400).json({ error: "Cannot cancel this order." });
    }
    ```

[BUG-FR20-03] Nút Hủy đơn trên Mobile App không hiển thị hộp thoại xác nhận Alert, kích hoạt hủy ngay khi bấm

Trường thông tin	Chi tiết
Bug ID	`BUG-FR20-03`
Tiêu đề Bug	`[FR-20][Mobile UI] Cancel order button invokes cancellation immediately without confirmation alert dialog`
Chức năng (Feature)	FR-20: Tra cứu & Hủy đơn hàng Mobile / Tiêu chuẩn an toàn giao diện Mobile (FR-21, FR-24)
Môi trường thử nghiệm	Mobile App (React Native / Expo 57) • Backend: `http://localhost:3000` • Linux
Mức độ (Severity)	**Major** (Rủi ro hành động ngoài ý muốn - Thiếu hộp thoại xác nhận cho thao tác phá hủy không thể hoàn tác)
Mức ưu tiên (Priority)	**High (P1)**
Test Case phát hiện	`TC_MOB_23` (Mobile GUI Safety Standards Verification)
GitHub Issue Link	Issue #42: [BUG] [FR-20][Mobile UI] Cancel order button invokes cancellation immediately without confirmation alert dialog
Người báo cáo	Nguyễn Quốc Kỳ (23120138)

1. Tiền điều kiện (Preconditions):

- Ứng dụng EShop Mobile App đang chạy trên Expo.
- Backend server đang hoạt động bình thường tại `http://localhost:3000`.
- Tài khoản người dùng User 1 đã đăng nhập thành công và sở hữu đơn hàng `#101` ở trạng thái `pending`.

2. Các bước tái hiện (Steps to Reproduce):

1. Mở ứng dụng Mobile App, chuyển sang màn hình **Hồ sơ** (Profile).
2. Cuộn xuống danh sách đơn hàng của tôi, định vị đơn hàng `#101` đang hiển thị trạng thái "Chờ xác nhận".
3. Nhận diện nút màu đỏ có nhãn **"Hủy đơn"**.
4. Chạm (click) vào nút "Hủy đơn".
5. Quan sát phản hồi trên màn hình: Kiểm tra xem ứng dụng có hiển thị hộp thoại xác nhận `Alert Dialog` kèm 2 nút "Hủy bỏ" và "Đồng ý" hay không.

3. Dữ liệu thử nghiệm (Test Data):

- Thành phần giao diện: Nút `TouchableOpacity` với nhãn `Hủy đơn` (`frontend-mobile/App.js:961–967`)
- Thao tác: Chạm 1 lần vào nút "Hủy đơn"

4. Kết quả mong đợi (Expected Result theo tiêu chuẩn GUI Safety FR-21 & FR-24):

> *Trích dẫn SRS:* "Đối với các thao tác mang tính phá hủy hoặc không thể hoàn tác như Hủy đơn hàng, ứng dụng Mobile bắt buộc phải kích hoạt hộp thoại xác nhận (Alert Dialog) với hai lựa chọn 'Hủy bỏ' và 'Đồng ý' trước khi gửi yêu cầu lên máy chủ."

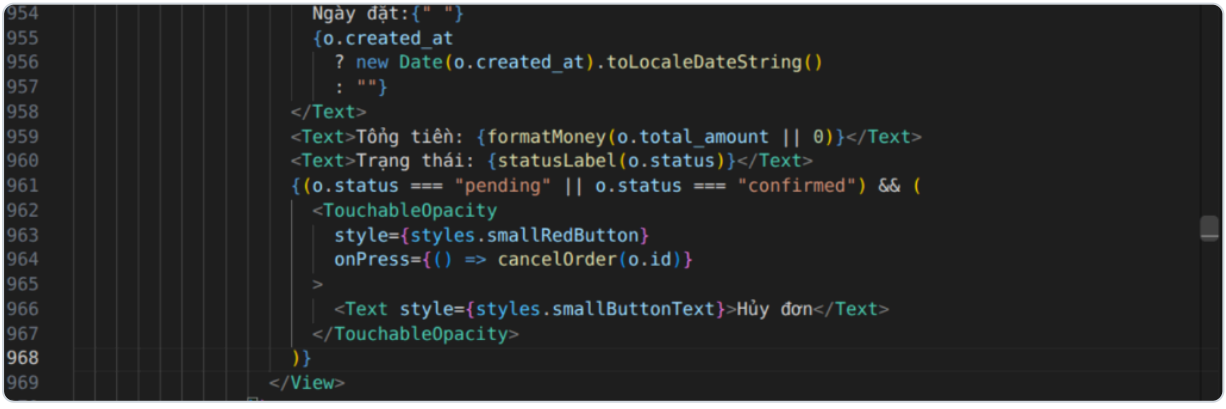
- Tầng giao diện: Màn hình phải hiển thị hộp thoại xác nhận an toàn (`Alert.alert`) hỏi người dùng: *"Bạn có chắc chắn muốn hủy đơn hàng này không?"* kèm 2 nút:
  - **"Hủy bỏ"**: Đóng hộp thoại, không gửi API, đơn `#101` giữ nguyên trạng thái.
  - **"Đồng ý"**: Chỉ gửi request hủy đơn khi người dùng xác nhận.

5. Kết quả thực tế (Actual Result):

- Ứng dụng **hoàn toàn không hiển thị bất kỳ hộp thoại xác nhận nào**.
- Vừa chạm vào nút "Hủy đơn", hàm `cancelOrder(o.id)` được gọi ngay lập tức:
  - Bắn request HTTP `PUT /api/orders/101/cancel` lên server.
  - Hiển thị pop-up thông báo thành công: `Thành công: Hủy đơn thành công!`.
  - Đơn hàng trong CSDL bị hủy ngay lập tức, tước đi quyền hủy bỏ của người dùng nếu vô tình chạm nhầm nút.

6. Bằng chứng kiểm thử (Screenshots & Logs):

- *Ảnh chụp mã nguồn nút Hủy đơn gọi trực tiếp hàm API không qua hộp thoại xác nhận:*



```
954                    Ngày đặt:{" "}
955                    {o.created_at
956                      ? new Date(o.created_at).toLocaleDateString()
957                      : ""}
958                  </Text>
959                  <Text>Tổng tiền: {formatMoney(o.total_amount || 0)}</Text>
960                  <Text>Trạng thái: {statusLabel(o.status)}</Text>
961                  {(o.status === "pending" || o.status === "confirmed") && (
962                    <TouchableOpacity
963                      style={styles.smallRedButton}
964                      onPress={() => cancelOrder(o.id)}
965                    >
966                      <Text style={styles.smallButtonText}>Hủy đơn</Text>
967                    </TouchableOpacity>
968                  )}
969                </View>
```

- *Ảnh chụp mã nguồn hàm cancelOrder thiếu logic hiển thị 2 nút xác nhận:*



```
311
312   const cancelOrder = async (orderId) => {
313     try {
314       const response = await fetch(`${API_URL}/orders/${orderId}/cancel`, {
315         method: "PUT",
316         headers: {
317           "Content-Type": "application/json",
318           Authorization: `Bearer ${token}`,
319         },
320         body: JSON.stringify({}),
321       });
322       const data = await response.json().catch(() => ({}));
323       if (!response.ok) throw new Error(data.error || "Không thể hủy đơn.");
324       Alert.alert("Thành công", "Hủy đơn thành công!");
```

- *Đường dẫn GitHub Issue:* https://github.com/faker26052005-lgtm/SUT-EShop/issues/42

7. Phân tích nguyên nhân & Khắc phục (Root Cause Analysis):

- **Vị trí lỗi:**
  - File `frontend-mobile/App.js`, dòng 961–967:

```
{(o.status === "pending" || o.status === "confirmed") && (
  <TouchableOpacity
    style={styles.smallRedButton}
    onPress={() => cancelOrder(o.id)}
  >
    <Text style={styles.smallButtonText}>Hủy đơn</Text>
  </TouchableOpacity>
)}
```

    Thuộc tính `onPress` được gắn thẳng vào `cancelOrder(o.id)` mà không kích hoạt hộp thoại cảnh báo trước khi hủy.
- **Khắc phục:**
  - Định nghĩa hàm trung gian hiển thị hộp thoại xác nhận 2 nút trước khi thực hiện request:

```
const confirmCancelOrder = (orderId) => {
  Alert.alert(
    "Xác nhận hủy đơn",
    "Bạn có chắc chắn muốn hủy đơn hàng này không?",
    [
      { text: "Hủy bỏ", style: "cancel" },
      { text: "Đồng ý", style: "destructive", onPress: () => cancelOrder(orderId) }
    ]
  );
};
```

  - Thay đổi sự kiện nút bấm: `onPress={() => confirmCancelOrder(o.id)}`.

---

3. PHÂN TÍCH NGUYÊN NHÂN LỖI & ĐÁNH GIÁ CHẤT LƯỢNG SUT

3.1 Phân Loại Lỗi Theo Bản Chất Kỹ Thuật

1. **Lỗi vi phạm giá trị biên (Boundary Off-by-one & Unbounded Inputs):**
   - Không kiểm soát biên dưới số học (≥ 0 và > 0 ở trường Coupon).

2. **Lỗi không thực thi State Machine (State Transition Bypass):**
    - Tầng UI và API chưa đồng bộ chặt chẽ với sơ đồ chuyển đổi trạng thái ở FR-10, cho phép User hủy đơn đã xuất kho (`shipping`).
3. **Lỗi bảo mật & Tiết lộ thông tin (Information Leakage & Lockout Absence):**
    - Thiếu cơ chế tạm khóa chống tấn công Brute-force tài khoản; phản hồi thông tin lỗi quá chi tiết.

3.2 Đánh Giá Chung Về Hệ Thống EShop

Hệ thống EShop đáp ứng tốt các luồng chức năng thông thường (Happy Path), nhưng bộc lộ nhiều lỗ hổng tại các điểm biên nghiệp vụ, xác thực đơn lỗi đầu vào và bảo vệ trạng thái đơn hàng. Kỹ thuật **Domain Testing** và **Boundary Value Analysis** đã chứng minh tính hiệu quả vượt trội khi phát hiện trúng các điểm yếu này.